



**Cyber security (CYBER);  
CRA;  
Cybersecurity requirements for public key infrastructure and  
digital certificate issuance software**

---

**Reference**

---

DEN/CYBER-EUS-0015

---

---

**Keywords**

---

certificate, CRA, cybersecurity, public key  
infrastructure

---

**ETSI**

---

650 Route des Lucioles  
F-06921 Sophia Antipolis Cedex - FRANCE

---

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B  
Association à but non lucratif enregistrée à la  
Sous-Préfecture de Grasse (06) N° w061004871

---

**Important notice**

---

The present document can be downloaded from the  
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,  
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to  
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our  
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

---

**Notice of disclaimer & limitation of liability**

---

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.  
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

---

**Copyright Notification**

---

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.

By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter. Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.  
All rights reserved.

# Contents

|                                                             |    |
|-------------------------------------------------------------|----|
| Introduction .....                                          | 8  |
| 1 Scope .....                                               | 9  |
| 2 References .....                                          | 9  |
| 2.1 Normative references .....                              | 9  |
| 2.2 Informative references .....                            | 9  |
| 3 Definition of terms, symbols and abbreviations .....      | 11 |
| 3.1 Terms .....                                             | 11 |
| 3.2 Symbols .....                                           | 12 |
| 3.3 Abbreviations .....                                     | 12 |
| 4 Product context .....                                     | 13 |
| 4.0 Introduction .....                                      | 13 |
| 4.1 Product Functions .....                                 | 14 |
| 4.2 Product Architecture .....                              | 15 |
| 4.3 Operational Environment .....                           | 17 |
| 4.3.1 General description .....                             | 17 |
| 4.3.2 Physical/Hardware environment .....                   | 17 |
| 4.3.3 Logical/Software environment .....                    | 17 |
| 4.3.4 Connectivity aspects .....                            | 17 |
| 4.4 Distribution of Security Functions .....                | 18 |
| 4.5 Users .....                                             | 18 |
| 4.6 Use cases .....                                         | 18 |
| 4.6.1 Private PKI for non critical sectors (UC1) .....      | 19 |
| 4.6.2 Private PKI for critical entities (UC2) .....         | 19 |
| 4.6.3 Public PKI for critical entities (UC3) .....          | 19 |
| 4.6.4 Public basic PKI for critical entities (UC4) .....    | 20 |
| 4.6.5 Multi-authority PKI for critical entities (UC5) ..... | 20 |
| 5 Technical requirements for the products .....             | 20 |
| 5.1 Introduction - Applicability of the requirements .....  | 20 |
| 5.2 No known exploitable vulnerabilities .....              | 21 |
| 5.3 Secure by default configuration .....                   | 21 |
| 5.3.1 SBDC- Access control .....                            | 21 |
| 5.3.2 SBDC- Monitoring .....                                | 21 |
| 5.3.3 SBDC- Cryptography .....                              | 21 |
| 5.3.4 SBDC- Certificates .....                              | 22 |
| 5.4 Secure updates .....                                    | 22 |
| 5.5 Authentication and access control .....                 | 22 |
| 5.6 Confidentiality .....                                   | 23 |
| 5.6.1 CON - General .....                                   | 23 |
| 5.6.2 CON - Secure storage and communications .....         | 25 |
| 5.6.3 CON - Key management .....                            | 25 |
| 5.7 Integrity .....                                         | 25 |
| 5.7.1 INT - Monitoring .....                                | 25 |
| 5.7.2 INT - Certificate signing .....                       | 27 |
| 5.7.3 INT- CRL signing .....                                | 27 |
| 5.8 Data minimisation .....                                 | 27 |
| 5.8.1 DM - General .....                                    | 28 |
| 5.8.2 DM - Secret management .....                          | 28 |
| 5.9 Availability protection .....                           | 28 |
| 5.9.1 AP - Certificate suspension and revocation .....      | 28 |
| 5.9.2 AP - Certificate status services .....                | 29 |
| 5.9.3 AP - Key management .....                             | 30 |
| 5.10 Impact minimisation .....                              | 30 |
| 5.11 Minimisation of attack surfaces .....                  | 30 |
| 5.12 Exploitation mitigation mechanisms .....               | 31 |
| 5.12.1 EMM - Certificate issuance .....                     | 31 |

|        |                                                                      |    |
|--------|----------------------------------------------------------------------|----|
| 5.12.2 | EMM - Certificate status.....                                        | 33 |
| 5.12.3 | EMM - Certificate re-key .....                                       | 34 |
| 5.12.4 | EMM - Certificate modification .....                                 | 34 |
| 5.13   | Logging and monitoring.....                                          | 34 |
| 5.14   | Data removal and transparency .....                                  | 35 |
| 5.14.1 | DRT - Secret management.....                                         | 36 |
| 6      | Assessment criteria for compliance with technical requirements ..... | 36 |
| 6.1    | Introduction to the assessment and compliance criteria .....         | 36 |
| 6.2    | No known exploitable vulnerabilities.....                            | 38 |
| 6.3    | Secure by default configuration.....                                 | 39 |
| 6.3.1  | SBDC - Access control .....                                          | 39 |
| 6.3.2  | SBDC - Monitoring .....                                              | 40 |
| 6.3.3  | SBDC - Cryptography .....                                            | 41 |
| 6.3.4  | SBDC - Certificates .....                                            | 42 |
| 6.4    | Secure updates.....                                                  | 43 |
| 6.5    | Authentication and access control .....                              | 45 |
| 6.5.1  | AC - General.....                                                    | 45 |
| 6.6    | Confidentiality.....                                                 | 46 |
| 6.6.1  | CON - General.....                                                   | 47 |
| 6.6.2  | CON - Secure storage and communications .....                        | 50 |
| 6.6.3  | CON - Key management.....                                            | 51 |
| 6.7    | Integrity.....                                                       | 53 |
| 6.7.1  | INT - Monitoring .....                                               | 53 |
| 6.7.2  | INT - Certificate signing.....                                       | 56 |
| 6.7.3  | INT- CRL signing.....                                                | 57 |
| 6.8    | Data minimisation .....                                              | 58 |
| 6.8.1  | General.....                                                         | 58 |
| 6.8.2  | DM - Secret management .....                                         | 61 |
| 6.9    | Availability protection.....                                         | 62 |
| 6.9.1  | AP - Certificate suspension and revocation .....                     | 62 |
| 6.9.2  | AP - Certificate status services .....                               | 65 |
| 6.9.3  | AP - Key management.....                                             | 67 |
| 6.10   | Impact minimisation.....                                             | 68 |
| 6.11   | Minimisation of attack surfaces.....                                 | 69 |
| 6.12   | Exploitation mitigation mechanisms .....                             | 70 |
| 6.12.1 | EMM - Certificate issuance .....                                     | 70 |
| 6.12.2 | EMM - Certificate status.....                                        | 75 |
| 6.12.3 | EMM - Certificate re-key .....                                       | 78 |
| 6.12.4 | EMM - Certificate modification .....                                 | 78 |
| 6.13   | Logging and monitoring.....                                          | 79 |
| 6.14   | Data removal and transparency .....                                  | 83 |

|                               |                                                                                                                                       |           |
|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>Annex A (informative):</b> | <b>Relationship between the present document and the requirements of EU Regulation (EU) 2024/2847 – the Cyber Resilience Act.....</b> | <b>86</b> |
|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|-----------|

|                               |                                                            |           |
|-------------------------------|------------------------------------------------------------|-----------|
| <b>Annex B (informative):</b> | <b>Security analysis.....</b>                              | <b>89</b> |
| B.1                           | Risk calculation.....                                      | 89        |
| B.2                           | Risk Assessment.....                                       | 90        |
| B.2.1                         | Likelihood risk factors.....                               | 90        |
| B.2.1.1                       | Deployment.....                                            | 90        |
| B.2.1.2                       | Network and Physical security .....                        | 91        |
| B.2.1.3                       | User expertise.....                                        | 91        |
| B.2.1.4                       | Interface exposure .....                                   | 91        |
| B.2.2                         | Impact risk factors .....                                  | 91        |
| B.3                           | Evaluate Risks .....                                       | 91        |
| B.4                           | Requirements applicability - threats mapping rational..... | 100       |

|                                  |            |
|----------------------------------|------------|
| <b>Annexes C to J: Void.....</b> | <b>110</b> |
|----------------------------------|------------|

|                             |                                                               |            |
|-----------------------------|---------------------------------------------------------------|------------|
| <b>Annex K (normative):</b> | <b>Generic cryptographic requirements and assessment.....</b> | <b>111</b> |
|-----------------------------|---------------------------------------------------------------|------------|

|     |                   |     |
|-----|-------------------|-----|
| K.1 | Cryptography..... | 111 |
|-----|-------------------|-----|

|                                                         |                                                                     |            |
|---------------------------------------------------------|---------------------------------------------------------------------|------------|
| K.1.1                                                   | Requirement .....                                                   | 111        |
| K.1.2                                                   | Assessment of product cryptographic configuration .....             | 112        |
| K.1.2.0                                                 | General.....                                                        | 112        |
| K.1.2.1                                                 | Assessment of ACM-listed cryptographic mechanisms.....              | 112        |
| K.1.2.1.1                                               | Assessment objective .....                                          | 112        |
| K.1.2.1.2                                               | Assessment preparation.....                                         | 112        |
| K.1.2.1.3                                               | Assessment activities .....                                         | 112        |
| K.1.2.1.4                                               | Assessment evidence.....                                            | 112        |
| K.1.2.1.5                                               | Assessment verdict.....                                             | 113        |
| K.1.2.2                                                 | Assessment of ACM-extended cryptographic mechanisms.....            | 113        |
| K.1.2.2.1                                               | Assessment objective .....                                          | 113        |
| K.1.2.2.2                                               | Assessment preparation.....                                         | 113        |
| K.1.2.2.3                                               | Assessment activities .....                                         | 113        |
| K.1.2.2.4                                               | Assessment evidence.....                                            | 114        |
| K.1.2.2.5                                               | Assessment verdict.....                                             | 114        |
| K.1.2.3                                                 | Assessment of interoperability-based cryptographic mechanisms.....  | 114        |
| K.1.2.3.1                                               | Assessment objective .....                                          | 114        |
| K.1.2.3.2                                               | Assessment preparation.....                                         | 114        |
| K.1.2.3.3                                               | Assessment activities .....                                         | 114        |
| K.1.2.3.4                                               | Assessment evidence.....                                            | 115        |
| K.1.2.3.5                                               | Assessment verdict.....                                             | 115        |
| K.2                                                     | Crypto agility.....                                                 | 115        |
| K.2.1                                                   | Requirement .....                                                   | 115        |
| K.2.2                                                   | Assessment of crypto-agility .....                                  | 116        |
| K.2.2.1                                                 | Assessment objective.....                                           | 116        |
| K.2.2.2                                                 | Assessment preparation .....                                        | 116        |
| K.2.2.3                                                 | Assessment activities .....                                         | 117        |
| K.2.2.4                                                 | Assessment evidence .....                                           | 117        |
| K.2.2.5                                                 | Assessment verdict .....                                            | 117        |
| K.3                                                     | ACM-extended cryptographic mechanisms .....                         | 117        |
| K.3.1                                                   | Requirement .....                                                   | 117        |
| K.3.2                                                   | List of ACM-extended cryptographic mechanisms.....                  | 118        |
| K.3.3                                                   | Assessment.....                                                     | 118        |
| K.4                                                     | Interoperability-based cryptographic mechanisms.....                | 118        |
| K.4.1                                                   | Requirement .....                                                   | 118        |
| K.4.2                                                   | List of interoperability-based cryptographic mechanisms.....        | 118        |
| K.4.3                                                   | Assessment.....                                                     | 118        |
| <b>Annexes I to T: Void.....</b>                        |                                                                     | <b>119</b> |
| <b>Annex U (informative): Use case description.....</b> |                                                                     | <b>120</b> |
| U.1                                                     | UC1 - Product for use in Private PKI for non critical sectors ..... | 120        |
| U.1.1                                                   | UC1 - General description.....                                      | 120        |
| U.1.2                                                   | UC1 - Product Functions and assets .....                            | 122        |
| U.1.2.1                                                 | UC1 - List of functions .....                                       | 122        |
| U.1.2.2                                                 | UC1 - Assets .....                                                  | 123        |
| U.1.3                                                   | UC1 - Operational Environment .....                                 | 123        |
| U.1.4                                                   | UC1 - Distribution of Security Functions.....                       | 123        |
| U.1.5                                                   | UC1 - Users.....                                                    | 124        |
| U.2                                                     | UC2 - Product for use in Private PKI for critical entities.....     | 124        |
| U.2.1                                                   | UC2 - General description.....                                      | 124        |
| U.2.2                                                   | UC2 - List of functions.....                                        | 126        |
| U.2.2.1                                                 | UC2 - Assets .....                                                  | 127        |
| U.2.3                                                   | UC2 - Operational Environment .....                                 | 127        |
| U.2.4                                                   | UC2 - Distribution of Security Functions.....                       | 128        |
| U.2.5                                                   | UC2 - Users.....                                                    | 128        |
| U.3                                                     | UC3 - Public PKI for critical entities .....                        | 128        |
| U.3.1                                                   | General description.....                                            | 128        |

|                               |                                                             |            |
|-------------------------------|-------------------------------------------------------------|------------|
| U.3.2                         | UC3 - List of functions.....                                | 129        |
| U.3.2.1                       | UC3 - Assets .....                                          | 130        |
| U.3.3                         | UC3 - Operational Environment .....                         | 130        |
| U.3.4                         | UC3 - Distribution of Security Functions.....               | 131        |
| U.3.5                         | UC3 - Users.....                                            | 131        |
| U.4                           | UC4 - Product for use in Critical Public basic PKI.....     | 131        |
| U.4.1                         | UC4 - General description.....                              | 131        |
| U.4.2                         | UC4 - List of functions.....                                | 133        |
| U.4.2.1                       | UC4 - Assets .....                                          | 133        |
| U.4.3                         | UC4 - Operational Environment .....                         | 134        |
| U.4.4                         | UC4 - Distribution of Security Functions.....               | 134        |
| U.4.5                         | UC4 - Users .....                                           | 134        |
| U.5                           | UC5 - Product for use in Critical Multi-Authority PKI ..... | 134        |
| U.5.1                         | General description.....                                    | 134        |
| U.5.2                         | UC5 - List of functions.....                                | 136        |
| U.5.2.1                       | UC5 - Assets .....                                          | 137        |
| U.5.3                         | UC5 - Operational Environment .....                         | 138        |
| U.5.4                         | UC5 - Distribution of Security Functions.....               | 138        |
| U.5.5                         | UC5 - Users .....                                           | 138        |
| <b>Annex V (informative):</b> | <b>Change history .....</b>                                 | <b>139</b> |
| History .....                 |                                                             | 141        |

# Intellectual Property Rights

## Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

## Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

**DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

# Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's Standardisation request M/606 - C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of EU Regulation No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in Table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

| Proposed national transposition dates                                                  |                                 |
|----------------------------------------------------------------------------------------|---------------------------------|
| Date of latest announcement of this EN (doa):                                          | 3 months after ETSI publication |
| Date of latest publication of new National Standard or endorsement of this EN (dop/e): | 6 months after doa              |
| Date of withdrawal of any conflicting National Standard (dow):                         | 18 months after doa             |

---

## Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

---

## Introduction

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

Clause 4 does not contain technical requirements; it describes the product context that is considered for the application of the present document.

Clause 4 also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

Clause 5 specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

Clause 6 specifies the assessment criteria and compliance verification procedures with the requirements of Clause 5.

Annex A maps the technical requirements of the present document with the essential requirements of the CRA [i.1] regulation.

Annex B informs about the methodology used to assess the security risks of the products in their context.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex U defines in more details the use cases contexts and parameters.



---

# 1 Scope

The present document specifies technical requirements and corresponding assessment criteria for public key infrastructure and digital certificate issuance software related to cybersecurity. The products with digital elements in scope, thereafter "the Products":

- are specified within the "technical description" of the "category of product" number "9" by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as:  
"Products with digital elements used as part of a public key infrastructure (PKI) that manage the validation, creation, issuance, distribution, status publication, renewal or revocation of digital certificates, or the generation, storage, escrow, exchange, destruction or rotation of cryptographic keys associated with such digital certificates. This category includes but is not limited to key management systems, digital certificate management systems, online certificate status protocol responders and all-in-one PKI solutions".
- are only covered within the product context described in clause 4.

The present document covers those Products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] Annex I Part I under the conditions identified in annex A.

Different use cases representing different product architecture are presented in clause 4.6. Requirements applicability in clause 5 then defines which requirements apply to which use case to ensure compliance with the CRA's essential cybersecurity requirements.

---

# 2 References

## 2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] ENISA Report 1747792503: "[European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms](#) - version 2" – April 2025.
- [2] [Recommendation ITU-T X.509 \(10/2019\)](#): "Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks".

NOTE: Identical text in the defining of public-key and attribute certificates is also available in ISO/IEC 9594-8 (paywall).

- [3] [IEEE Std 1609.2™-2025](#) "(2025)": "Standard for Wireless Access in Vehicular Environments - Security Services for Applications and Management Messages".
- [4] [IETF RFC 6960](#) (June 2013): "X.509 Internet Public Key Infrastructure Online Certificate Status Protocol - OCSP".

## 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
- [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
- [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
- [i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements - Vocabulary", produced by CEN CENELEC.

NOTE: Version and date to be added upon its publication by CEN CENELEC.

- [i.5] IETF RFC 4120: "The Kerberos Network Authentication Service (V5) - July 2005".
- [i.6] ETSI GS NFV 003 (V1.4.1) (2018-08): "Network Functions Virtualisation (NFV); Terminology for Main Concepts in NFV".
- [i.7] ETSI TS 102 941 (V2.2.1) (11-2022): "Intelligent Transport Systems (ITS); Security; Trust and Privacy Management; Release 2".
- [i.8] ETSI TS 102 165-2 (V4.2.1): "Telecommunications and Internet converged Services and Protocols for Advanced Networking (TISPAN); Methods and protocols; Part 2: Protocol Framework Definition; Security Counter Measures".
- [i.9] ETSI TS 133 501: "5G; Security architecture and procedures for 5G System (3GPP TS 33.501). .
- [i.10] ETSI EN 319 411-1 (V1.5.1) (04-2025): "Electronic Signatures and Trust Infrastructures (ESI); Policy and security requirements for Trust Service Providers issuing certificates; Part 1: General requirements".
- [i.11] [EU C-ITS Certificate policy](#).
- [i.12] [EU C-ITS Security Policy](#).
- [i.13] [Directive \(EU\) 2023/2661](#) of the European Parliament and of the Council of 22 November 2023 amending Directive 2010/40/EU on the framework for the deployment of Intelligent Transport Systems in the field of road transport and for interfaces with other modes of transport. .
- [i.14] ETSI TS 103 097: "Intelligent Transport Systems (ITS); Security; Security header and certificate formats; Release 2".
- [i.15] ETSI TR 119 540 (V1.1.1) (10-2025): "Electronic Signatures and Trust Infrastructures (ESI); Standardization requirements for Smart Contracts based on Electronic Ledgers".
- [i.16] ETSI TS 102 940 (V2.1.1) (07-2021): "Intelligent Transport Systems (ITS); Security; ITS communications security architecture and security management; Release 2".
- [i.17] prEN 40000-1-3: "Cybersecurity requirements for products with digital elements – Vulnerability Handling", produced by CEN CENELEC. .

NOTE: Version and date to be added upon its publication by CEN CENELEC.

- [i.18] IETF RFC 5280: "Intelligent Transport Systems (ITS); Security; Security header and certificate formats; Release 2".
- [i.19] [Directive \(EU\) 2022/2557](#) of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC".
- [i.20] NIST SP 800-130: "A Framework for Designing Cryptographic Key Management Systems" - August 2013.
- [i.21] [Regulation \(EU\) 2016/679](#) of the European Parliament and ff the council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC.

---

## 3 Definition of terms, symbols and abbreviations

### 3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

**certificate:** public key of a user, together with some other information, rendered un-forgeable by encipherment with the private key of the certification authority which issued it

NOTE: See ETSI EN 319 411-1 [i.10].

**Certificate Policy (CP):** named set of rules that indicates the applicability of a certificate to a particular community and/or class of application with common security requirements

NOTE: See ETSI EN 319 411-1 [i.10].

**Certificate Revocation List (CRL):** signed list indicating a set of certificates that have been revoked by the certificate issuer.

NOTE: See ETSI EN 319 411-1 [i.10].

**Certification Authority (CA):** authority trusted by one or more users to create and assign certificates

NOTE: See ETSI EN 319 411-1 [i.10].

**critical entities:** critical entities as defined by Directive (EU) 2022/2557.

NOTE: See [Directive \(EU\) 2022/2557 – Resilience of Critical Entities \(CER\)](#) [i.19].

**Cryptographic Key Management System (KMS):** Framework and services that provide for the generation, production, establishment, control, accounting, and destruction of cryptographic keys. It includes all elements (policies, procedures, devices, and components), facilities, personnel, and information products that form the system that establishes, manages, and supports cryptographic products and services for end entities.

NOTE: See NIST SP 800-130 [i.20].

**digital signature:** data appended to, or a cryptographic transformation of a data unit that allows a recipient of the data unit to prove the source and integrity of the data unit and protect against forgery e.g. by the recipient

NOTE: See ETSI EN 319 411-1 [i.10].

**personal data:** any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person

NOTE: See [Regulation \(EU\) 2016/679 \(GDPR\)](#) [i.21].

**PKI Software:** software implementing the PKI services, including, Registration, Certificate generation, Dissemination, Revocation management, Certificate status, Logging of security events, User accounts management

**product:** product with Digital Elements in the scope of the present document

NOTE: [Cyber Resilience Act \(Regulation \(EU\) 2024/2847\)](#) [i.1].

**Registration Authority (RA):** entity that is responsible for identification and authentication of subjects of certificates mainly

NOTE: See ETSI EN 319 411-1 [i.10].

**secure cryptographic:** device which holds the user's private key, protects this key against compromise and performs signing or decryption functions on behalf of the user

NOTE: See ETSI EN 319 411-1 [i.10].

## 3.2 Symbols

Void.

## 3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

|       |                                                         |
|-------|---------------------------------------------------------|
| AA    | Authorisation Authority                                 |
| AE    | Authentication Entity                                   |
| AES   | Advanced Encryption Standard                            |
| AID   | Authentication Identifier                               |
| AP    | Access Point                                            |
| API   | Application Programming Interface                       |
| ARC   | Architecture                                            |
| AT    | Authorisation Ticket                                    |
| C-ITS | Cooperative ITS                                         |
| CA    | Certification Authority                                 |
| CARL  | Certification Authority Revocation List                 |
| CEN   | Comité Européen de Normalisation                        |
| COM   | Communications                                          |
| CP    | Certificate Policy                                      |
| CPOC  | C-ITS-Point of Contact                                  |
| CPS   | Certification Practice Statement                        |
| CRA   | Cyber Resilience Act                                    |
| CRL   | Certificate Revocation List                             |
| CRY   | Cryptography                                            |
| CSA   | Cybersecurity Act                                       |
| CSP   | Cloud Service Provider / Cryptographic Service Provider |
| CSR   | Certificate Signing Request                             |
| CTL   | Certificate Trust List                                  |
| DC    | Distribution Center                                     |
| EA    | Enrolment Authority (similar to LTCA)                   |
| EC    | Enrolment Credential (similar to LTC)                   |
| ECTL  | Extended Certificate Trust List                         |
| HMAC  | Hash-based Message Authentication Code                  |
| HMI   | Human-Machine Interface                                 |
| HSM   | Hardware Security Module                                |
| IEEE  | Institute of Electrical and Electronics Engineers       |
| IT    | Information Technology                                  |
| ITS   | Intelligent Transport System                            |
| KMS   | Key Management System                                   |
| LAN   | Local Area network                                      |
| MA    | Misbehaviour Authority                                  |

|       |                                    |
|-------|------------------------------------|
| NA    | National Accreditation             |
| CSP   | Online Certificate Status Protocol |
| PKC   | Public Key Certificate             |
| PKI   | Public Key Infrastructure          |
| POE   | Physical Operational Environment   |
| PP    | Protection Profile                 |
| RA    | Registration Authority             |
| RBAC  | Role-Based Access Control          |
| RCA   | Root Certificate Authority         |
| RCS   | Remote Control System              |
| SCD   | Secure Cryptographic Device        |
| SHA   | Secure Hash Algorithm              |
| SOE   | Software Operational Environment   |
| SOTA  | State of the Art                   |
| SP    | Security Profile                   |
| SSO   | Single Sign-on                     |
| SSP   | Service Specific Permission        |
| SubCA | Subordinate Certificate Authority  |
| TAE   | Target of Assessment               |
| TLM   | Trust List Manager                 |
| TLS   | Transport Layer Security           |
| TPM   | Trusted Platform Module            |
| TSL   | Trust-service Status List          |
| TSP   | Trust Service Provider             |
| UC    | Use Case                           |
| URL   | Uniform Resource Locator           |
| VCS   | Version Control System             |
| VPN   | Virtual Private Network            |

---

## 4 Product context

### 4.0 Introduction

The technical requirements of the present document apply under the product context described herein, which shall be in accordance with its intended use. The equipment shall comply with all the technical requirements of the present document at all times when operating in such product context.

A PKI is a system that enables the management of public keys, and requires that the private key is kept secret. The assurance of the secrecy of the private key is most often achieved by maintaining the secret key in a hardware security module and limiting access to the key to cryptographic functions in such a way that the secret key itself is never visible externally to the device. Assertions that are signed by the private key similarly require that only the device holding the private key is able to create the signature. Verifications of signed attestations need access to the public key of the signer, and often that public key is distributed in a Public Key Certificate (PKC) that is stored securely on the verifying device.

**NOTE:** A public key has limited security value as it is intended to be known to all, but the PKC may contain some identifying information and therefore the PKC content should be protected in accordance with any general data protection rules for personal, or Personal Identifying Information (PII).

The present document describes product contexts for products with digital elements used as part of a Public Key Infrastructure (PKI) that manage the validation, creation, issuance, distribution, status publication, renewal or revocation of digital certificates, or the generation, storage, escrow, exchange, destruction or rotation of cryptographic keys associated with such digital certificates.

The reasonably foreseeable use of the product is to support certification services where a compromise carries a significant risk of impact to the security of other products, networks or services, or to the health, security or safety of the public.

**EXAMPLE 1:** C-ITS. In the context of the present document ETSI TS 102 941 [i.7] and the EU C-ITS Certificate Management System policy [i.11] and security profile [i.12] documents identify specific requirements on hardware elements and their certification.

EXAMPLE 2: Software used to issue certificates for public web sites and to validate the identity of web sites (these capabilities are often built into web-browsers).

EXAMPLE 3: Online Certificate Status Protocol support. Software used to verify the status of PKCs.

A single box PKI solution wherein one or more of the examples above are deployed in a single device and interfacing to other client devices within a closed environment.

## 4.1 Product Functions

Products with digital elements used as part of a public key cryptography scheme to manage asymmetric cryptographic keys and digital certificates, including their creation, issuance, distribution, validation, renewal, storage or revocation, support the functions outlined in this clause.

- **F.PublicPrivateKeyPairGen:** Generates a public-private key pair.

NOTE 1: This function may be specialised to address use cases for generation using a Secure Cryptographic Device (SCD) or without using an SCD.

- **F.ExternalKeyPairGen:** Requests the generation of a public-private key pair from an external SCD.
- **F.InternalKeyPairGen:** Generates a public-private key pair.
- **F.ExternalKeyManagement:** Requests key suppression, export, or renewal from an external SCD or KMS.
- **F.InternalKeyManagement:** Suppresses, exports, or renews software keys.
- **F.UserAccountManagement:** Creates, modifies, assigns rights to, and modify the different user accounts.
- **F.PrivateKeyImportExport:** Private keys, secret keys, or critical data can be encrypted and then exported in the form of an encrypted file.
- **F.OfficerCertGenApproval:** Authorised users can approve and execute this issuance when certificates are issued.
- **F.CertificateProfileManagement:** Administration functions to define the format and default values of certificates to be signed.
- **F.PseudonymCertIssuance:** Issues pseudonym certificates derived from long-term certificates. These certificates shall not include user identification data.
- **F.SubjectCertSignCreation:** Creates and signs subject certificates using the product's private key.
- **F.orertificateDissemination:** Distributes signed certificates to subscribers.
- **F.CertificateStatus:** Maintains certificate status information (e.g. active, expired, revoked).
- **F.PKC\_storage\_management:** Stores received PKCs and makes them available to relying parties.
- **F.SignedArtefactDissemination:** Distributes signed artefacts to subscribers.
- **F.RevocationManagement:** Processes revocation reports (e.g. CRLs) to determine the status of PKCs and may provide updates to the certificate status service (e.g. if the private key is withdrawn and the product invalidates its public key).
- **F.AuditEventManagement:** Configuration of audit events to be stored and their associated format. Includes search or erasure capabilities for stored audit events.
- **F.LoggingOfSecurityEvents:** Logs events as per the configuration enabled by F.Log\_management.
- **F.LogManagement:** Configuration of audit events to be stored and their associated format. Includes search or erasure capabilities for stored audit events.

- **F.NetworkConfiguration:** Sets up network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.).

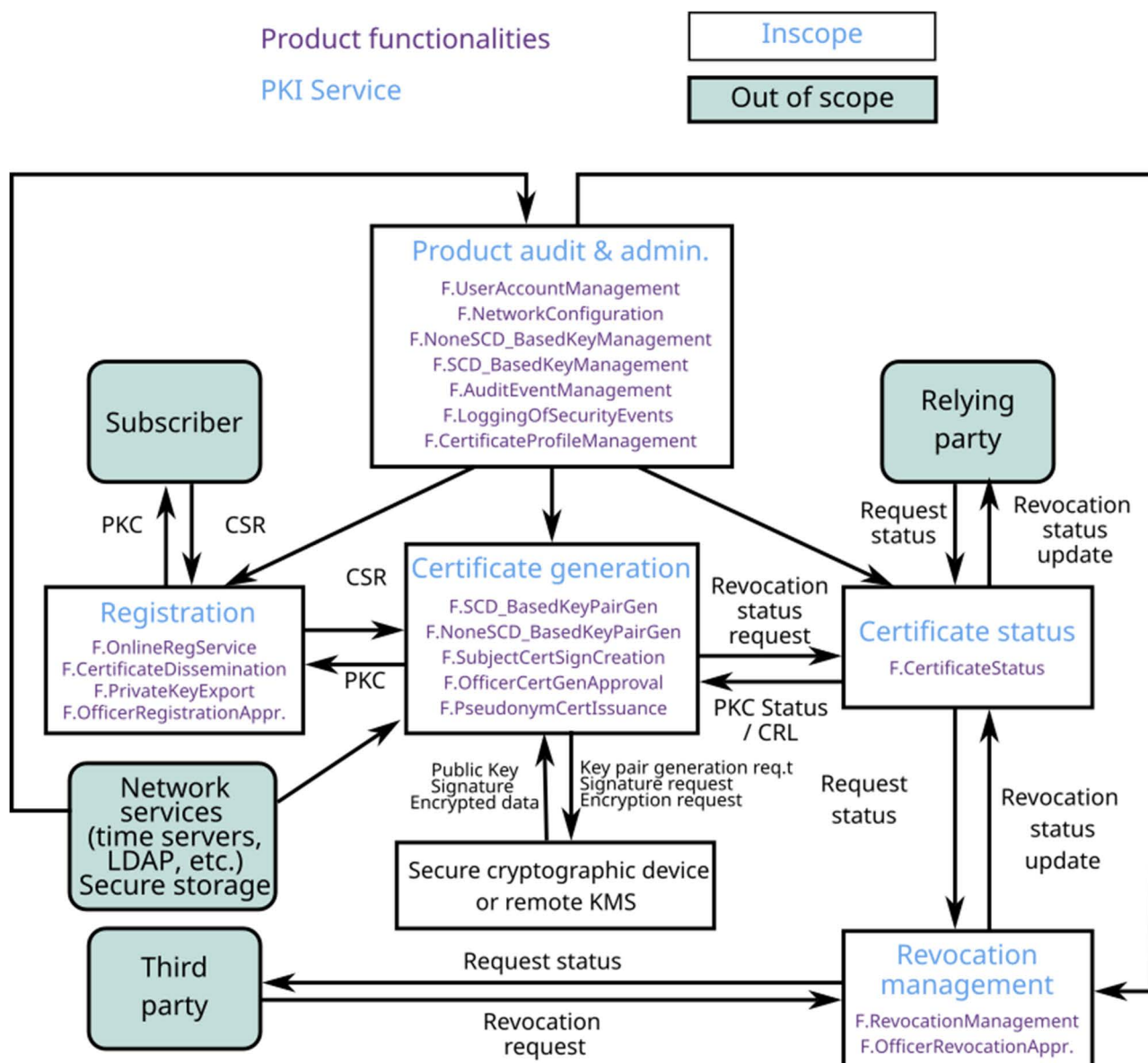
These functions operates on the following assets list.

| Category                         | Identifier                      | Asset                          | Definition                                                                         |
|----------------------------------|---------------------------------|--------------------------------|------------------------------------------------------------------------------------|
| User and Identity                | SYS02.User account data         | User Directory / Profiles      | Database of user accounts, roles, and permissions.                                 |
|                                  |                                 | User Data (Authentication)     | Credentials and identity attributes for verification.                              |
|                                  | SYS04.Authorized user data      | User Data (Officer Decisions)  | Records of privileged user approvals (e.g., for issuance/revocation).              |
| Cryptographic and trust elements | DIS01.Certificate store data    | Pseudonym Certificates         | Certificates without user identification data.                                     |
|                                  |                                 | Certificates                   | Digital certificates (e.g. X.509) binding keys to identities.                      |
|                                  | KEY01.Public Keys               | Public Keys                    | Public key from public/private key pairs for encryption, signing, or verification. |
|                                  | KEY02.Secret Keys               | Asymmetric Private Keys        | Private from public/private key pairs for encryption, signing, or verification.    |
|                                  |                                 | Symmetric Encryption Key       | Keys managed by external Secure Cryptographic Devices.                             |
|                                  | REG02.Certificate request       | Certificate Request Parameters | Technical data submitted during certificate requests.                              |
|                                  | REG01.Subscriber data           | Certificate User Data          | User identification data submitted during certificate requests.                    |
| Product administration           | STA01.Certificate status data   | CRL                            | List of revoked certificates.                                                      |
|                                  |                                 | Certificate status data        | Revocation status of issued certificates                                           |
|                                  | SYS01.System configuration data | Configuration Parameters       | Settings for PKI behavior (e.g., network, certificate profiles).                   |
| Software                         | SYS03.Event log data            | Audit Trails                   | Logs of security-relevant events.                                                  |
|                                  | SOF01.Software                  | PKI Software                   | Executed binaries.                                                                 |

**Figure 4.1-1: Assets**

## 4.2 Product Architecture

The product is defined by the integration of several key elements, including **Product audit & administration**, **Registration**, **Certificate generation**, **Certificate status**, and/or **Revocation management**. Each element exposes functions that are defined in clause 4.1. The diagram presented in **Figure 4.2-1** provides a high-level overview of the product architecture and the interactions between its constituent elements.



**Figure 4.2-1: Indicative product architecture**

In addition, the product elements may be configured in multiple ways depending on the deployment requirements:

- **ARC.Monolithic:** All components are integrated and run on a single machine or platform.
- **ARC.Distributed:** Functions are split across multiple machines or services, often communicating over a network.

The different elements are accessible through the interfaces defined below:

- **I.AuditAndAdministration** - Interface for remote access to product for administration and audit purposes.
- **I.Registration** - Online registration interface receiving remote Certificates Signing Requests from subscribers.
- **I.CertificateGeneration** - Interface with external components providing cryptographic services such as signature or key management.
- **I.CertificateStatus** - Online certificate status requests and dissemination.
- **I.RevocationManagement** - Online access to revocation management services (certificate revocation requests).
- **I.NetworkServices** - Interface to local network services (secure storage, timesources, user directory).



- **I.ExternalCryptographicService** - Interface to SCD or KMS, not part of the product.

Logical environments include the connected systems around the main product that shape how it operates in its environment. The trusted boundary is affected by potential third party software that runs on the product, data links to the outside world using radio interfaces, and user permissions and access control.

## 4.3 Operational Environment

### 4.3.1 General description

The operational environment of the product includes the physical environment, the logical environment, and the specific connectivity environment in which the product is deployed and communicates with external elements.

### 4.3.2 Physical/Hardware environment

An enterprise server room or data centre should have some physical access controls.

For the physical operational environment, the following environments are addressed for the Main Products:

- **POE.FullyControlled** - fully controlled physical operational environment.
- **POE.PartiallyControlled** - partially controlled physical operational environment.
- **POE.SCD** - The environment provides a Secure Cryptographic Device (often taking the form of an Hardware Security Module) to generate keys and provide signature support.

A cloud service provider should have strong physical security measures in place, but the servers hosting the PKI software should not be physically separated from other infrastructure.

For the physical operation environment, the following environments are addressed for cloud service (RDPSs):

- **POE.FullyControlled** - fully controlled physical operational environment.

### 4.3.3 Logical/Software environment

The security aspect of Logical/Software operational environment can be either:

- **SOE.FullyControlled** - Fully controlled logical operational environment (segregation, least privileged, network protection e.g. firewalls/IDS/IPS/etc.). Only authorised users can access the product interfaces and network data.
- **SOE.PartiallyControlled** - Partially controlled software operational environment product users can access the product's interfaces and network data in transit.

Additionally, the product may include the following required external components:

- **EC.Audit** - records secure storage external hardware and software use to store audit data.
- **EC.Timesource** - A network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes.
- **EC.UserDirectory** - A directory server that centrally stores, organises, and provides access to user, group, and resource information (e.g. authentication credentials, contact details) for networked systems and applications.

### 4.3.4 Connectivity aspects

For the logical operation environment, the following digital communication types are addressed for any architectural component of the product:

- **COM.Public** - Ingoing/outgoing communication from/to public networks.

- **COM.Adjacent** - Ingoing/outgoing communication from/to private networks which does not require physical proximity to product premises.
- **COM.Local** - Ingoing/outgoing communication which requires physical access to the product Local Area Network (LAN).
- **COM.UserInterface** - Physical interface provided to the authorised user, allowing direct access to the product HMI.

## 4.4 Distribution of Security Functions

Security functions distribution is presented in [Product Architecture](#) and is further refined use case by use case in the annexes. This distribution depends, for each use case, on the product functional (cf. clause 4.1, e.g. F.UserAccountManagement F.Network\_Configuration, ...) scope together with its distribution parameters.

## 4.5 Users

The product contains a number of assets that need privileged access to use. The following user classes are identified from consideration of the least privilege paradigm to the product assets as identified in the product architecture of clause 4.2.

- **U.ProductAdministrator:** Installs, configures, and maintains the product, ensuring its proper operation and security.
- **U.ProductOperator:** Performs operational tasks to ensure the availability and integrity of the product and data, e.g. execute system backups and recovery procedures to prevent data loss, monitor product health and performance, manage routine operational tasks, such as certificate issuance workflows.
- **U.Officer (or Registration Authority Officer):** Manages certificate life-cycle operations, including approvals and revocations e.g. Configure profiles, policies, and security parameters, review and approve or reject certificate requests based on policy compliance, initiate and manage certificate revocation (e.g. due to compromise, expiration, or policy violations), verify the identity and authenticity of certificate applicants, ensure that certificate issuance and revocation processes align with organisational policies.
- **U.Auditor:** Authorised to monitor and review product operations logs to ensure compliance and security.
- **U.End\_User:** Individuals or systems that request certificates or check certificate status for authentication, encryption, or digital signing purposes.

## 4.6 Use cases

PKIs can take many forms and the present document does not aim to cover all possible services and their implementations but uses the use cases to assist in identifying the product requirements for these implementations. The uses cases considered are:

- **UC1:** Private PKI for non-critical entities.
- **UC2:** Private PKI for critical entities.
- **UC3:** Public PKI for critical entities.
- **UC4:** Public basic PKI for critical entities.
- **UC5:** Multi-authority PKI for critical entities.

The following subsections present the use cases overviews, full details for use cases descriptions (functions, assets, interfaces, etc.) can be found in Annex U.

### 4.6.1 Private PKI for non critical sectors (UC1)

A private enterprise using public-key cryptography that manages a PKI internally to the enterprise. The enterprise therefore manages the policy framework, the generation of key pairs, the certification of key pairs and the purposes of keys. In such organisations the PKI may be organised on department centric hierarchies, or on location centric hierarchies, or on organisation role hierarchies or some combination of these. Whilst the set of services to be enabled by the PKI in this use case are large they may include VPN access and management, timestamp services, disk or message encryption, email, and document access and distribution and so on. The deployment of such a private Public Key Infrastructure (PKI) is not driven by regulatory or standardised requirements but rather by the need to align with the entity's internal policies and security practices. Additionally, users of these PKI solutions often prioritise flexibility and ease of use over highly secure but restrictive technologies. For instance, they will not rely on Secure Cryptographic Devices (SCD) but rather have private keys stored using operating system or platform key management facilities that provide protection against unauthorised access at rest. The manufacturer shall document the protection mechanisms relied upon and their limitations. Where the platform facility supports hardware-backed protection (e.g. TPM), this should be the preferred configuration.

EXAMPLE 1: Products deployed to support software maintenance.

EXAMPLE 2: Products deployed to support internal IT service for network security deployments (e.g. VPN, ssh, TLS servers).

EXAMPLE 3: User management (identification and authentication) for services like User & Device Authentication, Single Sign-On (SSO).

### 4.6.2 Private PKI for critical entities (UC2)

Critical entities often need to produce their own certificates to manage sensitive IT and network services. These services include VPNs, remote SSH connections, timestamp services, disk or message encryption, and PDF signatures. The deployment of such a private Public Key Infrastructure (PKI) is governed by regulatory or standardised requirements, which impose strict constraints, such as:

- Network and physical security,
- Encryption and access control of digital data,
- Incident reporting obligations,
- Compliance with secure operational practices.

As a result, users of these PKI solutions do not have the same deployment flexibility as in less regulated use cases (e.g. UC1). However, they are still permitted to use products that offer diverse functionalities.

EXAMPLE 1: Products deployed by telecommunications service providers used to manage proofs of identity, authorisation, and encryption to enable secure access to internal services and customer-facing networks, including e.g. 5G core and edge systems, as standardised in ETSI TS 133 501 [i.9] and ETSI GS NFV 003 [i.6]. The product is responsible for the issuance, revocation, and overall management of certificates and certificate status information (e.g. via CRLs or OCSP).

### 4.6.3 Public PKI for critical entities (UC3)

Product used to support certification management services (registration, certificate generation, revocation and status management) provided within very large multi-site company or provided by a CA to the public, and where a compromise carries a significant risk of impact to the security of remote or unknown users, other products, networks or services, or to the health, security or safety of the public.

Such PKIs are deployed in highly controlled environments, including robust physical and logical security measures, along with strict policies and processes.

#### 4.6.4 Public basic PKI for critical entities (UC4)

Product used to support certification services (certificate generation, revocation and status management) provided within very large multi-site company or provided by a CA to the public, and where a compromise carries a significant risk of impact to the security of remote or unknown users, other products, networks or services, or to the health, security or safety of the public.

Such PKIs are deployed in highly controlled environments, including robust physical and logical security measures, along with strict policies and processes.

**EXAMPLE:** Products deployed for Trust services. Software used to issue certificates for trust services including those used in electronic attribute attestation.

#### 4.6.5 Multi-authority PKI for critical entities (UC5)

In general terms the multi-authority model separates the entity responsible for authentication from the entity responsible for authorisation of specific services, in like manner to the model of Kerberos [i.5] but applied to a public key system.

The multi-authority PKI is intended to combine multiple authorities in a single (extended) domain, sharing resources, and enforcing minimisation of identifying data. In like manner to Kerberos the certificate model in multi-authority PKI enables anonymous or pseudonymous proof of authority. The product in multi-authority PKIs is expected to be able to generate and distribute signed attestations of authority, to verify any received attestation of authority, and to maintain the status of stored public keys.

**EXAMPLE 1:** The PKI dedicated to Co-operative Intelligent Transport Systems (C-ITS) is used to manage proofs of authorisation and identity to enable access to services on different components of ITS systems standardised in ETSI TS 102 940 [i.16] and ETSI TS 102 941 [i.7]. The product is responsible for the issuance, revocation, and overall management of certificates and certificate status information. The PKI service architecture and its functionalities considered here are the one. The C-ITS PKI standards provide the basis for the EU C-ITS security credential management system [i.11].

**NOTE 1:** For the C-ITS example within this use case the product requirements for the ITS-Station acting as a signature creation and verification element the European C-ITS trust model specifies that the ITS-S conforms to a specific protection profile.

**NOTE 2:** In the C-ITS model the product uses pseudonymous key pairs and cycles them rapidly and the product may need to have multiple key pairs maintained at any one time, this may place constraints on the number of private keys that have to be maintained in the product.

**EXAMPLE 2:** In a smart contract environment, such as that outlined in ETSI TR 119 540 [i.15], the chain of trust requires that a device operates within multiple trust domains and evidenced in the use of a distributed ledger wherein some entries may be signed as proof of an attribute attestation (e.g. a contractual state transition), or signed as proof of an identity attestation (e.g. identifying the legal entity that is a smart contract stakeholder).

---

## 5 Technical requirements for the products

### 5.1 Introduction - Applicability of the requirements

The technical requirements of the present document apply under the product context described in Clause 4, which shall be in accordance with its intended use. The equipment shall comply with all applicable technical requirements of the present document at all times when operating in such product context.

Not all requirements are universally applicable: The applicability of requirements may be based on use cases or specific capabilities of the product.

See the applicability fields associated with each technical cybersecurity requirement in the following Clause 5 subclauses.

## 5.2 No known exploitable vulnerabilities

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (a).

- REFERENCE: REQ-PKI-KEV-01
  - REQUIREMENT: The product shall not contain known exploitable vulnerabilities, unless vulnerability assessment demonstrates that:
    - the vulnerability is not exploitable in the product; or
    - specific user guidance is provided to prevent exploitation.

NOTE: Details of the vulnerability assessment are provided in the vulnerability handling process defined in prEN 40000-1-3 [i.17].

- APPLICABILITY: All use cases.

## 5.3 Secure by default configuration

### 5.3.1 SBDC- Access control

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (b).

- REFERENCE: REQ-PKI-SBDC-01
  - REQUIREMENT: All assets of the system shall be defined as protected assets with default access condition of DENY.

NOTE: See also clause 5.5.

EXAMPLE: The role of the access control countermeasure is described in ETSI TS 102 165-2 [i.8] (clause 6) where permission to access a resource is only ever true (PERMIT) or false (DENY) and where the decision to give permission is always deterministic.

- APPLICABILITY: All use cases.

### 5.3.2 SBDC- Monitoring

- REFERENCE: REQ-PKI-SBDC-02
  - REQUIREMENT: The audit log integrity protection event shall be performed by default once a day.
  - RATIONALE: The audit record integrity ensures that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: UC2, UC3, UC4 and UC5.

### 5.3.3 SBDC- Cryptography

- REFERENCE: REQ-PKI-SBDC-03
  - REQUIREMENT: All cryptographic mechanisms shall be configured by default in conformity to the general state of the art as defined in Annex K.
  - RATIONALE: Cf. Annex K rational.
  - APPLICABILITY: All use cases.

### 5.3.4 SBDC- Certificates

- REFERENCE: REQ-PKI-SBDC-04
  - REQUIREMENT: Certificates validity period shall be limited to 3 years by default.
  - RATIONALE: The longer a certificate is valid, the higher the risk that cryptographic attacks on its signature may succeed. A default limitation to 3 years reduces unnecessary exposure of certificates to potential vulnerabilities.
  - APPLICABILITY: All use cases.

## 5.4 Secure updates

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (c).

- REFERENCE: REQ-PKI-SU-01
  - REQUIREMENT: The product shall support software update mechanisms, that allow to update every part of the product's software, except for parts of the product's software that are immutable due to technical reasons.
- NOTE: Part of the product's software can be immutable due to its technology (e.g. software installed in a ROM).
- APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-SU-02
  - REQUIREMENT: Where an update is made available to the device it shall only be installed if it has been signed by a known and trusted entity with a valid key identified by its PKC.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-SU-03
  - REQUIREMENT: The product administrator shall be able to configure when available updates are installed.
- EXAMPLE: Options may include immediately on receipt, deferred to an agreed "maintenance" period.
- APPLICABILITY: All use cases.

## 5.5 Authentication and access control

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (d).

- REFERENCE: REQ-PKI-AAC-01
  - REQUIREMENT: Only authorised users shall be able to access product functionalities, stored data, and configuration data. To achieve this, the product shall enforce identification and authentication mechanisms by implementing cryptographic mechanisms conform to the general state of the art as defined in Annex K.
  - RATIONALE: Only authorised, identified, and authenticated users should be able to access product services and stored data. This addresses all relevant threats.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-AAC-02
  - REQUIREMENT: The product shall manage different user profiles, allowing Role Based Access Control (RBAC). This mechanism shall provide means to define specific user account capabilities for the following privileged roles: U.Administrator

This shall include at least the capability to limit user profile rights for the following product actions and their associated assets ():

- Product audit & administration  
F.UserAccountManagement F.NetworkConfiguration F.InternalKeyManagement  
F.AuditEventManager F.LoggingOfSecurityEvents  
F.CertificateProfileManagement
- APPLICABILITY: UC1.
- REFERENCE: REQ-PKI-AAC-03
  - REQUIREMENT: The product shall manage different user profiles, allowing RBAC. This mechanism shall provide means to define specific user account capabilities for the following roles: U.Administrator, U.Officer, U.Auditor  
This shall include at least the capability to limit user profile rights for the following product actions and their associated assets as defined in Annex U:
    - Product audit & administration  
F.UserAccountManagement F.NetworkConfiguration F.InternalKeyManagement  
F.ExternalKeyManagement F.AuditEventManager F.LoggingOfSecurityEvents  
F.CertificateProfileManagement
    - Registration F.OnlineRegService F.CertificateDissemination F.PrivateKeyImportExport  
F.OfficerRegistrationApproval
    - Certificate generation F.SCD\_BasedKeyPairGen F.NoneSCD\_BasedKeyPairGen  
F.SubjectCertSignCreation F.OfficerCertGenApproval F.PseudonymCertIssuance
    - Certificate status F.CertificateStatus
    - Revocation management F.RevocationManagement  
F.OfficerRevocationApproval
  - APPLICABILITY: UC2, UC3, UC4 and UC5.

## 5.6 Confidentiality

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (e).

### 5.6.1 CON - General

- REFERENCE: REQ-PKI-CON-01
  - REQUIREMENT: The product shall provide capabilities to ensure that the private key generated by the product cannot be removed or copied from the product by unauthorised users.
  - RATIONALE: Private keys are the root of trust in a PKI. When they are not generated or protected by an external SCD or KMS, this requirement ensures that only the product has access to them, protecting them from export, copying, or disclosure.

NOTE 1: Where a device creates a public-private key pair and maintains the related PKC that set (key pair and PKC) can be moved from one physical entity to another within a strictly controlled environment as per use case.

- APPLICABILITY: UC1.
- REFERENCE: REQ-PKI-CON-02
  - REQUIREMENT: Where the private key is stored in a cryptographically protected way, those cryptographic mechanisms shall conform to the general state of the art as defined in Annex K.
  - RATIONALE: Cf. Annex K rational.

- APPLICABILITY: UC2, UC3, UC4 and UC5
- REFERENCE: REQ-PKI-CON-03
  - REQUIREMENT: If a pseudonymous certificate is used to exchange a public key related to an ephemeral identity the product shall ensure that no data is contained in the certificate that can be used to break the pseudonymity of the sender.
  - RATIONALE: Pseudonymous certificates are designed to ensure privacy. If these certificates include data that can be linked to the user, the privacy protection is compromised, defeating the purpose of pseudonymity. This requires that the product is designed to create pseudonymous certificates containing only fields that provide technical information unrelated to the user.
  - APPLICABILITY: UC5
- REFERENCE: REQ-PKI-CON-04
  - REQUIREMENT: If the product sends data intended/labelled as personal or sensitive to another entity the product shall ensure that such data is protected from eavesdropping in a cryptographically protected way. These cryptographic mechanisms shall conform to the general state of the art as defined in Annex K.
  - RATIONALE: Analysis has to be performed and justified by the developer to ensure that the product protects personal and sensitive data. This requires to define what data are considered personal or sensitive and provide and associate cryptographic protection mechanisms.

NOTE 2: This includes any remote administration.

- APPLICABILITY: UC1, UC2, UC3 and UC5
- REFERENCE: REQ-PKI-CON-05
  - REQUIREMENT: A public key certificate request containing explicit personal data shall be protected in integrity and confidentiality by implementing cryptographic mechanisms conform to the general state of the art as defined in Annex K.
  - RATIONALE: Cf. Annex K rational.
  - APPLICABILITY: UC2, UC3, UC4 and UC5
- REFERENCE: REQ-PKI-CON-06
  - REQUIREMENT: The product shall implement a chosen set of cryptographic algorithms to decrypt data that has been confidentiality-protected using a known key, ensuring it can recover the plaintext data. Those cryptographic mechanisms shall conform to the general state of the art as defined in Annex K.
  - RATIONALE: Communication with external components requires to encrypt use case sensitive data using state of the art mechanisms (cf. Annex K rational).
  - APPLICABILITY: UC1, UC2, UC3 and UC5
- REFERENCE: REQ-PKI-CON-07
  - REQUIREMENT: The cryptographic mechanisms used to sign and verify content shall conform to the general state of the art, as defined in Annex K.
  - RATIONALE: Cf. Annex K rational.

NOTE 3: If the product is intended for a specific environment with a defined set of agreed cryptographic mechanisms, the product has to be able to be used in accordance with those cryptographic requirements.

- APPLICABILITY: UC1, UC2, UC3 and UC5



## 5.6.2 CON - Secure storage and communications

- REFERENCE: REQ-PKI-CON-08
  - REQUIREMENT: The cryptographic mechanisms used to encrypt and decrypt content shall conform to the general state of the art, as defined in Annex K.
  - RATIONALE: Cf. Annex K rational.
  - APPLICABILITY: All use cases where the product implements encryption mechanisms either for data storage or external communications.

NOTE: If the product is intended for a specific environment with a defined set of agreed cryptographic mechanisms, the product has to be able to be used in accordance with those cryptographic requirements.

- REFERENCE: REQ-PKI-CON-09
  - REQUIREMENT: The product shall be able to establish and maintain a secure link with the SCD or KMS, and that the SCD or KMS interfaces are properly called.
  - RATIONALE: To ensure the secure key management, the proper and secure use of external SCD or KMS is required.
  - APPLICABILITY: UC2, UC3, UC4, UC5.

## 5.6.3 CON - Key management

- REFERENCE: REQ-PKI-CON-10
  - REQUIREMENT: When the product exports private or symmetric keys it shall use state of the art cryptographic mechanisms for guaranteeing its confidentiality as defined in Annex K.
  - RATIONALE: A secret key should not be compromised if its exported form is intercepted.

EXAMPLE: The exported private or symmetric key can be encrypted such that only its designated recipient can decrypt it.

- APPLICABILITY: UC1 and UC2.
- REFERENCE: REQ-PKI-CON-11
  - REQUIREMENT: Secret keys shall not be stored persistently in plaintext form. They shall be stored within a secure cryptographic device or encrypted using approved algorithms as defined in Annex K using independently managed keys. They may only be accessed in plaintext form temporarily for a single operation or batch of operations.
  - RATIONALE: To ensure trust the product should rely on secure and valid key creation and management systems accessible only to authorised users provided by hardware security devices.
  - APPLICABILITY: UC2, UC3, UC4, UC5.

## 5.7 Integrity

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (f).

### 5.7.1 INT - Monitoring

- REFERENCE: REQ-PKI-INT-01
  - REQUIREMENT: The product shall be able to detect unauthorised modifications to the stored audit records during the audit using state of the art cryptographic mechanisms as defined in Annex K.

- RATIONALE: The audit record integrity and availability ensure that all auditable events are traceable and misuse of the product functions can be traced.
- APPLICABILITY: UC2, UC3, UC4 and UC5.
- REFERENCE: REQ-PKI-INT-02
  - REQUIREMENT: The timestamp shall be in the scope of the integrity protection of the audit record (to prevent manipulation of the time stamp after the event).
  - RATIONALE: The audit record integrity and timestamping validity ensure that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: UC2, UC3, UC4 and UC5.
- REFERENCE: REQ-PKI-INT-03
  - REQUIREMENT: The product shall periodically create an audit log signing event in which it computes a digital signature, keyed hash, or authentication code over the entries in the audit log. For that it shall use state of the art cryptographic mechanisms as defined in Annex K. The digital signature, keyed hash, or authentication code shall be computed over, at least:
    - every entry that has been added to the audit log since the previous audit log signing event;
    - the digital signature, keyed hash, or authentication code from the previous audit log signed event. The digital signature, keyed hash, or authentication code from the audit log signing event shall be included in the audit log.
  - RATIONALE: All entries of the audit log, and the order and exhaustivity of batches of entries should impact authenticity checks of the audit log. The audit record integrity ensure that all auditable events are traceable and misuse of the product functions can be traced.

NOTE 1: An audit log signing event is performed even if no entry was added to the audit log since the last one.

- APPLICABILITY: UC3, UC4 and UC5.
- REFERENCE: REQ-PKI-INT-04
  - REQUIREMENT: The product shall ensure the integrity of audit logs.
  - RATIONALE: Integrity protection of audit logs ensures that all auditable events are traceable and that product operations can be reliably tracked for accountability and security monitoring. For that the product shall use state of the art cryptographic mechanisms as defined in Annex K.

NOTE 2: Not all integrity protection mechanisms can be foreseen so for use cases with lower regulation of standardisation constraints (UC1, UC2) other approaches can be valid and so not identified here. Acceptable mechanisms include: append-only log storage, file-system integrity monitoring, hash-chained log entries, or forwarding to a trusted external log management system. The choice should be proportionate to the risk profile.

- APPLICABILITY: UC2
- REFERENCE: REQ-PKI-INT-05
  - REQUIREMENT: The specified frequency at which the audit log signing event occurs shall be configurable.
  - RATIONALE: The audit record integrity ensures that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: All use cases.

### 5.7.2 INT - Certificate signing

- REFERENCE: REQ-PKI-INT-06
  - REQUIREMENT: The product shall create certificate signature only by means of a Secure Cryptographic Device (SCD).
  - RATIONALE: To ensure trust the product software should rely on secure and valid key creation and management systems accessible only to authorised users provided by hardware security devices.
  - APPLICABILITY: UC3, UC4 and UC5
- REFERENCE: REQ-PKI-INT-07
  - REQUIREMENT: The cryptographic mechanisms used to create certificate signatures shall be as stated in Annex K.
  - RATIONALE: The use of recognised and validated cryptographic algorithms is mandatory for a PKI and thus a product to ensure trust. Known weak or insufficiently validated algorithms are not allowed.
  - APPLICABILITY: All use cases.

### 5.7.3 INT- CRL signing

- REFERENCE: REQ-PKI-INT-08
  - REQUIREMENT: The product shall create CRL signature only by means of a Secure Cryptographic Device (SCD).
  - RATIONALE: To ensure trust the product software should rely on secure and valid key creation and management systems accessible only to authorised users provided by hardware security devices.
  - APPLICABILITY: UC3, UC4 and UC5
- REFERENCE: REQ-PKI-INT-09
  - REQUIREMENT: The cryptographic mechanisms used to create CRL signatures shall be as stated in Annex K.
  - RATIONALE: The use of recognised and validated cryptographic algorithms is mandatory for a PKI and thus a product to ensure trust. Known weak or insufficiently validated algorithms are not allowed.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-INT-10
  - REQUIREMENT - [CONDITIONAL]: If Certificate Revocation Lists (CRLs) concerning end users certificates including any variants are used, the CRL shall be signed using a valid certificate.

NOTE: This requirement is derived from CSS-6.3.9-08 contained in ETSI EN 319 411-1 [i.10]. Example of variant can be Delta CRLs.

- RATIONALE: If the CRL is not signed by the CA or a TSP-appointed entity, it may be usurped to mislead end-users regarding a certificate's status.
- APPLICABILITY: Where the product has a certificate status service, issuing CRLs.

## 5.8 Data minimisation

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (g).

### 5.8.1 DM - General

- REFERENCE: REQ-PKI-DM-01
  - REQUIREMENT: The product shall only maintain configuration data sufficient to connect to other elements of the PKI system that the product serves.
  - RATIONALE: Unnecessary network configuration elements add complexity and increase the potential attack surface.
  - APPLICABILITY: UC1, UC2, UC3, and UC5
- REFERENCE: REQ-PKI-DM-02
  - REQUIREMENT: The product shall only maintain configuration data sufficient to provide PKC management functions.
  - RATIONALE: Unnecessary PKC management function configurations (as defined per use case in Annex U) introduce unnecessary complexity and avoidable risks.
  - APPLICABILITY: UC1, UC2, UC3, and UC5
- REFERENCE: REQ-PKI-DM-03
  - REQUIREMENT: The product shall only maintain and process user data necessary for certificate management.
  - RATIONALE: For each use case, only user data necessary for the certificate management functions identified in Annex U are required.

NOTE: Example of such data can be: certificate requests, updates, etc.

- APPLICABILITY: All use cases.

### 5.8.2 DM - Secret management

- REFERENCE: REQ-PKI-DM-04
  - REQUIREMENT: The product shall only create keys by means of a Secure Cryptographic Device (SCD) or remote Key Management System providing cryptographic mechanisms conform to the general state of the art as defined in Annex K.
  - RATIONALE: To ensure trust the product software should rely on secure and valid key creation and management systems accessible only to authorised users provided by hardware security devices.
  - APPLICABILITY: UC2, UC3, UC4, UC5

## 5.9 Availability protection

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (h).

This clause considers that certificates status availability and trust are direct part of availability protection of the PKI service, since

### 5.9.1 AP - Certificate suspension and revocation

- REFERENCE: REQ-PKI-AP-01
  - REQUIREMENT: Once a certificate has been revoked by means of REQ-PKI-EMM-08, it shall not be reinstated.

- RATIONALE: Revocation is intended to be a definitive action, from which this requirement stems. Tampering certificates status can enable distrust when it becomes unclear if certificates are valid or not, thus it also tampers the availability of the service which consists in providing trust.
- APPLICABILITY: All use cases where the product has a certificate generation service, issuing public-key certificates.
- REFERENCE: REQ-PKI-AP-02
  - REQUIREMENT - [CONDITIONAL]: If Certificate Revocation Lists (CRLs) concerning end users certificates including any variants are used as defined and provide a nextUpdate field, every CRL shall state a time for next scheduled CRL issue, unless it is the last CRL issued for those certificates in the scope of the CRL, in which case the nextUpdate field in the CRL, shall be set to "99991231235959Z".

NOTE 1: This requirement is derived from CSS-6.3.9-06 contained in ETSI EN 319 411-1 [i.10].

- RATIONALE: The inclusion of an expiry of the CRL's validity reduces the ability of an attacker to replay the CRL to its users, and enables caching for end-users. The special value of that field in the event the next update would be the CRL issuer expires ensures the status information is valid until that expiry.
- APPLICABILITY: Where the product has a certificate status service, issuing CRLs according to REQ-PKI-EMM-08 and REQ-PKI-EMM-09.
- REFERENCE: REQ-PKI-AP-03
- REQUIREMENT - [CONDITIONAL]: If CARL is used, a new CARL shall be generated at least once a year with a nextUpdate of at most 1 year after the issuing date.

NOTE 2: This requirement is derived from CSS-6.3.9-12 contained in ETSI EN 319 411-1 [i.10].

- RATIONALE: With respect to the severity of a CA compromise, a revocation should be made known as quickly as possible by immediately issuing a new CARL, rather than waiting for the next scheduled CARL.
- APPLICABILITY: Where the product has a certificate status service issuing CARLs according.
- REFERENCE: REQ-PKI-AP-04
  - REQUIREMENT - [CONDITIONAL]: If CARL is used, a new CARL shall be generated once a CA certificate has been revoked.

NOTE 3: This requirement is derived from CSS-6.3.9-13 contained in ETSI EN 319 411-1 [i.10].

- RATIONALE: With respect to the severity of a CA compromise, a revocation should be made known as quickly as possible by immediately issuing a new CARL, rather than waiting for the next scheduled CARL.
- APPLICABILITY: Where the product has a certificate status service, issuing CRLs or CARLs.

## 5.9.2 AP - Certificate status services

- REFERENCE: REQ-PKI-AP-05
  - REQUIREMENT: Revocation status information shall provide information on the status of certificates at least until the certificate expires.
- NOTE 1: This requirement is derived from CSS-6.3.10-04 contained in ETSI EN 319 411-1 [i.10].
  - RATIONALE: If no revocation information status is available before the end of the validity of a certificate, its status becomes unknown and it cannot be trusted anymore.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-AP-06

- REQUIREMENT: OCSP or CRL shall be supported.

NOTE 2: This requirement is derived from CSS-6.3.10-05 contained in ETSI EN 319 411-1 [i.10].

- RATIONALE: If no revocation information status is available before the end of the validity of a certificate, its status becomes unknown and it cannot be trusted anymore.
- APPLICABILITY: UC2, UC3, UC4 and UC5.
- REFERENCE: REQ-PKI-AP-07
  - REQUIREMENT: If a product supports multiple methods to provide revocation status, the information provided by all services shall be consistent over time taking into account different delays in updating the status information for all the methods.
  - RATIONALE: The product shall provide accurate and integrity protected certificates status.
  - APPLICABILITY: UC1, UC2 and UC3.

NOTE 3: This is aligned with requirement CSS-6.3.10-09 contained in ETSI EN 319 411-1 [i.10].

### 5.9.3 AP - Key management

- REFERENCE: REQ-PKI-AP-08
  - REQUIREMENT: The product shall be able to maintain multiple key pairs.
  - RATIONALE: A product requires multiple key pairs to provide essential services, including: support for different authorities (e.g. root CA, intermediate CAs, end-entities), use of various cryptographic mechanisms (e.g. separate key pairs for signing and encryption), facilitation of key rotation and lifecycle management (e.g. active and backup keys), etc.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-AP-09
  - REQUIREMENT: The product shall provide the capability for authorised users to delete keys.
  - RATIONALE: Proper key management includes the capability for authorised users to delete key when necessary (as defined by the Certificate Policy).
  - APPLICABILITY: All use cases.

## 5.10 Impact minimisation

*Proposed ESR code: IM*

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (i).

The primary impact of a product on its environment is the unavailability of its services. PKI systems are passive systems that respond to requests from external entities. Therefore, minimizing the impact on other systems relies on the combination of requirements identified in clause 5 that collectively ensure the product correctly manages the Public Key Certificate (PKC) lifecycle and provides the appropriate level of trust to dependent systems.

## 5.11 Minimisation of attack surfaces

*Proposed ESR code: MAS*

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (j).

- REFERENCE: REQ-PKI-MAS-01
  - REQUIREMENT: Only interfaces identified for each use case in Annex U shall be implemented.

- RATIONALE: Only interfaces implementing functions provided by each use case are necessary.
- APPLICABILITY: All use cases.

## 5.12 Exploitation mitigation mechanisms

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (k).

### 5.12.1 EMM - Certificate issuance

To limit certificate forgery or misuse of certificate content, this clause defines requirements for the PKI to enforce the use of standardised certificate formats and recognised cryptographic signature mechanisms.

- REFERENCE: REQ-PKI-EMM-01a
  - REQUIREMENT: The format of the certificates issued by the certificate generation service shall comply with Recommendation ITU-T X.509 [2] or functionally-equivalent standard.
  - RATIONALE: Using normative formats ensures the interoperability of PKIs and enforces that certificate content contains only normalised and necessary information.
- NOTE: Recommendation ITU T X.509 [2] is normatively referenced as a whole. Although certain clauses are not relevant, its requirements and definitions are interdependent and the standard should therefore be considered in its entirety when assessing conformity.
- APPLICABILITY: All use cases, not applicable if REQ-PKI-EMM-01b is used.
- REFERENCE: REQ-PKI-EMM-01b
  - REQUIREMENT: The format of the certificates issued by the certificate generation service shall comply with the IEEE 1609.2 standard [3].
  - RATIONALE: Using normative formats ensures the interoperability of PKIs and enforces that certificate content contains only normalised and necessary information.
  - APPLICABILITY: UC5 for C-ITS
- REFERENCE: REQ-PKI-EMM-02
  - REQUIREMENT: The product shall implement a certificate profile compliant to the base standard of REQ-PKI-EMM-01 (a or b) and appropriate to its scope/context and shall ensure that issued certificates are consistent with that profile.
  - RATIONALE: The specification of a specific certificate profile (e.g. by reference to applicable standards such as IETF RFC 5280 [i.18] or ETSI TS 103 097 [i.14]) is in scope of a Certificate Policy and out of the scope of the present document. However, requiring the implementation of a certificate profile ensures that authorised users can ensure interoperability of PKIs and that certificate content contains only normalised and necessary information to minimise attack surface.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-EMM-03
  - REQUIREMENT: The product shall enable authorised users to specify the set of acceptable values for the following fields and extensions:
    - the authority key identifier (if applicable);
    - the algorithm identifier for the subject's public/private key pair;
    - the identifier of the certificate issuer or of the issuing certificate;
    - the duration for which the certificate is valid.

- RATIONALE: Only valid certificates, as defined by authorised users in conformity with the PKI certificate policy, shall be generated by the product, including those fields.
- APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-EMM-04
  - REQUIREMENT: The product shall enable authorised users to specify the set of acceptable values for the following fields and extensions:
    - keyUsage;
    - basicConstraints; certificatePolicies.
  - RATIONALE: Only valid certificates as defined by the product service provider policies shall be generated by the product including those fields.
  - APPLICABILITY: All use cases, applicable only if REQ-PKI-EMM-01a is used.
- REFERENCE: REQ-PKI-EMM-05
  - REQUIREMENT: The product shall mark the following extensions as critical:
    - keyUsage;
    - basicConstraints; certificatePolicies.
  - RATIONALE: Only valid certificates as defined by the product service provider policies shall be generated by the product including those fields.
  - APPLICABILITY: All use cases, applicable only if REQ-PKI-EMM-01a is used.
- REFERENCE: REQ-PKI-EMM-06
  - REQUIREMENT: The product shall disallow the keyUsage extension to simultaneously include values from:
    - digitalSignature, contentCommitment, keyCertSign, cRLSign; and
    - keyEncipherment, dataEncipherment, keyAgreement.
  - RATIONALE: The same public key cannot be used for signature verification, and encryption or key agreement. Only valid certificates as defined by the PKI service provider policies shall be generated by the product.
  - APPLICABILITY: U2, UC3, UC4, UC5, applicable only if REQ-PKI-EMM-01a is used.
- REFERENCE: REQ-PKI-EMM-07
  - REQUIREMENT: The product shall verify that the prospective certificate subject possesses the private key corresponding to the public key contained in the certificate request by means of a cryptographic challenge before issuing a certificate, unless the public/private key pair was generated by the product and has never left the certificate issuance service.
  - RATIONALE: A subject bringing forth his own public key should prove ownership of the corresponding private key. The product can generate a key pair and associated public key, and later communicate the private key to the correct subject in a secure manner. This can notably be done for other components of the product itself needing public-key certificates. The same private key should not be owned by distinct subjects, including other services of the product; if the private key was generated by the product but already provided to the subject once, the subject can and should prove its ownership.
  - APPLICABILITY: U2, UC3, UC4, UC5.



### 5.12.2 EMM - Certificate status

- REFERENCE: REQ-PKI-EMM-08
    - REQUIREMENT: The certificate status service shall provide certificate revocation statuses as either or both of:
      - CRLs as defined by and subject to the requirements of Recommendation ITU-T X.509 [2]; or
      - OSCP responses to OSCP requests as defined by and subject to the requirements of IETF RFC 6960 [4].
    - RATIONALE: The product shall provide accurate and integrity protected certificates status either using the standardised CRL format ensuring integrity of revocation list or protected OSCP services as defined by IETF RFC 6960 [4].
    - APPLICABILITY: UC1, UC2 and UC3.
  - REFERENCE: REQ-PKI-EMM-09
    - REQUIREMENT: The product shall implement a CRL profile and shall ensure that issued CRLs are consistent with that profile.
    - RATIONALE: The product shall provide accurate and integrity protected certificates status using the standardised CRL format ensuring integrity of revocation list and conformity to the product service provider chosen policies.
    - APPLICABILITY: Where the product has a certificate status service, issuing CRLs.
  - REFERENCE: REQ-PKI-EMM-10
    - REQUIREMENT: The product shall enable authorised users to specify the set of acceptable values for the following CRL fields and extensions:
      - issuer;
      - issuerAltName; nextUpdate.
    - RATIONALE: The product shall provide accurate and integrity protected certificates status using the standardised CRL format ensuring integrity of revocation list and conformity to the product service provider chosen policies.
    - APPLICABILITY: Where the product has a certificate status service, issuing CRLs.
- NOTE 1: The issuerAltName can be absent from the profile if issued certificates do not use it.
- REFERENCE: REQ-PKI-EMM-11
    - REQUIREMENT: The product shall implement an OSCP response profile and shall ensure that issued OSCP responses are consistent with that profile.
    - RATIONALE: The product shall provide accurate certificates status as defined by the service provider chosen policies.
    - APPLICABILITY: Where the product has a certificate status service, issuing OSCP responses.
  - REFERENCE: REQ-PKI-EMM-12
    - REQUIREMENT: The product shall enable authorised users to specify the set of acceptable values for the responseType field.
    - RATIONALE: The product shall provide accurate certificates status as defined by the service provider chosen policies.
    - APPLICABILITY: Where the product has a certificate status service, issuing OSCP responses, not restricted to the basic response type: UC1 and UC2.

- REFERENCE: REQ-PKI-EMM-13
  - REQUIREMENT: The product shall enable authorised users to specify the set of acceptable values for the responderID field.
  - RATIONALE: The product shall provide accurate certificates status as defined by the service provider chosen policies.
  - APPLICABILITY: Where the product has a certificate status service, issuing OCSP responses of the basic response type: UC1 and UC2.

NOTE 2: An OCSP responder is required to be capable to emit OCSP responses of the basic type by IETF RFC 6960 [4].

### 5.12.3 EMM - Certificate re-key

- REFERENCE: REQ-PKI-EMM-14
  - REQUIREMENT: In case of certificate re-key, any modified certified names or attributes shall be validated and updated registration information shall be recorded.
  - RATIONALE: The product should never issue a certificate without having validated all its certified names and attributes at some point in time. The product should possess accurate registration information regarding certificates it re-keys.
  - APPLICABILITY: All use cases where the product has a certificate generation service, issuing public-key certificates and supporting certificate re-key.

### 5.12.4 EMM - Certificate modification

- REFERENCE: REQ-PKI-EMM-15
  - REQUIREMENT: In case of a request for certificate modification, any modified certified names or attributes shall be validated and updated registration information shall be recorded.

NOTE: See ETSI 319 411-1 [i.10] clause 6.3.8 for the definition of certificate modification.

- RATIONALE: The product should never issue a certificate without having validated all its certified names and attributes at some point in time. The product should possess accurate registration information regarding certificates it modifies.
- APPLICABILITY: All use cases where the product has a certificate generation service, issuing public-key certificates and supporting certificate modification.

## 5.13 Logging and monitoring

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (l).

These requirements are about the collection and handling of auditable events, that is, particular events happening during the product operations which require to be traced so as to allow an authorised third-party to audit the PKI's operation. A PKI may produce other types of logs that do not fall under these requirements.

- REFERENCE: REQ-PKI-MON-01
  - REQUIREMENT: The product shall record events related to all product functions identified for each use case (as defined in Annex U), as well as all privileged user login attempts and product updates.
  - RATIONALE: All management functions of the PKI can impact the overall confidence in the system. Therefore, events related to Registration, Certificate Generation, Certificate Status, and Revocation Management should be recorded. Additionally, the management of privileged user accounts and their login activities should be logged to ensure accountability, which is critical for maintaining trust in the produced and managed PKI certificates.

- APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-MON-02
  - REQUIREMENT: The product shall record within each audit record at least the following information:
    - Date and time of the event
    - Type of event
    - Subject identity (if applicable)
    - The outcome (success or failure) of the event
  - RATIONALE: The audit record timestamping and subject identification ensure that all auditable events are traceable and misuse of the product functions can be traced.
- NOTE: The audit should not include in plaintext any secret keys or other critical security parameters.
- APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-MON-03
  - REQUIREMENT: The audit record shall identify the timing source used to generate the timestamp.
  - RATIONALE: The audit record timestamping validity ensure that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-MON-04
  - REQUIREMENT: For audit events resulting from actions of identified users, the product shall be able to associate each auditable event with the identity of the user that caused the event.
  - RATIONALE: The audit record integrity and timestamping validity ensure that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: All use cases.
- REFERENCE: REQ-PKI-MON-05
  - REQUIREMENT: The product shall prevent auditable events, except those taken by the auditor, if the audit log is full.
  - RATIONALE: If the PKI system is properly deployed - with appropriate policies, effective system management, and regular log reviews - an overload of logs should be seen as a symptom of a potentially significant security issue. In such cases, corrective actions should be taken before operations return to normal. Meanwhile, a full audit log should never result in the loss of old audit records or prevent future auditable events from being recorded. The audit record integrity and availability ensure that all auditable events are traceable and misuse of the product functions can be traced.
  - APPLICABILITY: Not applicable where the product implements or supports automatic log management mechanisms (e.g. log rotation with archival, log pruning, log forwarding to an external system) ensuring continuity of audit recording without data loss. Otherwise applicable to

## 5.14 Data removal and transparency

This clause addresses the requirements in the CRA [i.1] Annex I Part I (2) (m).

### 5.14.1 DRT - Secret management

- REFERENCE: REQ-PKI-DRT-01
  - REQUIREMENT: Public keys stored within the product, but not within a secure cryptographic device, shall be protected against undetected modification. If verification fails, the product shall not:
    - release the accessed public key to the caller; or
    - use the accessed public key.
  - RATIONALE: Unauthorised modifications of public keys stored by the product should not go undetected. Public keys modified without authorisation should not be considered safe for use and not be disseminated throughout or outside the product.
  - APPLICABILITY: All use cases
- REFERENCE: REQ-PKI-DRT-02
  - REQUIREMENT: The product shall zeroize secrets in plaintext form.
  - RATIONALE: Zeroizing secrets reduces the compromise of secrets during the temporary compromise of a product component, to only secrets used while the compromise is in effect. This enables better tracing of what secrets were likely compromised.
  - APPLICABILITY: Where the product temporarily manipulates secrets in plaintext form.

---

## 6 Assessment criteria for compliance with technical requirements

### 6.1 Introduction to the assessment and compliance criteria

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5, based on the UC and/or the Security Profile it may belong towards its placement in the EU market.

For each cybersecurity requirements defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement. It includes the reference index of the requirement(s) it aims to assess.
- **Assessment preparation:** Describes the environment, setup, and preconditions required before executing the test. It includes the following elements as applicable:
  - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
  - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialised, certificates loaded, user roles created).
  - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).
  - Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.

- Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment activities:** Provides execution steps to be performed. Assessment activities may include, as applicable:
  - Review information/documentation for the assessment to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
  - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment
  - Perform security functional or penetration tests to verify that implemented controls are correctly implemented e.g. to prevent unauthorised access or data modification (e.g. via attempting to log in with invalid credentials to test lockout enforcement or trying to modify protected configuration files without administrative privileges).
  - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
  - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
  - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment verdict:** Defines the pass/fail criteria.
  - **Pass:** The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
    - Minimum cryptographic strength (e.g. AES-128 or higher);
    - Password policy limits (e.g. minimum of 12 characters);
    - Login protection mechanisms (e.g. account lockout after five consecutive failed attempts);
    - Resistance to a specified attack potential (e.g. equivalent to CSA High/AVA\_VAN.3 or higher).
  - **Fail:** The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).
- **Assessment evidence:** Defines the artefacts and documentation collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA essential requirements. The supporting evidence include, where applicable:
  - Test or assessment reports showing the steps performed and results obtained;
  - Logs, configuration files, or audit traces demonstrating the implementation of the requirement;
  - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
  - Relevant vendor or design documentation describing the applied security measures;

## 6.2 No known exploitable vulnerabilities

- REFERENCE: ACC-PKI-KEV-01
  - **Assessment objective:** Verify that:
    - Known exploitable vulnerabilities affecting the product are identified.
    - For each identified known exploitable vulnerability, one of the following applies:
      - the vulnerability assessment demonstrates that the vulnerability is not exploitable in the product; or specific user guidance is provided to prevent exploitation.
    - No known exploitable vulnerability remains in the product without one of the above justifications.
  - **Assessment preparation:**
    - Product documentation identifying elements contained in the product (elements may include software, firmware, or hardware elements, as applicable).
    - Component inventory, bill of materials, or equivalent software identification information, including version and patch-level information where available.
    - Access to the product, or to relevant components such as binaries, packages, images, firmware, containers, or file systems, sufficient to perform vulnerability scanning where technically feasible.
    - Vulnerability scanning tools and associated vulnerability databases suitable for identifying candidate vulnerabilities in the product.
    - Access to recognised public vulnerability sources:
      - Public databases e.g. EUVD, CISA Known Exploited Vulnerabilities (KEV) Catalog, the CVE List, the NIST National Vulnerability Database (NVD)) and relevant vendor advisories;
      - Complementary sources that may support identification of relevant vulnerabilities, where relevant, for example technical research papers, conference papers and other publicly available security research.
  - **Assessment activities:**
    - Review the product documentation, component inventory, bill of materials, or equivalent information to identify the elements contained in the product (which may include software, firmware, or hardware elements, as applicable) and their relevant versions or patch levels, where available.
    - Perform vulnerability scanning, where technically feasible, on the product or relevant components to identify candidate vulnerabilities affecting elements contained in the product.
    - Assess, in accordance with prEN 40000-1-3 [i.17], the vulnerabilities identified through correlation of scanning results, product identification information, vendor advisories, and recognised public vulnerability sources.
    - For each identified known exploitable vulnerability, review the vulnerability assessment and verify whether it demonstrates that the vulnerability is not exploitable in the product:
    - Where the treatment of an identified known exploitable vulnerability relies on user guidance, review the user guidance and verify that it specifically addresses the conditions to prevent exploitation.
    - Verify that no identified known exploitable vulnerability affecting the product remains without:
      - a vulnerability assessment demonstrating non-exploitability in the product; or
      - specific required user guidance to prevent exploitation.

- **Assessment verdict:**
  - Pass: Known exploitable vulnerabilities affecting the product are identified, and each such vulnerability is covered either by a vulnerability assessment demonstrating non-exploitability in the product, or by specific user guidance preventing exploitation.
  - Fail: Vulnerability assessment is missing or insufficient for one or more such vulnerabilities, user guidance is missing or inadequate where relied upon, or one or more known exploitable vulnerabilities remain without justified treatment.
- **Assessment evidence:**
  - Vulnerability scanning results, including the tools and vulnerability databases used.
  - Recognised public vulnerability sources, vendor advisories, and product identification information used in the assessment.
  - Vulnerability assessment records and conclusions produced in accordance with prEN 40000-1-3 [i.17].
  - REQ-PKI-AAC-01Product user guidance relied upon to prevent exploitation, where applicable.

## 6.3 Secure by default configuration

### 6.3.1 SBDC - Access control

- REFERENCE: ACC-PKI-SBDC-01
  - **Assessment objective:**
    - Verify that all system assets are identified as protected assets and that the default access control policy is configured to deny access unless an explicit permission is granted.
  - **Assessment preparation:**
    - System architecture documentation and asset inventory.
    - Default access control policies, role definitions, and authorisation matrices.
    - Administrator documentation describing access control configuration.
    - Default user accounts with different privilege levels, including unauthenticated and unauthorised accounts.
  - **Assessment activities:**
    - Review the asset inventory and identify all system assets requiring access protection.
    - Review access control configurations and verify that the default decision for all protected assets is DENY.
    - Verify that access permissions are granted only through explicit authorisation rules.
    - Attempt to access protected assets using unauthenticated and unauthorised accounts.
    - Verify that access requests without explicit permissions are denied in a deterministic manner.
  - **Assessment verdict:**
    - SUCCESS:
      - All identified assets are configured by default as protected assets.
      - The default access condition for all assets is DENY.

- Access is permitted only when explicitly authorised.
- Unauthorised access attempts are consistently denied.
- **FAIL:**
  - One or more assets are not protected.
  - The default policy allows access without explicit authorisation.
  - Unauthorised access attempts result in successful access or inconsistent behavior.
- **Assessment evidence:**

System architecture and asset inventory documents.

Access control policy configuration files.

Role and permission matrices.

Screenshots or configuration exports showing default DENY settings.

Test execution records and access attempt logs.

### 6.3.2 SBDC - Monitoring

- **REFERENCE:** ACC-PKI-SBDC-02
  - **Assessment objective:** Verify that audit log integrity protection mechanisms are enabled by default and are executed automatically at least once every 24 hours.
- **Assessment preparation:**
  - Audit logging and monitoring configuration documentation.
  - (If available) Documentation describing the audit integrity protection mechanism.
  - System scheduling and logging configurations.
  - Test environment with audit logging enabled.
- **Assessment activities:**
  - Review the audit logging configuration.
  - Verify that audit log integrity protection is enabled by default.
  - Review scheduler configuration and verify that integrity protection events are configured to execute once every 24 hours.
  - Observe system operation or examine generated records to confirm execution of the integrity protection event when reaching expecting activation time (manually set system time if necessary).
  - Verify that evidence of execution is retained in logs or reports.
- **Assessment verdict:**
  - **SUCCESS:**
    - Audit log integrity protection is enabled by default.
    - The integrity protection event is automatically executed at least once every 24 hours.
    - Execution records are generated and retained.



- **FAIL:**
  - Integrity protection is disabled by default.
  - The integrity protection event is not scheduled or does not execute daily.
  - No evidence of execution can be produced.
- **Assessment evidence:**
  - Audit logging configuration files.
  - Scheduler or cron configuration.
  - System logs showing execution timestamps.
  - Integrity verification reports.
  - Screenshots or configuration exports demonstrating default settings.

### 6.3.3 SBDC - Cryptography

- **REFERENCE: ACC-PKI-SBDC-03**
  - **Assessment objective:**
    - Verify that all cryptographic mechanisms are configured by default using algorithms, key lengths, protocols, and parameters that conform to the requirements specified in Annex K.
  - **Assessment preparation:**
    - Cryptographic architecture documentation.
    - Default security configuration files.
    - (If available) Tools capable of inspecting cryptographic configurations and certificates.
  - **Assessment activities:**
    - Identify all cryptographic mechanisms implemented by the system.
    - Review default cryptographic configurations, including algorithms, protocols, key lengths, and operational parameters.
    - Compare the default configurations against Annex K assessment requirements.
    - Verify that deprecated, weak, or non-approved cryptographic mechanisms are not enabled by default.
    - Verify that cryptographic defaults remain compliant following installation or initialisation.
  - **Assessment verdict:**
    - **SUCCESS:**

All cryptographic mechanisms use algorithms and parameters conformant with Annex K assessment requirements.

Default installation results in a compliant cryptographic configuration.
  - **FAIL:**

One or more cryptographic mechanisms do not conform to Annex K requirements.

Default configurations require manual modification to achieve compliance.

- **Assessment evidence:**
  - Cryptographic architecture documentation.
  - Default configuration files.
  - Configuration exports and screenshots.
  - Cryptographic parameter inspection outputs.
  - Mapping of implemented mechanisms to Annex K requirements.
  - Test reports demonstrating default compliance.

### 6.3.4 SBDC - Certificates

- REFERENCE: ACC-PKI-SBDC-04
  - **Assessment objective:**
    - Verify that the default certificate issuance configuration limits certificate validity periods to a maximum of three years.
  - **Assessment preparation:**
    - Certificate management documentation.
    - Default certificate issuance policy and configuration files.
    - Environment capable of generating certificates using default settings.
    - Tools to parse certificate content.
  - **Assessment activities:**
    - Review the certificate issuance configuration and policies.
    - Verify that the default certificate validity period is configured to be no greater than three years.
    - Generate one or more certificates using default settings.
    - Inspect the generated certificates and calculate the validity period using the Not Before and Not After fields or any other field providing validity duration.
    - Verify that no certificate generated using default settings exceeds three years of validity.
  - **Assessment verdict:**
    - SUCCESS:
      - The default certificate validity period is configured to a maximum of three years.
      - Certificates generated using default settings do not exceed three years of validity.
    - FAIL:
      - The default configuration allows certificate validity periods exceeding three years.
      - Certificates generated using default settings exceed the permitted validity period.
  - **Assessment evidence:**
    - Certificate issuance policies and configuration files.
    - Generated test certificates.

- Certificate inspection outputs (Not Before and Not After values).
- Screenshots or configuration exports showing default validity settings.
- Test execution records and assessment report.

## 6.4 Secure updates

- REFERENCE: ACC-PKI-SU-01
  - **Assessment objective:**
    - Verify that the product supports software update mechanisms capable of updating all mutable parts of its software, excluding only those parts that are immutable due to technical constraints (e.g. ROM-based software).
  - **Assessment preparation:**
    - Identify all software components of the product.
    - Determine which components are mutable and which are immutable (e.g. ROM-based).
    - Prepare a test environment with access to the product's update mechanisms.
  - **Assessment activities:**
    - Attempt to update each mutable component of the product's software.
    - Verify that updates are successfully applied to all mutable components.
    - Confirm that immutable components (e.g. ROM-based) are not updated and that this is justified by technical constraints.
    - Document any components that cannot be updated and validate their immutability.
  - **Assessment verdict:**
    - SUCCESS:
      - All mutable components can be updated.
      - Immutable components are correctly identified and justified.
    - FAIL:
      - Any mutable component cannot be updated.
      - Immutable components are not justified or incorrectly classified.
  - **Assessment evidence:**
    - Logs or screenshots of successful updates for mutable components.
    - Documentation or technical specifications justifying immutability for excluded components.
    - Test reports confirming the update process.
- REFERENCE: ACC-PKI-SU-02
  - **Assessment objective:**
    - Verify that the product only installs updates signed by a known and trusted entity with a valid key identified by its PKC (Public Key Certificate).
  - **Assessment preparation:**
    - Obtain a valid signed update from a trusted entity.

- Obtain an unsigned update or an update signed with an invalid/unknown key.
- Prepare a test environment with the product configured to recognise the trusted entity's PKC.
- **Assessment activities:**
  - Attempt to install the valid signed update and verify it is accepted.
  - Attempt to install the unsigned update or update signed with an invalid key and verify it is rejected.
  - Check that the product validates the signature and PKC before installation.
  - Test edge cases, such as expired or revoked certificates.
- **Assessment verdict:**
  - SUCCESS:
    - Valid signed updates are installed.
    - Unsigned or invalidly signed updates are rejected.
  - FAIL:
    - Valid signed updates are rejected.
    - Unsigned or invalidly signed updates are accepted.
- **Assessment evidence:**
  - Logs or screenshots showing successful installation of valid updates.
  - Logs or screenshots showing rejection of unsigned or invalidly signed updates.
  - Test reports confirming signature and PKC validation.
- REFERENCE: ACC-PKI-SU-03
  - **Assessment objective:**
    - Verify that the device administrator can configure when available updates are installed, with options such as immediate installation upon receipt or deferred installation during a maintenance period.
  - **Assessment preparation:**
    - Identify the administrator configuration interface for update settings.
    - Prepare test scenarios for different update installation options (e.g. immediate, deferred).
  - **Assessment activities:**
    - Configure the product to install updates immediately upon receipt and verify the behavior.
    - Configure the product to defer updates to a specified maintenance to specify the set of acceptable values for the and verify the behavior.
    - Attempt to trigger an update under each configuration and confirm it follows the configured timing.
    - Verify that the administrator has sufficient control over the update timing.
  - **Assessment verdict:**
    - SUCCESS:
      - The administrator can configure update timing options.
      - Updates are installed according to the configured timing (immediate or deferred).

- **FAIL:**
  - The administrator cannot configure update timing.
  - Updates are not installed according to the configured timing.
- **Assessment evidence:**
  - Screenshots or logs of the administrator interface showing configuration options.
  - Test reports confirming updates are installed according to the configured timing.
  - Documentation of the update process under different configurations.

## 6.5 Authentication and access control

### 6.5.1 AC - General

- **REFERENCE:** ACC-PKI-AAC-01
- **Assessment objective:**
  - Verify the product allows to create different user profiles (users with different access rights to functions, configuration, and stored data) for the roles defined by PKI policies, each with distinct credentials protected using state of the art cryptographic mechanisms.
- **Assessment preparation:** Access to the administrative and user interfaces of the product.
- **Assessment activities:**
  - Create one account for each manageable profile (at least: PKI Administrator, PKI Operator, PKI Officer, PKI Auditor) with unique credentials.
  - For each account:
    - Attempt to log in using credentials from other accounts or invalid credentials.
    - Log in with the correct credentials for each account.
    - Verify that only the authorised actions defined by the user profile are accessible.
    - If the account is not authorised to, attempt to read stored data
    - If the account is not authorised to, attempt to read configuration data
    - If the account is not authorised to, attempt to modify stored data
    - If the account is not authorised to, attempt to modify configuration data
  - Validate supporting cryptographic mechanisms following annex K assessment requirements.
- **Assessment verdict:**
  - **SUCCESS:** if only correct identification and authentication allows access to the specific rights of a user profile, and only authorised users may read or modify stored data or configuration data, or perform protected actions.
  - **FAIL:** if unauthorised access or incorrect rights assignment is detected.
- **Assessment evidence:**
  - Results of identification and authentication attempts (successful and failed).
  - List of validated functionalities and data access rights for each user profile.

- Screenshots or logs of access attempts and rights verification.
- REFERENCE: ACC-PKI-AAC-02
  - **Assessment objective:**
    - Verify that the product only allows identified and authenticated authorised users to perform access-controlled actions.
  - **Assessment preparation:**
    - Access to the product interfaces.
  - **Assessment activities:**
    - Enumerate product interfaces and identify any interfaces without access control.
    - Attempt to perform protected actions without being identified or authenticated.
    - Log in as authorised users, then try to intercept and replay user authentication data or session authentication tokens.
    - Systematically try all possible combinations of usernames, passwords, or other credentials to attempt unauthorised access.
  - **Assessment verdict:**
    - SUCCESS: No unauthorised users may read or modify stored data or configuration data, or perform protected actions.
    - FAIL: If unauthorised access or incorrect rights assignment is detected.
  - **Assessment evidence:**
    - Results of identification and authentication attempts (both successful and failed).
    - Screenshots or logs of access attempts, rights verification, or rejected actions.

## 6.6 Confidentiality

The following requirement of cryptographic mechanisms validity shall conform to Annex K assessment requirements:

- REQ-PKI-CON-02
- REQ-PKI-CON-04
- REQ-PKI-CON-05
- REQ-PKI-CON-06
- REQ-PKI-CON-07
- REQ-PKI-CON-08

Validity of access control requirement are covered by clause 6.5:

- REQ-PKI-CON-01

## 6.6.1 CON - General

- REFERENCE: ACC-PKI-CON-01
  - **Assessment objective:**
    - Verify that private keys generated by the product are protected against unauthorised export, copying, disclosure, or removal.
  - **Assessment preparation:**
    - (If available) Key management architecture documentation.
    - Documentation describing private key generation, storage, and access controls.
    - Identify interfaces, APIs, administrative functions, backup mechanisms, and export capabilities that may provide access to private keys.
    - Access to authorised and unauthorised user accounts.
  - **Assessment activities:**
    - (If available) Review the design of private key generation and storage mechanisms.
    - Verify that generated private keys are stored in protected locations or secure cryptographic devices.
    - Verify that export or copy operations require explicit authorisation.
    - Attempt to access, export, copy, or remove private keys using unauthorised accounts and interfaces.
    - Verify that unauthorised operations are denied and appropriately logged.
    - Where controlled migration of key pairs is supported, verify that transfer is performed only under documented and authorised procedures.
  - **Assessment verdict:**
    - SUCCESS:
      - Unauthorised users cannot access, export, copy, or remove private keys.
      - All key management interfaces enforce authorisation controls.
      - Any permitted key transfer mechanisms are appropriately controlled and documented.
    - FAIL:
      - Unauthorised users can obtain, copy, export, or remove private keys.
      - Key protection mechanisms can be bypassed.
      - Key migration mechanisms lack appropriate controls.
  - **Assessment evidence:**
    - Key management design documentation.
    - Access control configurations.
    - Security architecture diagrams.
    - Test results of attempted unauthorised exports.
    - Audit logs of key management operations.
    - Configuration files and screenshots.

- REFERENCE: ACC-PKI-CON-02
  - **Assessment objective:**
    - Verify that when a pseudonymous certificate is used to exchange a public key associated with an ephemeral identity, the certificate contains no information that could directly or indirectly reveal, correlate, or facilitate identification of the sender, thereby preserving sender pseudonymity.
  - **Assessment preparation:**
    - Product security architecture documentation describing the implementation of pseudonymous certificates and ephemeral identities.
    - The certificate profile specification, including all mandatory and optional certificate fields and extensions.
    - Pseudonymous certificates generated by the product.
    - Product configuration settings for certificate generation and identity management.
    - Tools for certificate parsing and inspection.
    - Identify any external repositories, certificate databases, or services that may be used to correlate certificate information.
  - **Assessment activities:**
    - Review the product design documentation to determine how pseudonymous certificates are generated and associated with ephemeral identities.
    - Examine the certificate profile and identify all fields and extensions included in the pseudonymous certificate.
    - Inspect sample certificates and verify that subject names, subject alternative names, serial numbers, issuer attributes, custom extensions, identifiers, URLs, metadata, or any other fields do not contain:
      - Personally identifiable information (PII);
      - Persistent identifiers linked to a specific user or device;
      - Information that permits direct or indirect sender identification;
      - Values that can be correlated across multiple certificates to establish sender identity.
      - Verify that any included certificate information is strictly limited to technical information necessary for certificate validation and cryptographic operation.
      - Assess whether certificate serial number generation, extension values, and metadata are randomly generated or otherwise designed to prevent sender correlation.
      - Review product configuration and operational procedures to ensure that pseudonymous certificates cannot be configured to include identifying information.
      - Attempt to correlate multiple pseudonymous certificates issued to the same sender and determine whether any certificate data enables identity linkage.
  - **Assessment verdict:**
    - SUCCESS:
      - The product generates pseudonymous certificates containing only technical information necessary for cryptographic processing and validation.
      - No certificate field or extension contains identifying information, persistent identifiers, or metadata that can directly or indirectly reveal the sender's identity.



- Multiple certificates associated with the same sender cannot be correlated using certificate contents.
  - Product configuration prevents the inclusion of identifying information in pseudonymous certificates.
- **FAIL:**
  - One or more certificate fields contain information that directly or indirectly identifies the sender.
  - Certificate contents include persistent identifiers or metadata that enable correlation of certificates belonging to the same sender.
  - Certificate serial numbers, extensions, naming conventions, or custom attributes permit sender re-identification.
  - Product configuration allows pseudonymous certificates to include user-related identifying information.
- **Assessment evidence:**
  - Product architecture and design documentation describing pseudonymous certificate generation.
  - Certificate profile specifications and extension definitions.
  - Parsed representations of sample pseudonymous certificates.
  - Configuration files and settings controlling certificate generation.
  - Assessment records demonstrating inspection of certificate fields and extensions.
  - Correlation analysis results showing that certificate contents cannot be used to identify or link the sender.
  - Assessor observations and test logs supporting the final determination.
- **REFERENCE: ACC-PKI-CON-03**
  - **Assessment objective:**
    - Verify that all transmissions of personal or sensitive data are protected using state-of-the-art cryptographic mechanisms in accordance with Annex K.
  - **Assessment preparation:**
    - Data flow diagrams or interface specifications.
    - Data classification documentation identifying personal and sensitive data.
    - Cryptographic configuration documentation.
    - Network monitoring tools.
    - Test environment including external components the product will connect to.
  - **Assessment activities:**
    - Identify all interfaces transmitting personal or sensitive data.
    - Verify that transmitted data is protected by cryptographic mechanisms compliant with Annex K.
    - Capture network traffic during data transmission. Verify that sensitive information is not transmitted in plaintext.

- **Assessment verdict:**
  - SUCCESS:
    - All identified sensitive data transmissions are cryptographically protected.
    - The implemented cryptographic mechanisms conform to Annex K assessment requirement.
    - No sensitive data is observable in plaintext.
  - FAIL:
    - Sensitive data is transmitted without cryptographic protection.
    - Non-approved or weak cryptographic mechanisms are used.
    - Sensitive information can be recovered from network captures.
- **Assessment evidence:**
  - Data flow diagrams.
  - Data classification documentation.
  - Network packet captures.
  - Cryptographic configuration files.
  - Protocol inspection reports.
  - Test execution records.

## 6.6.2 CON - Secure storage and communications

- REFERENCE: ACC-PKI-CON-04
  - **Assessment objective:**
    - Verify that communications with the SCD or KMS are securely established, maintained, and use only authorised and correctly implemented interfaces.
  - **Assessment preparation:**
    - SCD/KMS integration documentation or API documentation.
    - Product interface specifications and API documentation.
    - Cryptographic configuration documentation.
    - Running product with access to an operational SCD or KMS.
    - Network monitoring tools.
  - **Assessment activities:**
    - Review the architecture and communication methods used with the SCD or KMS.
    - Verify that communications are protected using authenticated and encrypted channels.
    - Verify that only documented interfaces and APIs are invoked.
    - Observe key management operations that invoke the SCD or KMS.
    - Capture network traffic during data transmission and verify that sensitive information is not transmitted in plaintext.
    - Introduce communication failures or invalid requests and verify proper error handling.

- Verify that security-relevant interactions are logged.
- **Assessment verdict:**
  - SUCCESS:
    - Secure authenticated communications with the SCD or KMS are established and maintained.
    - Only approved interfaces are used.
    - Communication failures are securely handled.
  - FAIL:
    - Communications occur without appropriate protection.
    - Undocumented or insecure interfaces are used.
    - Communication failures compromise security functions.
- **Assessment evidence:**
  - Architecture documentation.
  - Interface specifications.
  - Communication configuration files.
  - Network captures.
  - API invocation logs.
  - Audit records.

### 6.6.3 CON - Key management

- REFERENCE: ACC-PKI-CON-05
- **Assessment objective:**
  - Verify that exported private or symmetric keys are protected against disclosure using cryptographic mechanisms conforming to Annex K.
- **Assessment preparation:**
  - Determine whether key export functionality exists.
  - Obtain export procedures and cryptographic documentation.
  - Prepare test keys and export environments.
- **Assessment activities:**
  - Verify whether key export functionality is supported.
  - Review mechanisms protecting exported keys.
  - Export private and symmetric keys using supported procedures.
  - Verify that exported keys are encrypted using approved algorithms and key management procedures as defined by Annex K assessment requirements.
  - Attempt to access exported keys without possessing required decryption material.

- **Assessment verdict:**
  - SUCCESS:
    - Exported keys are protected using approved cryptographic mechanisms.
    - Unauthorised parties cannot recover exported key material.
  - FAIL:
    - Keys are exported in plaintext.
    - Weak or non-approved protection mechanisms are used.
    - Exported key material can be recovered without authorisation.
- **Assessment evidence:**
  - Export procedures.
  - Cryptographic configurations.
  - Exported key files.
  - Key inspection results.
  - Test reports.
- REFERENCE: ACC-PKI-CON-06
  - **Assessment objective:**
    - Verify that secret keys are never persistently stored in plaintext and are protected by secure cryptographic devices or encryption mechanisms using independently managed keys.
  - **Assessment preparation:**
    - Key management and storage architecture documentation.
    - Database and filesystem documentation.
    - Access to storage repositories and backup media.
    - (If possible) Known private key content
  - **Assessment activities:**
    - Identify all locations where secret keys may be stored.
    - Review storage mechanisms and encryption methods.
    - Inspect storage locations, backups, and configuration files for plaintext secret keys.
    - Verify that keys stored outside secure cryptographic devices are encrypted using approved mechanisms.
    - Verify that plaintext key access occurs only temporarily during cryptographic operations.
  - **Assessment verdict:**
    - SUCCESS:
      - Secret keys are never persistently stored in plaintext.
      - Stored keys are protected by secure cryptographic devices or approved encryption mechanisms.
      - Plaintext access is temporary and limited to operational requirements.

- **FAIL:**
  - Secret keys are persistently stored in plaintext.
  - Encryption mechanisms do not comply with Annex K.
  - Plaintext key exposure exceeds operational requirements.
- **Assessment evidence:**
  - Architecture documentation.
  - Storage configuration files.
  - Database and filesystem inspection results.
  - Backup inspection results.
  - Key management procedures.

## 6.7 Integrity

Assessment requirements covering Monitoring are presented in clause 6.13.

The validity of the cryptographic mechanisms used to ensure those functions is covered by annex K assessment requirement:

- REQ-PKI-CON-02
- REQ-PKI-CON-04
- REQ-PKI-CON-05
- REQ-PKI-CON-06
- REQ-PKI-CON-07
- REQ-PKI-CON-08
- REQ-PKI-CON-10
- REQ-PKI-CON-11

### 6.7.1 INT - Monitoring

- REFERENCE: ACC-PKI-INT-01
- **Assessment objective:**
  - Verify that unauthorised modifications to stored audit records are detected using cryptographic integrity mechanisms conforming to Annex K.
- **Assessment preparation:**
  - Audit architecture documentation.
  - Integrity protection mechanism specifications.
  - Prepare access to test audit records.
- **Assessment activities:**
  - Generate audit records.
  - Modify stored audit records without authorisation.

- Execute integrity verification procedures.
    - Verify that modifications are detected and reported.
    - Verify that integrity mechanisms are conform to Annex assessment requirements.
  - **Assessment verdict:**
    - SUCCESS: Unauthorised modifications are reliably detected.
    - FAIL: Unauthorised modifications remain undetected.
  - **Assessment evidence:**
    - Audit configuration.
    - Integrity verification reports.
    - Tampered audit records.
    - System logs.
- REFERENCE: ACC-PKI-INT-02
    - **Assessment objective (OBJECTIVE):**
      - Verify that timestamps are included within the integrity protection scope of audit records.
    - **Assessment preparation:**
      - Audit record mechanisms documentation.
      - Integrity mechanism specifications.
    - **Assessment activities:**
      - Generate audit records.
      - Modify timestamps without changing other fields.
      - Execute integrity verification.
      - Verify that timestamp modification is detected.
    - **Assessment verdict:**
      - SUCCESS: Timestamp modifications invalidate integrity verification.
      - FAIL: Timestamp modifications are not detected.
    - **Assessment evidence:**
      - Audit record format documentation.
      - Test audit records.
      - Integrity verification results.
    - Audit logs.
  - REFERENCE: ACC-PKI-INT-03
    - **Assessment objective:**
      - Verify that audit log integrity protection events are periodically created and include chaining of current and previous integrity protection events.

- **Assessment preparation:**
  - Audit signing specifications.
  - Scheduler configuration.
  - Prepare a test environment allowing audit event logging.
- **Assessment activities:**
  - Generate audit entries.
  - Trigger multiple signing events.
  - Verify that cryptographic integrity protection include all entries since the previous signing event.
  - Verify inclusion of the previous signature value.
  - Verify that signing events occur even when no entries have been added.
  - Verify that all cryptographic integrity protection mechanisms conform to Annex K assessment requirement.
- **Assessment verdict:**
  - SUCCESS: Periodic signed audit chains are correctly created.
  - FAIL: Signatures omit entries, omit previous signature values, or fail to execute.
- **Assessment evidence:**
  - Scheduler configuration.
  - Audit logs.
  - Signature records.
  - Integrity verification reports.
- REFERENCE: ACC-PKI-INT-04
  - **Assessment objective:**
    - Verify that the product ensures the integrity of audit logs using appropriate protection mechanisms without Annex Conformant cryptographic mechanisms.
  - **Assessment preparation:**
    - Obtain logging architecture documentation.
    - Obtain integrity protection configuration.
  - **Assessment activities:**
    - Review implemented integrity mechanisms.
    - Attempt unauthorised modification, deletion, or insertion of log entries.
    - Verify that integrity violations are prevented or detected.
    - Verify operation of external logging mechanisms where implemented.
  - **Assessment verdict:**
    - SUCCESS: Audit log integrity is maintained and violations are detected.
    - FAIL: Audit logs can be modified without detection.

- **Assessment evidence:**
  - Logging architecture.
  - Configuration files.
  - Audit records.
  - Tests records
- REFERENCE: ACC-PKI-INT-05
  - **Assessment objective:**
    - Verify that the frequency of audit log signing events is configurable.
  - **Assessment preparation:**
    - Administration documentation.
    - Configuration access.
  - **Assessment activities:**
    - Review available configuration settings.
    - Modify integrity protection frequency parameters.
    - Verify that changes are applied.
    - Verify operation using multiple configured frequencies.
  - **Assessment verdict:**
    - SUCCESS: Signing frequency is configurable and functions correctly.
    - FAIL: Signing frequency cannot be configured or configuration changes are ineffective.
  - **Assessment evidence:**
    - Configuration files.
    - Administrative procedures.
    - System logs.
    - Test records.

## 6.7.2 INT - Certificate signing

- REFERENCE: ACC-PKI-INT-06
  - **Assessment objective:**
    - Verify that certificate signatures are created exclusively using an SCD.
  - **Assessment preparation:**
    - Certificate signing architecture documentation.
    - SCD integration documentation.
  - **Assessment activities:**
    - Generate certificate signing requests.
    - Observe certificate signing operations.



- Verify that private signing keys remain within the SCD.
- Attempt signing operations without the SCD.
- **Assessment verdict:**
  - SUCCESS: Certificate signatures are generated exclusively through the SCD.
  - FAIL: Certificate signatures can be generated outside the SCD.
- **Assessment evidence:**
  - Architecture documentation.
  - SCD logs.
  - Certificate generation logs.
  - Test records.

### 6.7.3 INT- CRL signing

- REFERENCE: ACC-PKI-INT-07
  - **Assessment objective:**
    - Verify that CRL signatures are created exclusively using an SCD.
  - **Assessment preparation:**
    - Obtain CRL signing documentation.
    - Obtain SCD integration documentation.
  - **Assessment activities:**
    - Generate CRLs.
    - Observe signing operations.
    - Verify that SCD logs identify the signature creation request and generation.
    - Verify that signing keys remain within the SCD.
    - Attempt CRL generation without the SCD.
  - **Assessment verdict:**
    - SUCCESS: CRL signatures are generated only through the SCD.
    - FAIL: CRL signatures can be generated outside the SCD.
  - **Assessment evidence:**
    - CRL generation logs.
    - SCD logs.
    - Architecture documentation.
    - Test reports.
- REFERENCE: ACC-PKI-INT-08
  - **Assessment objective:**
    - Verify that CRLs are digitally signed.

- **Assessment preparation:**
  - Determine whether CRLs are supported.
  - CRL signing procedures and trust model documentation.
  - Prepare certificate and signature validation tools.
- **Assessment activities:**
  - Generate CRLs.
  - Inspect the signer identity and signature information.
  - Verify that the signer corresponds to a CA (e.g. basicConstraints field contains CA:TRUE) or an authorised delegated entity (certificate with keyUsage including cRLSign).
  - Validate the digital signature.
  - Attempt to validate a CRL modified after signing.
- **Assessment verdict:**
  - SUCCESS:
    - All CRLs are signed by authorised entities.
    - Signature validation succeeds.
    - Tampered CRLs fail validation.
  - FAIL:
    - CRLs are unsigned.
    - CRLs are signed by unauthorised entities.
    - Signature validation does not detect tampering.
- **Assessment evidence:**
  - CRL samples.
  - Signature validation reports.
  - Trust model documentation.
  - Delegation documentation.
  - Test execution records.

## 6.8 Data minimisation

### 6.8.1 General

- REFERENCE: ACC-PKI-DM-01
- **Assessment objective:**
  - Determine whether the product only maintains network configuration data necessary for communication with PKI system elements required by the applicable use case and does not maintain unnecessary network configuration information.
- **Assessment preparation:**
  - Product architecture and deployment documentation.

- List of external components and interfaces to connect to.
- Access to configuration files, administrative guides, and installation procedures.
- **Assessment activities:**
  - Review the product design and configuration documentation.
  - Identify all stored network configuration parameters.
  - Verify that each configured endpoint, interface, protocol, and network parameter is required to support the applicable PKI use case.
  - Verify that no unused, unnecessary, or undocumented network configuration data are maintained.
  - Confirm that administrators cannot configure network connections unrelated to the PKI functions provided by the product.
- **Assessment verdict:**
  - SUCCESS:
    - All maintained network configuration data are necessary for communication with PKI elements required by the applicable use case.
    - No unnecessary network endpoints, protocols, interfaces, or configuration parameters are maintained.
  - FAIL:
    - The product maintains network configuration data unrelated to the applicable PKI functions.
    - Unnecessary interfaces or endpoints are configured or can be configured without operational justification.
- **Assessment evidence:**
  - Product architecture documentation.
  - Configuration files and parameter listings.
  - Assessment records demonstrating the review of network configuration parameters.
- REFERENCE: REQ-PKI-DM-02
  - **Assessment objective:**
    - Verify that the product only maintains and processes user data necessary for certificate management.
  - **Assessment preparation:**
    - Access to the product's user data storage and certificate management logs.
  - **Assessment activities:**
    - Review the user data stored and processed by the product.
    - Identify all user data related to certificate management (e.g. certificate requests, updates).
    - Verify that no unnecessary or unrelated user data is stored or processed.
    - Confirm that the stored and processed data is limited to what is required for certificate management.

- **Assessment verdict:**
  - SUCCESS: If the product only maintains and processes user data necessary for certificate management.
  - FAIL: If unnecessary or unrelated user data is found.
- **Assessment evidence:**
  - List of stored and processed user data.
  - Documentation or logs showing the alignment of user data with certificate management requirements.
- REFERENCE: ACC-PKI-DM-03
  - **Assessment objective:**
    - Determine whether the product maintains only the configuration data required to implement the PKC management functions applicable to the use case.
  - **Assessment preparation:**
    - Product configuration documentation.
    - List of implemented PKC management functions and associated configuration parameters.
  - **Assessment activities:**
    1. Review the applicable use case requirements.
    2. Identify all PKC management functions implemented by the product.
    3. Review all PKC-related configuration parameters.
    4. Verify that each configuration item supports an identified PKC management function.
    5. Verify that unnecessary PKC management functions and associated configuration data are not maintained.
  - **Assessment verdict:**
    - SUCCESS:
      - All PKC configuration parameters support identified certificate management functions required by the applicable use case.
      - No unnecessary PKC management functions or associated configuration data are maintained.
    - FAIL:
      - Configuration data are maintained for PKC functions not required by the applicable use case.
      - Unnecessary PKC management capabilities are present.
  - **Assessment evidence:**
    - Use case analysis.
    - Configuration documentation.
    - Assessment records mapping configuration parameters to PKC functions.

## 6.8.2 DM - Secret management

- REFERENCE: ACC-PKI-DM-04
  - **Assessment objective:**
    - Determine whether all key generation operations are performed exclusively by Secure Cryptographic Devices (SCDs) or remote Key Management Systems (KMSs) implementing cryptographic mechanisms conformant with Annex K.
  - **Assessment preparation:**
    - Cryptographic architecture documentation.
    - Documentation for the SCD or KMS.
    - Cryptographic algorithm specifications and configuration information.
    - Identify all key generation functions.
  - **Assessment activities:**
    - Review the product's cryptographic architecture.
    - Identify all key generation operations.
    - Verify that keys are generated only by approved SCDs or remote KMSs.
    - Verify that no software-based key generation mechanism exists outside the SCD or KMS.
    - Verify that the cryptographic mechanisms used by the SCD or KMS conform to Annex K requirements.
  - **Assessment verdict:**
    - SUCCESS:
      - All key generation operations are delegated exclusively to approved SCDs or remote KMSs.
      - The cryptographic mechanisms employed conform to Annex K requirements.
    - FAIL:
      - Keys can be generated outside an SCD or KMS.
      - The SCD or KMS uses non-approved cryptographic mechanisms.
  - **Assessment evidence:**
    - Cryptographic architecture documentation.
    - SCD/KMS specifications and certifications.
    - Configuration files.
    - Assessment records demonstrating key generation paths.

## 6.9 Availability protection

### 6.9.1 AP - Certificate suspension and revocation

- REFERENCE: ACC-PKI-AP-01
  - **Assessment objective:**
    - Verify that revoked certificates cannot be returned to a valid status after revocation.
  - **Assessment preparation:**
    - Certificate lifecycle management documentation.
    - Certificate status management procedures and configurations.
    - Prepare test certificates and authorised administrative accounts.
  - **Assessment activities:**
    - Issue a test certificate.
    - Revoke the certificate using the supported revocation procedure.
    - Verify that the certificate status changes to revoked.
    - Attempt to reinstate, reactivate, or remove the revocation status of the certificate.
    - Verify that all attempts to restore the certificate to a valid state are rejected.
  - **Assessment verdict:**
    - SUCCESS:
      - Once revoked, the certificate permanently remains in the revoked state.
      - No administrative interface or API permits reinstatement.
    - FAIL:
      - A revoked certificate can be returned to a valid state.
      - Revocation information can be modified to remove the revoked status.
  - **Assessment evidence:**
    - Certificate lifecycle procedures.
    - Certificate status records.
    - Revocation logs.
    - Administrative interface screenshots.
    - Test execution records.
- REFERENCE: ACC-PKI-AP-02
  - **Assessment objective:**
    - Verify that CRLs contain a valid nextUpdate field and that the special value 99991231235959Z is used only for the final CRL.
  - **Assessment preparation:**
    - Determine whether CRLs are supported.

- CRL generation procedures and configuration documentation.
- Prepare CRL inspection tools.
- **Assessment activities:**
  - Generate one or more CRLs.
  - Inspect the nextUpdate field in each CRL.
  - Verify that ordinary CRLs contain the next scheduled issue time.
  - Where applicable, generate the final CRL and verify that nextUpdate is set to 99991231235959Z.
  - Verify that no non-final CRL uses the special value.
- **Assessment verdict:**
  - SUCCESS:
    - All generated CRLs contain a valid nextUpdate field.
    - The special value is used only for the final CRL.
  - FAIL:
    - A CRL omits the nextUpdate field.
    - The special value is incorrectly used or omitted.
- **Assessment evidence:**
  - CRL configuration files.
  - Generated CRLs.
  - CRL inspection outputs.
  - Test records.
- REFERENCE: ACC-PKI-AP-03
  - **Assessment objective:**
    - Verify that CARLs are generated at least annually and that the nextUpdate value does not exceed one year after issuance.
  - **Assessment preparation:**
    - Determine whether CARLs are supported.
    - CARL generation procedures and scheduling configuration.
    - Prepare CARL inspection tools.
    - Product in executable state.
  - **Assessment activities:**
    - Review CARL generation schedules.
    - Generate or inspect existing CARLs.
    - Verify the issuance dates and nextUpdate values.
    - Calculate the interval between issuance and nextUpdate.
    - Verify that the interval does not exceed one year.

- **Assessment verdict:**
  - SUCCESS:
    - CARLs are generated at least once per year.
    - nextUpdate is not more than one year after issuance.
  - FAIL:
    - CARLs are not generated annually.
    - nextUpdate exceeds one year.
- **Assessment evidence:**
  - CARL schedules.
  - Generated CARLs.
  - CARL inspection reports.
  - System logs.
- REFERENCE: ACC-PKI-AP-04
  - **Assessment objective:**
    - Verify that revocation of a CA certificate immediately triggers generation of a new CARL.
  - **Assessment preparation:**
    - Determine whether CARLs are supported.
    - Obtain CA revocation procedures and CARL generation procedures.
    - Prepare test CA certificates.
    - Product in executable state.
  - **Assessment activities:**
    - Revoke a CA certificate.
    - Monitor the system response.
    - Verify that a new CARL is generated after revocation.
    - Verify that the revoked CA certificate is included in the CARL.
    - Verify that generation events are logged.
  - **Assessment verdict:**
    - SUCCESS:
      - A new CARL is generated after CA certificate revocation.
      - The revoked CA certificate appears in the CARL.
    - FAIL:
      - No new CARL is generated.
      - The revoked CA certificate is omitted.



- **Assessment evidence:**
  - Revocation logs.
  - Generated CARLs.
  - System event logs.
  - Test reports.

## 6.9.2 AP - Certificate status services

- REFERENCE: ACC-PKI-AP-05
  - **Assessment objective:**
    - Verify that revocation status information remains available until certificate expiration.
  - **Assessment preparation:**
    - Obtain certificate status service documentation.
    - Product in executable state.
    - Prepare certificates with varying validity periods.
  - **Assessment activities:**
    - Issue and revoke test certificates.
    - Query certificate status information during the certificate validity period.
    - Verify that status information remains available until expiration.
    - Verify behavior immediately after expiration.
  - **Assessment verdict:**
    - SUCCESS:
      - Status information remains available until certificate expiration.
    - FAIL:
      - Status information becomes unavailable before certificate expiration.
  - **Assessment evidence:**
    - Status service configuration.
    - Certificate status responses.
    - Test records.
  - Service logs.
- REFERENCE: ACC-PKI-AP-06
  - **Assessment objective:**
    - Verify that the product supports at least one certificate status mechanism: OCSP or CRL.
  - **Assessment preparation:**
    - Obtain product documentation.
    - Prepare OCSP and CRL validation tools.

- Product in executable state.
- **Assessment activities:**
  - Identify supported certificate status services.
  - Verify configuration and operation of each supported service.
  - Query certificate status information.
  - Verify that responses accurately reflect certificate status.
- **Assessment verdict:**
  - SUCCESS:
    - At least one certificate status mechanism is implemented and operational.
  - FAIL:
    - Neither OCSP nor CRL functionality is supported.
- **Assessment evidence:**
  - Product documentation.
  - Configuration files.
  - Status responses.
  - Test records.
- REFERENCE: ACC-PKI-AP-07
  - **Assessment objective:**
    - Verify that multiple certificate status services provide consistent certificate status information.
  - **Assessment preparation:**
    - Determine supported status mechanisms.
    - Prepare certificates and status query tools.
    - Product in executable state.
  - **Assessment activities:**
    - Issue and revoke test certificates.
    - Query all supported status services.
    - Record responses over time.
    - Verify that status information remains consistent, considering expected propagation delays.
    - Verify that discrepancies are temporary and documented.
  - **Assessment verdict:**
    - SUCCESS:
      - All status mechanisms eventually provide consistent status information.
      - Any temporary differences are within documented synchronisation periods.
    - FAIL:
      - Status information remains inconsistent.

- Different services provide contradictory certificate statuses.
- **Assessment evidence:**
  - Status service configurations.
  - Status responses.
  - Synchronisation documentation.
  - Test reports.

### 6.9.3 AP - Key management

- REFERENCE: ACC-PKI-AP-08
- **Assessment objective:**
  - Verify that the product can generate, store, and manage multiple key pairs simultaneously.
- **Assessment preparation:**
  - Key management documentation.
  - Prepare administrative access and test environments.
  - Product in executable state.
- **Assessment activities:**
  - Generate multiple key pairs.
  - Assign key pairs to different services, authorities, or purposes.
  - Verify that multiple key pairs coexist without conflict.
  - Verify that management operations can be performed independently on each key pair.
  - Verify support for key lifecycle activities such as activation and rotation.
- **Assessment verdict:**
  - SUCCESS:
    - Multiple key pairs can be maintained simultaneously.
    - Key management operations function independently for each key pair.
  - FAIL:
    - Multiple key pairs cannot coexist.
    - Management operations interfere with other key pairs.
- **Assessment evidence:**
  - Key management documentation.
  - Key inventories.
  - Administrative screenshots.
  - System logs.
  - Test records.

- REFERENCE: ACC-PKI-AP-09
  - **Assessment objective:**
    - Verify that authorised users can delete keys and that unauthorised users cannot perform key deletion.
  - **Assessment preparation:**
    - Key management procedures.
    - Prepare authorised and unauthorised user accounts for key deletion.
    - Generate test key pairs.
  - **Assessment activities:**
    - Generate test key pairs.
    - Delete keys using authorised accounts.
    - Verify successful deletion and removal of associated key references.
    - Attempt key deletion using unauthorised accounts.
    - Verify that unauthorised deletion attempts are denied and logged.
  - **Assessment verdict:**
    - SUCCESS:
      - Authorised users can successfully delete keys.
      - Unauthorised users cannot delete keys.
      - Key deletion events are logged.
    - FAIL:
      - Authorised users cannot delete keys.
      - Unauthorised users can delete keys.
      - Key deletion events are not properly recorded.
      - Keys are still accessible or usable after erasure request.
  - **Assessment evidence:**
    - Key management procedures.
    - Access control configurations.
    - System and audit logs.
    - Administrative screenshots.
    - Test execution records.

## 6.10 Impact minimisation

As stated in clause 5.10, since minimizing the impact on other systems relies on the combination of requirements identified in clause 5. All security requirement collectively ensure the product correctly manages the Public Key Certificate (PKC) lifecycle and provides the appropriate level of trust to dependent systems. Thus the assessment of impact minimisation is covered by all other assessment requirements.

## 6.11 Minimisation of attack surfaces

- REFERENCE: ACC-PKI-MAS-01
  - **Assessment objective:**
    - Verify that the product implements only the interfaces required to support the use case as defined in Annex U.
    - Verify that no additional, undocumented, unnecessary, or unauthorised interfaces are present or accessible.
  - **Assessment preparation:**
    - List of use case interfaces as defined in Annex U.
    - Product architecture documentation, interface specifications, and deployment documentation.
    - Identify all communication interfaces that may be exposed by the product, including:
      - Network services and listening ports.
      - Administrative interfaces.
      - Web interfaces and APIs.
      - Command-line interfaces.
      - Database interfaces.
      - File transfer interfaces.
    - Prepare test tools capable of identifying exposed interfaces (e.g. port scanners, API discovery tools, operating system service enumeration utilities).
    - Product in executable state
  - **Assessment activities:**
    - Review the product documentation and identify all interfaces required by the use case.
    - Enumerate all implemented interfaces exposed by the product in its operational configuration.
    - For each discovered interface:
      - Determine its purpose and associated functionality.
      - Verify that it is explicitly required by the use case.
    - Attempt to identify undocumented or hidden interfaces by:
      - Enumerating network ports and services.
      - Inspecting running processes and service configurations.
      - Discovering accessible APIs and endpoints.
      - Reviewing installation packages and configuration files for additional services.
    - Verify that:
      - No additional interfaces are active beyond those identified for the use case.
      - Disabled or unsupported interfaces cannot be accessed or enabled without authorisation.
      - Administrative, debugging, maintenance, or test interfaces are either absent or explicitly identified and justified by the use case.

- Document the mapping between each implemented interface and its corresponding Annex U use case.
- **Assessment verdict:**
  - **SUCCESS:**
    - Every implemented interface can be mapped to one or more interface identified for the use cases in Annex U.
    - No undocumented, unnecessary, or unauthorised interfaces are present.
    - No hidden, debugging, maintenance, or test interfaces are accessible unless explicitly required by the use case.
    - The implemented interfaces are limited to those necessary to provide the use case functionality.
  - **FAIL:**
    - One or more implemented interfaces cannot be mapped to an interface required for the use cases.
    - Additional, undocumented, or unnecessary interfaces are present or accessible.
    - Hidden, debugging, maintenance, or test interfaces are exposed without explicit authorisation or justification.
- **Assessment evidence:**
  - Interface inventory showing all implemented interfaces.
  - Mapping matrix between implemented interfaces and Annex U use case.
  - Results of network port scans and service enumeration.
  - API discovery results and endpoint listings, where applicable.
  - Screenshots or reports showing active services and interfaces.
  - Product documentation identifying required interfaces.
  - Test records demonstrating that no additional interfaces are present or accessible.

## 6.12 Exploitation mitigation mechanisms

### 6.12.1 EMM - Certificate issuance

- REFERENCE: ACC-PKI-EMM-01
- **Assessment objective:**
  - Verify the certificates issued by the certificate generation service are public-key certificates or attribute certificates whose format complies with the X.509 standard ITU-T X.509 [2].
- **Assessment preparation:**
  - Certificate request interface accessible.
  - Required user profiles defined to generate the certificate.
  - Certificate Policy parameters defined, i.e. product configuration related to configurable certificate generation constraints (e.g. Certificate validity periode, mandatory Certificate fields and values, etc.)

- **Assessment activities:**
- Verify that certificates are correctly generated when correct information is provided.
  - Provide a set of necessary and correct elements defined by the Certificate Policy.
  - Generate, i.e. activate the certificate generation function with the correct inputs
  - Verify that a certificate is generated including the inputted data
  - Verify that the signature is correct and covers all the necessary fields
  - Verify that certificates are not generated if inputted data are missing or incorrect related to the Certificate Policy configuration
  - Provide a set of necessary and correct elements defined by the Certificate Policy.
  - Generate, i.e. activate the certificate generation function with the correct inputs
  - Verify that a certificate is generated including the inputted data
  - Verify that the signature is correct and covers all the necessary fields
- **Assessment verdict:**
  - SUCCESS: Certificates are generated only when all required and correct inputs are provided, conform to the X.509 format, correctly include the supplied data, and have a valid signature covering all required fields.
  - FAIL: Certificates are generated with missing or incorrect inputs, do not conform to the X.509 format, contain incorrect data, have an invalid signature, or omit required fields from signature protection.
- **Assessment evidence:**
  - Certificate generation requests parameters
  - Generated certificates or error messages generated by the product
  - Signature verification input and output
- REFERENCE: ACC-PKI-EMM-02
  - **Assessment objective:** Verify the product implements and follows a certificate profile for issued certificates.
  - **Assessment preparation:**
    - Document the circumstances in which the certificate generation service may issue a certificate.
    - Ability to request a certificate issuance for the different identified circumstances.
    - Document the certificate profile implemented by the product.
  - **Assessment activities:** For each way the product may issue a certificate:
    - issue a certificate;
    - verify the certificate to match the constraints of the certificate profile;
    - for all constraints of the certificate profile, attempt to issue a certificate disrespecting the constraint, and verify the issuance to fail.
  - **Assessment verdict:**
    - SUCCESS: All documented certificate issuance scenarios produce certificates conforming to the documented certificate profile, and all attempts to violate profile constraints are rejected without issuing a non-conforming certificate.

- FAIL: Any valid issuance scenario fails, any issued certificate does not conform to the documented certificate profile, or any profile constraint can be bypassed to issue a non-conforming certificate.
- **Assessment evidence:**
  - The documentation of certificate issuance circumstances;
  - the documentation of the certificate profile;
  - the way issuances were requested, and the responses and issued certificates from the product.
- REFERENCE: ACC-PKI-EMM-03
  - **Assessment objective:** Verify the product enables the authorised user to specify the set of acceptable values for the following fields and extensions:
    - the authority key identifier;
    - the algorithm identifier for the subject's public/private key pair;
    - the identifier of the certificate issuer;
    - the length of time for which the certificate is valid.
  - **Assessment preparation:**
    - Authorised user access, to enable configuration.
    - Ability to request a certificate issuance for the different identified circumstances.
  - **Assessment activities:**
    - Configure a set of acceptable values for each of the identified fields and extensions, which does not contain all possible values.
    - For each way the product may issue a certificate:
      - For each of the identified fields and extensions:
        - attempt to issue a certificate, where all fields and extensions have acceptable values except the one being verified;
        - verify the issuance to fail or to be impossible.
  - **Assessment verdict:**
    - SUCCESS: The authorised users can configure restricted sets of acceptable values for all specified certificate fields and extensions, and any certificate request containing a non-acceptable value is rejected or cannot be issued.
    - FAIL: The product does not allow restricting acceptable values for one or more specified fields or extensions, or a certificate can be issued using a value outside the configured acceptable set.
  - **Assessment evidence:**
    - The documentation of public-key certificate issuance circumstances;
    - The applied configuration of the identified fields and extensions;
    - the way issuances were requested, and the responses and issued certificates from the product.
- REFERENCE: ACC-PKI-EMM-04
  - **Assessment objective:** Verify that the product enables the authorised user to specify the set of acceptable values for the fields and extensions: keyUsage, basicConstraints, CertificatePolicies.



- **Assessment preparation:**
  - Certificate generation service documentation.
  - Authorised user access to certificate generation service and related configuration.
- **Assessment activities:** For each way the product may issue a public-key certificate:
  - verify that no certificate may be issued until acceptable values for the identified fields and extensions are set, i.e.:
    - keyUsage;
    - basicConstraints; CertificatePolicies.
- **Assessment verdict:**
  - SUCCESS: The product prevents the issuance of any public-key certificate until the authorised user has configured acceptable values for all necessary fields and extensions.
  - FAIL: A public-key certificate can be issued before acceptable values for one or more required fields or extensions have been configured by the authorised user.
- **Assessment evidence:**
  - the documentation of public-key certificate issuance circumstances;
  - the way issuances were requested, and the responses from the product.
- REFERENCE: ACC-PKI-EMM-05
  - **Assessment objective:**
    - Verify the product marks the keyUsage, basicConstraints and certificatePolicies as critical in issued certificates.
  - **Assessment preparation:** Document the circumstances in which the certificate generation service may issue a public-key certificate. Ability to request a certificate issuance for the different identified circumstances.
  - **Assessment activities:** For each way the product may issue a public-key certificate:
    - issue a certificate;
    - verify the keyUsage, basicConstraints and certificatePolicies extensions to be marked critical;
    - if applicable, attempt to issue a certificate with either extension marked not critical, and verify the issuance to fail.
  - **Assessment verdict:**
    - SUCCESS: All issued public-key certificates mark the keyUsage, basicConstraints, and certificatePolicies extensions as critical, and any attempt to issue a certificate with these extensions marked non-critical is rejected.
    - FAIL: Any issued public-key certificate does not mark one or more of the required extensions as critical, or a certificate can be issued with one of these extensions marked non-critical.
  - **Assessment evidence:**
    - the documentation of public-key certificate issuance circumstances;
    - the way issuances were requested, and the responses and issued certificates from the product.

- REFERENCE: ACC-PKI-EMM-06
  - **Assessment objective:**
    - Verify the product disallows the keyUsage extension to offer both digital signature and encryption or key agreement capabilities.
  - **Assessment preparation:** Document the circumstances in which the certificate generation service may issue a public-key certificate. Ability to request a certificate issuance for the different identified circumstances.
  - **Assessment activities:** For each way the product may issue a public-key certificate:
    - issue a certificate;
    - verify the keyUsage extension does not contain values from simultaneously:
      - digitalSignature, contentCommitment, keyCertSign, cRLSign; and
      - keyEncipherment, dataEncipherment, keyAgreement.
    - if applicable, attempt to issue such a certificate and verify the issuance to fail.
  - **Assessment verdict:**
    - SUCCESS: No issued public-key certificate contains both signature capabilities (digitalSignature, contentCommitment, keyCertSign, cRLSign) and encryption or key agreement capabilities (keyEncipherment, dataEncipherment, keyAgreement) in the keyUsage extension, and any attempt to issue such a certificate is rejected.
    - FAIL: A public-key certificate is issued containing both signature and encryption or key agreement capabilities in the keyUsage extension, or an attempt to issue such a certificate is not rejected.
  - **Assessment evidence:**
    - the documentation of public-key certificate issuance circumstances;
    - the way issuances were requested, and the responses and issued certificates from the product.
- REFERENCE: ACC-PKI-EMM-07
  - **Assessment objective:**
    - Verify the product ensures a prospective certificate subject possesses the private key that corresponds to the public key in the certificate request before issuing a certificate, unless the private key never left the certificate issuance service.
  - **Assessment preparation:**
    - Document the circumstances in which the certificate generation service may issue a public-key certificate.
    - Ability to request a certificate issuance.
  - **Assessment activities:** For each way the product may issue a public-key certificate:
    - Attempt to issue a certificate with digital signature capabilities for a given public-key;
      - if the product does not generate the key pair itself, or it has left the issuance service:
        - provide an invalid signature when required;
          - verify the issuance to fail;
        - provide a valid signature when required;
          - verify the issuance to succeed.

- Attempt to issue a certificate with encryption or key agreement capabilities for a given public-key;
  - if the product does not generate the key pair itself, or it has left the issuance service:
    - provide an invalid decryption when required;
      - verify the issuance to fail.
    - provide an valid decryption when required;
      - verify the issuance to succeed.
- Among all the issuance attempts involving signing or decryption, verify the random value to sign or decrypt is always distinct, and their concatenation of high entropy.
- **Assessment verdict:**
  - SUCCESS: The product verifies proof of possession of the private key before issuing a certificate whenever the private key is external to the issuance service, rejects invalid signing or decryption proofs, and uses distinct, high-entropy challenge values.
  - FAIL: A certificate can be issued without valid proof of possession of the corresponding private key, invalid proofs are accepted, or the challenge values used for proof of possession are not distinct or sufficiently random.
- **Assessment evidence:**
  - The documentation of public-key certificate issuance circumstances;
  - The way issuances were requested, and the responses from the product;
  - The key pairs issued by the product if any, and how and when they were obtained;
  - The random values generated by the product.

## 6.12.2 EMM - Certificate status

- REFERENCE: ACC-PKI-EMM-08
- **Assessment objective:** Verify the certificate revocation statuses to be either or both of CRLs as defined by and subject to the requirements of Recommendation ITU-T X.509 [2], or OCSP responses as defined by and subject to the requirements of IETF RFC 6960 [4].
- **Assessment preparation:** Document the circumstances in which the certificate generation service may issue a public-key certificate. Ability to request a certificate issuance. Ability to configure revocation aspects of the certificate profile if supported.
- **Assessment activities:**
  - Attempt to configure the certificate profile to not offer any revocation source in issued certificates;
    - if successful, request a certificate for each way the product may issue a public-key certificate, and verify the issuances to fail.
  - For each way the product may successfully issue a public-key certificate:
    - request a certificate;
    - verify the issued certificate to contain information allowing a verifier to obtain a CRL or OCSP response.
- **Assessment verdict:**
  - SUCCESS: The product does not issue certificates without a configured revocation mechanism and all issued public-key certificates contain information enabling retrieval of a CRL and/or an OCSP response.

- **FAIL:** The product issues certificates without a revocation source, or any issued public-key certificate lacks information enabling retrieval of a CRL or OCSP response.
- **Assessment evidence:**
  - The configuration attempts, or other evidence such configuration is not supported;
  - the way issuances were requested, and the responses from the product.
- **REFERENCE: ACC-PKI-EMM-09**
  - **Assessment objective:**
    - Verify the product implements and enforces a CRL profile for issued CRLs.
  - **Assessment preparation:**
    - Ability to request a CRL as certificate status for a given certificate.
    - Documentation of the CRL profile implemented by the product.
  - **Assessment activities:**
    - Request a CRL;
    - verify the CRL to match the constraints of the CRL profile.
  - **Assessment verdict:**
    - **SUCCESS:** All issued CRLs conform to the documented CRL profile, including all required fields, formats, and constraints, and are successfully validated against the profile. **FAIL:** Any issued CRL does not conform to the CRL profile, is missing required elements, or violates any defined constraint in the CRL profile.
  - **Assessment evidence:** The way the CRL was requested, and the response and CRL from the product.
- **REFERENCE: ACC-PKI-EMM-10**
  - **Assessment objective:** Verify that the product enables authorised users to specify the set of acceptable values for the fields and extensions: issuer, issuerAltName, nextUpdate.
  - **Assessment preparation:** authorised users access to not-installed or reinitialised product, or specifically its certificate status service and related configuration.
  - **Assessment activities:**
    - Verify that authorised users can modify the issuer, issuerAltName, nextUpdate.
    - Verify that no CRL may be issued until acceptable values for the issuer, issuerAltName and nextUpdate fields and extensions are set.
  - **Assessment verdict:**
    - **SUCCESS:** Authorised users can configure the acceptable values for issuer, issuerAltName, and nextUpdate, and no CRL can be issued until all required values are properly set.
    - **FAIL:** The product does not allow configuration of acceptable values for the required fields, or it issues CRLs before these values are fully defined.
  - **Assessment evidence:** The way CRLs were requested, and the responses from the product.
- **REFERENCE: ACC-PKI-EMM-11**
  - **Assessment objective:** Verify the product implements and enforces an OCSP response profile for issued OCSP responses.
  - **Assessment preparation:** Ability to request an OCSP response as certificate status for a given certificate. Document the OCSP response profile implemented by the product.

- **Assessment activities:**
    - Request an OCSP response;
    - verify the OCSP response to match the constraints of the OCSP response profile.
  - **Assessment verdict:**
    - SUCCESS: All issued OCSP responses conform to the defined OCSP response profile, including all required constraints and structure validation.
    - FAIL: Any OCSP response is issued that does not conform to the OCSP response profile or violates its defined constraints.
  - **Assessment evidence:** The way the OCSP response was requested, and the response and OCSP response from the product.
- REFERENCE: ACC-PKI-EMM-12
    - **Assessment objective:** Verify that the product enables the authorised users to specify the set of acceptable values for the responseType field.
    - **Assessment preparation:** Authorised users access to not-installed or reinitialised product, or specifically its certificate status service and related configuration.
    - **Assessment activities:** Verify that no OCSP response may be issued until acceptable values for the responseType field are set.
    - **Assessment verdict:**
      - SUCCESS: OCSP responses cannot be issued until acceptable values for the responseType field are configured.
      - FAIL: The product allows issuance of OCSP responses without configured acceptable values for responseType.
    - **Assessment evidence:** The way OCSP responses were requested, and the responses and OCSP responses from the product.
  - REFERENCE: ACC-PKI-EMM-13
    - **Assessment objective:** Verify that the product enables the authorised users to specify the set of acceptable values for the responderID field.
    - **Assessment preparation:** Authorised users access to not-installed or reinitialised product, or specifically its certificate status service and related configuration.
    - **Assessment activities:** Verify that no OCSP response may be issued until acceptable values for the responderID field are set.
    - **Assessment verdict:**
      - SUCCESS: OCSP responses cannot be issued until acceptable values for the responderID field are configured.
      - FAIL: The product allows issuance of OCSP responses without configured acceptable values for responderID.
    - **Assessment evidence:** The way OCSP responses were requested, and the responses and OCSP responses from the product.

### 6.12.3 EMM - Certificate re-key

- REFERENCE: ACC-PKI-EMM-14
  - **Assessment objective:**
    - Verify that during certificate re-key operations, any modified certified names or attributes are validated and that updated registration information is properly recorded.
  - **Assessment preparation:**
    - Certificate generation service supporting certificate re-key is available.
    - Ability to request certificate re-key operations.
    - Administrator or authorised user access to registration information and configuration.
  - **Assessment activities:**
    - Perform certificate re-key requests with modified certified names and/or attributes.
    - Verify that all modified values are validated before issuance.
    - Verify that updated registration information is recorded and associated with the re-keyed certificate.
  - **Assessment verdict:**
    - SUCCESS: All modified certified names and attributes are validated prior to issuance, and updated registration information is correctly recorded for all certificate re-key operations.
    - FAIL: Any re-keyed certificate is issued without validating modified certified names or attributes, or updated registration information is not recorded.
  - **Assessment evidence:**
    - Re-key request inputs and configuration.
    - Issued re-keyed certificates.
    - Validation logs or system responses.
    - Registration database or records showing updated information.

### 6.12.4 EMM - Certificate modification

- REFERENCE: ACC-PKI-EMM-15
  - **Assessment objective:**
    - Verify that during certificate modification operations, any modified certified names or attributes are validated and updated registration information is recorded.
  - **Assessment preparation:**
    - Certificate generation service supporting certificate modification is available.
    - Ability to request certificate modification operations.
    - Authorised user access to registration information and audit/configuration data.
  - **Assessment activities:**
    - Perform certificate modification requests with changes to certified names and/or attributes.
    - Verify that all modified values are validated before issuance.

- Verify that updated registration information is recorded and correctly linked to the modified certificate.
- **Assessment verdict:**
  - SUCCESS: All modified certified names and attributes are validated before issuance, and updated registration information is correctly recorded for all certificate modification operations.
  - FAIL: Any modified certificate is issued without validation of updated certified names or attributes, or updated registration information is not recorded.
- **Assessment evidence:**
  - Certificate modification request inputs.
  - Issued modified certificates.
  - Validation results and system logs.
  - Registration records reflecting updated certificate information.

## 6.13 Logging and monitoring

- REFERENCE: ACC-PKI-MON-01
  - **Assessment objective:**
    - Verify that the product records audit events for:
      - All product functions associated with the use cases defined in Annex U.
      - All privileged user login attempts, including both successful and failed attempts.
      - All product update activities.
  - **Assessment preparation:**
    - List of PKI functions associated to the use cases as defined in Annex U.
    - List of privileged user roles supported by the product (e.g. PKI Administrator, Registration Authority Operator, Auditor, System Administrator).
    - Product in executable state and sufficient testing environment to activate desired functions.
    - Ensure the audit log storage is empty or note the current audit log state before testing.
    - Prepare test accounts for privileged users.
  - **Assessment activities:**
    - Enable and verify audit logging functionality.
    - Execute each function identified in Annex U for the chosen use case.
    - For each executed function:
      - Perform at least one successful operation.
      - Where applicable, perform an unsuccessful or rejected operation.
      - Verify that an audit event is generated.
    - Using privileged user accounts:
      - Attempt successful logins.

- Attempt failed logins using invalid credentials.
  - Attempt logins for disabled or locked accounts, if supported.
  - Verify that each login attempt generates an audit event.
- Perform one or more product update operations when they exist, such as:
  - Software update installation.
  - Configuration package update.
  - Security patch application.
  - Version upgrade.
  - Verify that each update activity generates an audit event.
- **Assessment verdict:**
  - **SUCCESS:**
    - Audit records are generated for all functions.
    - Audit records are generated for all successful and failed privileged user login attempts.
    - Audit records are generated for all product update activities.
    - No required events are missing from the audit logs.
  - **FAIL:**
    - One or more functions do not generate audit records.
    - Privileged user login attempts are not consistently recorded.
    - Product update activities are not recorded.
    - Audit records lack sufficient information for accountability or traceability.
    - Audit logging can be bypassed, disabled without authorisation, or fails to capture required events.
- **Assessment evidence:**
  - Audit log extracts.
  - Screenshots or exported reports of the audit logging interface.
  - Test execution records mapping each test activity to its corresponding audit event.
  - List of executed test cases and their corresponding timestamps and log entries.
- **REFERENCE: ACC-PKI-MON-02**
  - **Assessment objective:**
    - Verify that the product records within each audit record the required information, and that these records do not include any secret key or other secret parameter in plaintext form.
  - **Assessment preparation:**
    - Ability to trigger auditable events, and ability to audit events.
  - **Assessment activities:** Trigger an auditable event. Access the corresponding audit record.
    - Verify the audit record contains at least:



- the date and time of the event;
- the type of the event;
- the subject identity (if applicable);
- the outcome of the event.
- Perform the above for each audit event type, and verify that the audit record additionally contains the additional information specified by the developer.
- For each information verified to be present, verify it matches the expected value given when and how the event was triggered.
- For each of the generated audit record, verify that no private or symmetric key, as well as no other secret parameter is present in plaintext form.
- **Assessment verdict:**
  - SUCCESS: All audit records include required metadata (timestamp, event type, subject identity where applicable, outcome) and contain no secret or sensitive key material in plaintext.
  - FAIL: Audit records are missing required fields, contain incorrect values, or expose secret/sensitive key material in plaintext.
- **Assessment evidence:** The way the events were triggered and at what time, and the corresponding audit records.
- REFERENCE: ACC-PKI-MON-03
  - **Assessment objective:**
    - Verify that the product employs reliable time stamps.
  - **Assessment preparation:**
    - Ability to trigger auditable events, and ability to audit events.
    - Access to a trusted time stamp origin. Determine how the product determines its time stamps.
  - **Assessment activities:** Trigger an auditable event. Access the corresponding audit record. Verify the date and time of the event to match the trusted time stamp origin.
    - Repeat the above several times from different accesses to the product in parallel and verify the produced time stamps from the product to be monotonic.
    - If the product may determine its time stamps by querying time information from a source it trusts, verify that it authenticates that source messages using state of the art mechanisms.
    - If the product may increment temporary or long-term time information stored locally, verify that the time information may not be used in data issued by the product until it has properly been incremented, or alternatively that the service responsible for it cannot fail.
  - **Assessment verdict:**
    - SUCCESS: Audit timestamps are reliable, monotonic where applicable, and securely derived from trusted and authenticated time sources or correctly maintained local time mechanisms.
    - FAIL: Audit timestamps are unreliable, non-monotonic, unauthenticated, or otherwise inconsistent with trusted time sources.
  - **Assessment evidence:**
    - The way the events were triggered and at what time, and the corresponding audit records;
    - arguments relating to the authentication of a trusted source (if applicable);

- arguments relating to the monotonicity of local time information (if applicable).
- REFERENCE: ACC-PKI-MON-04
  - **Assessment objective:**
    - Verify that the product records within each audit record resulting from actions of identified users the corresponding user information.
  - **Assessment preparation:**
    - Ability to identify to the product as a given user.
    - Ability to trigger auditable events as a user, and ability to audit events.
  - **Assessment activities:** Identify to the product as the given user. Trigger an auditable event as the given user. Access the corresponding audit record.
    - Verify the audit record contains the identity of the user that caused the event.
    - Verify this identity to match that of the given user.
  - **Assessment verdict:**
    - SUCCESS: Audit records cannot be deleted by unauthorised users, and all protected audit logs remain intact after attempted deletion actions.
    - FAIL: Unauthorised users can delete or alter audit records, or audit data is not preserved after deletion attempts.
  - **Assessment evidence:**
    - The identity of the given user used for the test;
    - the way the event was triggered and at what time, and the corresponding audit record.
- REFERENCE: ACC-PKI-MON-05
  - **Assessment objective:**
    - Verify the product's prevention of auditable events, except those taken by the auditor, if the audit log is full.
  - **Assessment preparation:**
    - Ability to trigger auditable events, and ability to audit events. The maximum size of the audit log may be reduced.
  - **Assessment activities:** Do not identify as an auditor to the product. Trigger auditable events until the audit log is full, or nearly so.
    - Verify that a given additional auditable event cannot be performed.
    - Identify as an auditor to the product.
    - Verify that a given additional auditable event may be triggered as the auditor.
  - **Assessment verdict:**
    - SUCCESS: When the audit log is full, non-auditor actions are blocked while auditor actions remain permitted and correctly recorded.
    - FAIL: The system continues to allow non-auditor actions when the log is full, or improperly blocks auditor actions.
  - **Assessment evidence:**
    - The configured maximum size of the audit log;

- the size of the audit when full, or nearly so;
- the way the additional event was attempted to be triggered, and the corresponding response from the product.

## 6.14 Data removal and transparency

- REFERENCE: ACC-PKI-DRT-01
  - **Assessment objective:**
    - Verify that all public keys stored by the product outside of a secure cryptographic device are protected against undetected modification.
    - Verify that the product detects unauthorised modification of stored public keys before they are released or used.
    - Verify that, upon detection of a modification, the product does not release the public key to the requesting entity and does not use the modified public key for any cryptographic operation.
  - **Assessment preparation:**
    - Identify all locations where public keys are stored outside secure cryptographic devices (e.g. databases, filesystems, configuration repositories, directories, caches, backups).
    - Identify the mechanisms used to protect public key integrity (e.g. digital signatures, hashes, message authentication codes, integrity checks).
    - Valid test public keys and associated integrity protection information.
    - Tools and permissions necessary to modify stored public key data and integrity protection data.
  - **Assessment activities:**
    - Store one or more valid public keys in each identified and accessible storage location.
    - Access and use the stored public keys and verify that:
      - Integrity verification is performed prior to release or use.
      - Valid public keys are successfully released and used.
    - Modify a stored public key without updating its integrity protection information.
    - Attempt to access or use the modified public key and verify that:
      - The integrity verification mechanism detects the modification.
      - The modified public key is not returned to the requesting entity.
      - The modified public key is not used in any cryptographic operation.
    - Attempt to perform cryptographic operations that depend on the modified public key and verify that such operations fail safely.
    - Review system logs and verify that integrity verification failures are appropriately recorded, where logging is implemented.
  - **Assessment verdict:**
    - SUCCESS:
      - All public keys stored outside secure cryptographic devices are protected by an integrity verification mechanism.
      - Unauthorised modifications of stored public keys are reliably detected.

- Modified public keys are neither released nor used by the product.
  - Cryptographic operations depending on modified public keys fail safely and predictably.
- **FAIL:**
  - A stored public key can be modified without detection.
  - A modified public key is released to a none-authorised user.
  - A modified public key is used by the product.
  - Integrity verification mechanisms can be bypassed or are not consistently applied.
  - Cryptographic operations continue using modified public keys.
- **Assessment evidence:**
  - Public key storage locations.
  - Documentation of integrity protection mechanisms.
  - Test records showing successful verification of valid public keys.
  - Test records demonstrating detection of unauthorised modifications.
  - Screenshots or log extracts showing integrity verification failures.
- Evidence that modified public keys were neither released nor used.
- **REFERENCE: ACC-PKI-DRT-02**
  - **Assessment objective:**
    - Verify that all secrets temporarily manipulated by the product in plaintext form are zeroized after use.
    - Verify that plaintext secrets are not retained in memory, temporary files, caches, or other storage locations beyond their required period of use.
    - Verify that secret zeroization occurs consistently during normal operation and error conditions.
  - **Assessment preparation:**
    - Identify all secrets that may be temporarily manipulated in plaintext form, including:
      - Private keys.
      - Authentication credentials.
      - Passphrases and passwords.
      - Key-encryption keys.
      - Session keys and other cryptographic secrets.
    - Identify all components and processes that temporarily process these secrets.
    - Documentation describing secret handling and zeroization mechanisms.
    - Tools capable of examining process memory, temporary files, and storage artifacts.
  - **Assessment activities:**
    - Execute all functions that temporarily manipulate secrets in plaintext form.
    - During and after each operation, inspect:

- Process memory.
- Temporary files.
- Cache locations.
- Swap or paging areas, where applicable.
- Inter-process communication buffers, where applicable.
- Verify that plaintext secrets are present only for the duration necessary to perform the operation.
- Verify that plaintext secrets are overwritten or cleared immediately after use.
- Induce abnormal conditions, including:
  - Operation failures.
  - Interrupted processing.
  - Unexpected exceptions.
  - Service restarts.
- Verify that plaintext secrets are also zeroized following abnormal termination conditions.
- Repeat the assessment for all identified components that temporarily manipulate secrets.
- **Assessment verdict:**
  - **SUCCESS:**
    - All identified plaintext secrets are zeroized after use.
    - Plaintext secrets are not retained in memory or temporary storage beyond their operational need.
    - Zeroization occurs during both normal and abnormal execution paths.
    - No recoverable plaintext secret material remains after completion of processing.
  - **FAIL:**
    - One or more plaintext secrets remain accessible after use.
    - Plaintext secrets persist in memory, temporary files, caches, or buffers beyond their required lifetime.
    - Zeroization is not performed during abnormal termination conditions.
    - Recoverable plaintext secret material can be obtained after the completion of processing.
  - **Assessment evidence:**
    - Inventory of secrets manipulated in plaintext form.
    - Design documentation describing secret handling and zeroization mechanisms.
    - Memory analysis reports demonstrating the removal of plaintext secrets.
    - Inspection results for temporary files, caches, and storage artifacts.
    - Test records for normal and abnormal execution scenarios.
    - Screenshots, logs, or forensic reports demonstrating successful zeroization.

## Annex A (informative): Relationship between the present document and the requirements of EU Regulation (EU) 2024/2847 – the Cyber Resilience Act

The present document has been prepared under the Commission's standardisation request C(2025) 618 [i.3] final to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and  
the requirements of Regulation (EU) 2024/2847 - the Cyber Resilience Act**

| Description             | Essential Requirements of Regulation (EU) 2024/2847                                                                                                                                                                                                                                                                                                                                                                | Clause(s) of the present document | Remarks / Notes                                                                              |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|----------------------------------------------------------------------------------------------|
| Annex I, Part I, (1)    | "Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."                                                                                                                                                                                                                                                | Clause 5 and 6                    | See applicability field associated to each technical cybersecurity requirements in clause 5. |
| Annex I, Part I, (2)(a) | "Products with digital elements shall be made available on the market without known exploitable vulnerabilities."                                                                                                                                                                                                                                                                                                  | Clause 5.2 and 6.2                |                                                                                              |
| Annex I, Part I, (2)(b) | "Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."                                                                                                    | Clause 5.3 and 6.3                |                                                                                              |
| Annex I, Part I, (2)(c) | "Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available updates to users, and the option to temporarily postpone them" | Clause 5.4 and 6.4                |                                                                                              |

| Description             | Essential Requirements of Regulation (EU) 2024/2847                                                                                                                                                                                                                      | Clause(s) of the present document | Remarks / Notes |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|-----------------|
| Annex I, Part I, (2)(d) | "Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access"                      | Clause 5.5 and 6.5                |                 |
| Annex I, Part I, (2)(e) | "Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."     | Clause 5.6 and 6.6                |                 |
| Annex I, Part I, (2)(f) | "Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions." | Clause 5.7 and 6.7                |                 |
| Annex I, Part I, (2)(g) | "Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."                                  | Clause 5.8 and 6.8                |                 |
| Annex I, Part I, (2)(h) | "Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."                                                        | Clause 5.9 and 6.9                |                 |
| Annex I, Part I, (2)(i) | "Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."                                                                             | Clause 5.10 and 6.10              |                 |
| Annex I, Part I, (2)(j) | "Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."                                                                                                                                      | Clause 5.11 and 6.11              |                 |
| Annex I, Part I, (2)(k) | "Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."                                                                                      | Clause 5.12 and 6.12              |                 |

| Description             | Essential Requirements of Regulation (EU) 2024/2847                                                                                                                                                                                                                  | Clause(s) of the present document | Remarks / Notes |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|-----------------|
| Annex I, Part I, (2)(l) | "Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."                  | Clause 5.13 and 6.13              |                 |
| Annex I, Part I, (2)(m) | "Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner." | Clause 5.14 and 6.14              |                 |

**Key to columns:**

**Description**      A textual reference to the requirement.

**Requirements of Regulation**

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

**Clause(s) of the present document**

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.



## Annex B (informative): Security analysis

This Annex applies a "state of the art" risk assessment methodology to the Product in scope of the present document, to identify threats, evaluate the risks and define security profiles applicable to the different use cases of the product context.

### B.1 Risk calculation

Risk is calculated as the product of impact and likelihood.

In assessing impact reasonable consideration has to be made for the use case in which the product is deployed which should include assessment of the following factors and as these are dependent on the specific use case the mitigations primarily consider limiting the likelihood of an attack:

- Deployment factors
- Network security factors
- User Expertise
- Operational security procedures
- Interfaces exposure

**Table B.1-1: Impact metric for use in risk calculation**

| Impact | Explanation                                                                                                                                                                                             | Value |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|
| Low    | The concerned party is not harmed very strongly; the possible damage is low. For the product this is modified to mean "negligible impact to the organisation"                                           | 1     |
| Medium | The threat addresses the interests of providers/subscribers and cannot be neglected. For the product this is modified to mean "significant impact to the organisation, negligible impact to the sector" | 2     |
| High   | A basis of business is threatened and severe damage might occur in this context. For the product this is modified to mean "Severe impact to the organisation, significant impact to the sector"         | 3     |

**Table B.1-2: Likelihood metric**

| Value                                                                                                                                                                                                                                                         | Likelihood of occurrence | Modified likelihood | Explanation                                                                                                                                                                                                 |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 (see note)                                                                                                                                                                                                                                                  | Very unlikely to         | Low                 | According to up-to-date knowledge, there are no means of solving the technical difficulties to state the threat irrespective of the motivation or resources available to the attacker.                      |
| 1                                                                                                                                                                                                                                                             | Unlikely to succeed      | Low                 | According to up-to-date knowledge, a possible attacker needs to solve strong technical difficulties to state the threat or the motivation for an attacker is very low.                                      |
| 2                                                                                                                                                                                                                                                             | Possible (could succeed) | Medium              | The technical requirements necessary to state this threat are not high and could be solved without significant effort; furthermore, there is a reasonable motivation for an attacker to perform the threat. |
| 3                                                                                                                                                                                                                                                             | Likely to succeed        | High                | There are no sufficient mechanisms installed to counteract this threat and the motivation for an attacker is quite high.                                                                                    |
| 3 (see note)                                                                                                                                                                                                                                                  | Very likely to succeed   | High                | As for very likely but the threat is considered more imminent.                                                                                                                                              |
| NOTE: The values assigned to "Very unlikely" and "Unlikely" are identical, similarly the values assigned to "Likely" and "Very likely" are identical. The rationale is that they represent extreme poles but, in each case, do not equate to risk escalation. |                          |                     |                                                                                                                                                                                                             |

## B.2 Risk Assessment

### B.2.1 Likelihood risk factors

#### B.2.1.1 Deployment

The criticality of the environment in which a product is deployed influences its attractiveness as a target and, consequently, the likelihood of attacks. However, this effect is partially reduced by the fact that highly critical entities employ more robust security management and deployment practices.

**Table B.2.1.1-1: Risk factor DEP**

| Risk factor | Description                                      | Value  | UC Parameter                  |
|-------------|--------------------------------------------------|--------|-------------------------------|
| DEP-2       | Consumer use or non-critical use in enterprises. | Low    | UC not identified as critical |
| DEP-1       | Product use in critical environment.             | Medium | UC identified as critical     |

### B.2.1.2 Network and Physical security

**Table B.2.1.2-1: Risk factor NET**

| Risk factor | Description                                                       | Value  | UC Parameter            |
|-------------|-------------------------------------------------------------------|--------|-------------------------|
| NET-2       | Enhanced network and physical security with continuous monitoring | Low    | POE.FullyControlled     |
| NET-1       | Standard enterprise network and physical security                 | Medium | POE.PartiallyControlled |
| NET-0       | Limited network or physical security                              | High   | Not identified          |

### B.2.1.3 User expertise

**Table B.2.1.3-1: Risk factor USR**

| Risk factor | Description                                                    | Value  | UC Parameter               |
|-------------|----------------------------------------------------------------|--------|----------------------------|
| USR-2       | Skilled users with relevant experience and regular training.   | High   | UE.SkilledUsers            |
| USR-1       | Standard enterprise users with one-off or infrequent training. | Medium | UE.StandardUserCompetences |
| USR-0       | Unskilled users                                                | High   | UE.UnskilledUsers          |

### B.2.1.4 Interface exposure

**Table B.2.1.4-1: Risk factor COM**

| Risk factor | Description                                          | Value  | UC parameter                    |
|-------------|------------------------------------------------------|--------|---------------------------------|
| COM-2       | Local interfaces only                                | Low    | COM.Local or COM.UserInterface  |
| COM-1       | Remote interfaces accessible from enterprise network | Medium | COM.Adjacent or ARC.PublicCloud |
| COM-0       | Remote interfaces accessible from public network     | High   | COM.Public                      |

## B.2.2 Impact risk factors

The following figures present the impact factors evaluation for the 4 use cases used to calculate risks. They are categorised as follows:

- Availability
- Integrity
- Confidentiality
- and Traceability

## B.3 Evaluate Risks

This clause presents the evaluation of the risk factors for each of the use cases. The following tables evaluate the risks for each use case related to threats defined in clause 4. For each threat the list of associated risk factors values are assessed and for each combination of factors a maximum function is applied (the resulting impact or likelihood level is the maximum of all risk factors levels).

The risk are then calculated and their applicability defined using the matrixes presented below.

| Availability |                                                                                                                                  | Assets classification by use cases                                                                                                                                                              |                                                                                                                                                                                                                                                                       |                                                                                                                                                                             |                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                       |
|--------------|----------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk Factor  | Description                                                                                                                      | UC1 – Private PKI                                                                                                                                                                               | UC2 – Critical Private PKI                                                                                                                                                                                                                                            | UC3 – Critical Public PKI                                                                                                                                                   | UC4 – Critical Public basic PKI                                                                                                                                                                                                     | UC5 - Critical Multi-authority PKI                                                                                                                                                                                                                                    |
| AVA-2        | The unavailability of the asset is not critical and does not meaningfully disrupt the PKI service and associated provided trust. | REG01. Subscriber data<br>REG02. Certificate request<br>STA01. Certificate status data<br>SYS02. User account data<br>DIS01. Certificate store data<br>SYS03. Event log data<br>SOF01. Software |                                                                                                                                                                                                                                                                       |                                                                                                                                                                             |                                                                                                                                                                                                                                     |                                                                                                                                                                                                                                                                       |
| AVA-1        | The unavailability of the asset is important and implies partial disruption of the PKI service and associated provided trust.    | KEY01. Public Keys<br>KEY02. Secret Keys<br>REV01. Revocation request<br>SYS01. System configuration data                                                                                       | DIS01. Certificate store data<br>KEY01. Public Keys<br>REG01. Subscriber data<br>REG02. Certificate request<br>STA01. Certificate status data<br>SYS01. System configuration data<br>SYS02. User account data<br>SYS03. Event log data<br>SYS04. Authorised user data | DIS01. Certificate store data<br>KEY01. Public Keys<br>SYS01. System configuration data<br>SYS02. User account data<br>SYS03. Event log data<br>SYS04. Authorised user data | DIS01. Certificate store data<br>KEY01. Public Keys<br>REG01. Subscriber data<br>REG02. Certificate request<br>SYS01. System configuration data<br>SYS02. User account data<br>SYS03. Event log data<br>SYS04. Authorised user data | DIS01. Certificate store data<br>KEY01. Public Keys<br>REG01. Subscriber data<br>REG02. Certificate request<br>SYS01. System configuration data<br>SYS02. User account data<br>SYS03. Event log data<br>SYS04. Authorised user data<br>STA01. Certificate status data |
| AVA-0        | The unavailability of the asset is critical and implies disruption of the trust elements provide by the PKI.                     |                                                                                                                                                                                                 | KEY02. Secret Keys<br>SOF01. Software                                                                                                                                                                                                                                 | KEY02. Secret Keys<br>SOF01. Software<br>STA01. Certificate status data                                                                                                     | KEY02. Secret Keys<br>SOF01. Software<br>STA01. Certificate status data                                                                                                                                                             | KEY02. Secret Keys<br>SOF01. Software<br>STA01. Certificate status data                                                                                                                                                                                               |

Figure B.3-1: Risk factor availability

| Confidentiality |                                                                                                                     | Assets classification by use cases                                                                                                                         |                                                                                                                                                                                          |                                                                                                                                                             |                                                                                                                                                             |                                                                                                                                    |
|-----------------|---------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Risk Factor     | Description                                                                                                         | UC1 – Private PKI                                                                                                                                          | UC2 – Critical Private PKI                                                                                                                                                               | UC3 – Critical Public PKI                                                                                                                                   | UC4 – Critical Public basic PKI                                                                                                                             | UC5 - Critical Multi-authority PKI                                                                                                 |
| CON-2           | The disclosure of the asset is not critical and does not compromise the trust provide by the PKI.                   | DIS01.Certificate store data<br>KEY01.Public Keys<br>SOF01.Software<br>STA01.Certificate status data<br>SYS03.Event log data<br>SYS04.Authorised user data | DIS01.Certificate store data<br>KEY01.Public Keys<br>STA01.Certificate status data                                                                                                       | DIS01.Certificate store data<br>KEY01.Public Keys<br>STA01.Certificate status data                                                                          | DIS01.Certificate store data<br>KEY01.Public Keys<br>STA01.Certificate status data                                                                          | DIS01.Certificate store data<br>KEY01.Public Keys<br>STA01.Certificate status data                                                 |
| CON-1           | The disclosure of the asset is partially critical and implies partial compromition of the trust provide by the PKI. | SYS01.System configuration data<br>SYS02.User account data<br>REG01.Subscriber data<br>REG02.Certificate request                                           | REG01.Subscriber data<br>REG02.Certificate request<br>SOF01.Software<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | REG01.Subscriber data<br>SOF01.Software<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | REG01.Subscriber data<br>SOF01.Software<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | SOF01.Software<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data |
| CON-0           | The disclosure of the asset is critical and does compromise entirely the trust provide by the PKI.                  | KEY02.Secret Keys                                                                                                                                          | KEY02.Secret Keys                                                                                                                                                                        | KEY02.Secret Keys                                                                                                                                           | KEY02.Secret Keys                                                                                                                                           | REG01.Subscriber data<br>REG02.Certificate request<br>KEY02.Secret Keys                                                            |

Figure B.3-2: Risk factor confidentiality

| Integrity   |                                                                                                                     | Assets classification by use cases                                                                                                                                                                   |                                                                                                                                                                                                        |                                                                                                                                           |                                                                                                                                                                           |                                                                                                                                                                                                        |
|-------------|---------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Risk Factor | Description                                                                                                         | UC1 – Private PKI                                                                                                                                                                                    | UC2 – Critical Private PKI                                                                                                                                                                             | UC3 – Critical Public PKI                                                                                                                 | UC4 – Critical Public basic PKI                                                                                                                                           | UC5 - Critical Multi-authority PKI                                                                                                                                                                     |
| INT-2       | The modification of the asset is not critical and does not compromise the trust provided by the PKI.                | STA01.Certificate status data<br>SYS03.Event log data                                                                                                                                                |                                                                                                                                                                                                        |                                                                                                                                           |                                                                                                                                                                           |                                                                                                                                                                                                        |
| INT-1       | The modification of the asset is partially critical and implies partial compromise of the trust provide by the PKI. | REG01.Subscriber data<br>REG02.Certificate request<br>DIS01: Certificate store data<br>KEY01.Public Keys<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS04.Authorised user data | DIS01.Certificate store data<br>REG01.Subscriber data<br>REG02.Certificate request<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | REG01.Subscriber data<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | DIS01.Certificate store data<br>REG01.Subscriber data<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data | DIS01.Certificate store data<br>REG01.Subscriber data<br>REG02.Certificate request<br>SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>SYS04.Authorised user data |
| INT-0       | The modification of the asset is critical and does compromise entirely the trust provide by the PKI.                | SOF01.Software<br>KEY02.Secret Keys                                                                                                                                                                  | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>STA01.Certificate status data                                                                                                              | DIS01.Certificate store data<br>KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>STA01.Certificate status data                 | DIS01.Certificate store data<br>KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>STA01.Certificate status data                                                 | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>STA01.Certificate status data                                                                                                              |

Figure B.3-3: Risk factor integrity

| Traceability |                                                                                                                                                    | Assets classification by use cases                                                                                                          |                                                                                                                                             |                                                                                                                     |                                                                                                                         |                                                                                                                     |
|--------------|----------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| Risk Factor  | Description                                                                                                                                        | UC1 – Private PKI                                                                                                                           | UC2 – Critical Private PKI                                                                                                                  | UC3 – Critical Public PKI                                                                                           | UC4 – Critical Public basic PKI                                                                                         | UC5 - Critical Multi-authority PKI                                                                                  |
| TRA-2        | The lack of Traceability of the events about the asset is not critical and does not compromise the trust provide by the PKI if forensic is needed. | DIS01.Certificate store data<br>REG01.Subscriber data<br>REG02.Certificate request<br>STA01.Certificate status data<br>SYS03.Event log data | DIS01.Certificate store data<br>REG01.Subscriber data<br>REG02.Certificate request<br>STA01.Certificate status data<br>SYS03.Event log data | DIS01.Certificate store data<br>REG01.Subscriber data                                                               | DIS01.Certificate store data<br>REG01.Subscriber data                                                                   | DIS01.Certificate store data<br>REG01.Subscriber data<br>REG02.Certificate request<br>STA01.Certificate status data |
| TRA-1        | The lack of Traceability of the events about the asset is severe and compromise the trust provide by the PKI if forensic is needed.                | KEY01.Public Keys<br>SOF01.Software configuration data<br>SYS01.System configuration data<br>SYS02.User account data<br>KEY02.Secret Keys   | SYS01.System configuration data<br>SYS02.User account data                                                                                  | SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data<br>STA01.Certificate status data | SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data                                      | SYS01.System configuration data<br>SYS02.User account data<br>SYS03.Event log data                                  |
| TRA-0        | The lack of Traceability of the events about the asset is not acceptable and compromise the trust provide by the PKI if forensic is needed.        |                                                                                                                                             | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>SYS04.Authorised user data                                                      | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>SYS04.Authorised user data                              | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>STA01.Certificate status data<br>SYS04.Authorised user data | KEY01.Public Keys<br>KEY02.Secret Keys<br>SOF01.Software<br>SYS04.Authorised user data                              |

Figure B.3-4: Risk factor traceability

The risk and their applicability to use cases defined in Annex U are presented in Figure B.3-5.

| Threat  |                                                                                                 |                                                                     |       | Impact risk factors     |              |             |             |             |             | Likelihood risk factors |                         |                         |                         |                         | Risk Evaluation      |                      |                      |                      |                      | UC / App.                               |
|---------|-------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|-------|-------------------------|--------------|-------------|-------------|-------------|-------------|-------------------------|-------------------------|-------------------------|-------------------------|-------------------------|----------------------|----------------------|----------------------|----------------------|----------------------|-----------------------------------------|
| ID      | Description                                                                                     | Attack vector                                                       | Asset | Impact Type             | Value UC1    | Value UC2   | Value UC3   | Value UC4   | Value UC5   | Value UC1               | Value UC2               | Value UC3               | Value UC4               | Value UC5               | Risk Value UC1 (SP1) | Risk Value UC2 (SP2) | Risk Value UC3 (SP3) | Risk Value UC4 (SP4) | Risk Value UC5 (SP5) |                                         |
| T_SYS01 | Local unauthorised user modifies system configuration data.                                     | COM.UserInterface<br>I.AuditAndAdministration                       | SYS01 | Availability, Integrity | AVA-2 INT-1  | AVA-2 INT-0 | AVA-2 INT-0 | AVA-2 INT-0 | AVA-2 INT-0 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-2 USR-2 COM-1 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | Medium               | High                 | High                 | High                 | High                 | All UC                                  |
| T_SYS02 | Network attacker modifies system configuration data.                                            | COM.Public or COM.Adjacent or COM.Local<br>I.AuditAndAdministration | SYS01 | Availability, Integrity | AVA-2 INT-1  | AVA-2 INT-0 | AVA-2 INT-0 | NA          | AVA-2 INT-0 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-2 USR-2 COM-1 | DEP-1 NET-2 USR-2 COM-0 | NA                      | DEP-1 NET-2 USR-2 COM-0 | Medium               | High                 | High                 | NA                   | High                 | UC1, UC2, UC5                           |
| T_SYS03 | Local unauthorised user discloses sensitive parameters in system configuration data.            | COM.UserInterface<br>I.AuditAndAdministration                       | SYS01 | Confidentiality         | CON-1        | CON-1       | CON-1       | CON-1       | CON-1       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-2 USR-2 COM-1 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | Medium               | Medium               | Medium               | Medium               | Medium               | All UC                                  |
| T_SYS04 | Network attacker discloses sensitive parameters in system configuration data.                   | COM.Public or COM.Adjacent or COM.Local<br>I.AuditAndAdministration | SYS01 | Confidentiality         | CON-1        | CON-1       | CON-1       | NA          | CON-1       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-2 USR-2 COM-1 | DEP-1 NET-2 USR-2 COM-0 | NA                      | DEP-1 NET-2 USR-2 COM-0 | Medium               | Medium               | High                 | NA                   | High                 | UC1, UC2, UC3, UC5                      |
| T_SYS05 | Local unauthorised user modifies access rights in user account data.                            | COM.UserInterface<br>I.AuditAndAdministration                       | SYS02 | Availability, Integrity | AVA-2 INT-1  | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | DEP-1 NET-2 USR-2 COM-2 | Medium               | Medium               | Medium               | Medium               | Medium               | All UC                                  |
| T_SYS06 | Network attacker modifies user authentication credentials or access rights in user account data | COM.Public or COM.Adjacent or COM.Local<br>I.AuditAndAdministration | SYS02 | Availability, Integrity | AVA-2 INT-2  | AVA-1 INT-1 | AVA-1 INT-1 | NA          | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-2 USR-1 COM-1 | DEP-1 NET-2 USR-2 COM-0 | NA                      | DEP-1 NET-2 USR-2 COM-0 | Medium               | Medium               | High                 | NA                   | High                 | UC1, UC2, UC3, UC5                      |
| T_SYS07 | Local unauthorised user discloses user authentication credentials in user account data          | COM.UserInterface<br>I.AuditAndAdministration                       | SYS02 | Confidentiality         | CON-1        | CON-1       | CON-1       | CON-1       | CON-1       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | Medium               | Medium               | Medium               | All UC                                  |
| T_SYS08 | Network attacker user discloses user authentication credentials in user account data            | COM.Public or COM.Adjacent or COM.Local<br>I.AuditAndAdministration | SYS02 | Confidentiality         | CON-1        | CON-1       | CON-1       | NA          | CON-1       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | High                 | NA                   | High                 | UC1, UC2, UC3, UC5                      |
| T_SYS09 | Local unauthorised user modifies or deletes events in event log data.                           | COM.UserInterface<br>I.AuditAndAdministration                       | SYS03 | Availability, Integrity | AVA-1 INT-1  | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Low                  | Medium               | Medium               | Medium               | Medium               | UC1 (specific req.), UC2, UC3, UC4, UC5 |
| T_SYS10 | Network attacker user modifies or deletes events in event log data.                             | COM.Public or COM.Adjacent or COM.Local<br>I.AuditAndAdministration | SYS03 | Availability, Integrity | AVA-2, INT-2 | AVA-1 INT-1 | AVA-1 INT-1 | NA          | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Low                  | Medium               | High                 | NA                   | High                 | UC2, UC3, UC5                           |
| T_SYS11 | Local unauthorised users discloses events in event log data.                                    | COM.UserInterface<br>I.AuditAndAdministration                       | SYS03 | Confidentiality         | CON-2        | CON-1       | CON-1       | CON-1       | CON-1       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Low                  | Medium               | Medium               | Medium               | Medium               | UC2, UC3, UC4, UC5                      |



| Threat  |                                                                                                             |                                                                              |       | Impact risk factors     |             |             |             |             |             | Likelihood risk factors |                         |                         |                         |                         | Risk Evaluation      |                      |                      |                      |                      | UC / App.          |
|---------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|-------|-------------------------|-------------|-------------|-------------|-------------|-------------|-------------------------|-------------------------|-------------------------|-------------------------|-------------------------|----------------------|----------------------|----------------------|----------------------|----------------------|--------------------|
| ID      | Description                                                                                                 | Attack vector                                                                | Asset | Impact Type             | Value UC1   | Value UC2   | Value UC3   | Value UC4   | Value UC5   | Value UC1               | Value UC2               | Value UC3               | Value UC4               | Value UC5               | Risk Value UC1 (SP1) | Risk Value UC2 (SP2) | Risk Value UC3 (SP3) | Risk Value UC4 (SP4) | Risk Value UC5 (SP5) |                    |
| T_SYS12 | Network attacker discloses events in event log data.                                                        | COM.Public or COM.Adjacent or COM.Local I.AuditAndAdministration             | SYS03 | Confidentiality         | CON-2       | CON-1       | CON-1       | NA          | CON-1       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Low                  | Medium               | High                 | NA                   | High                 | UC2, UC3, UC5      |
| T_REG01 | Local unauthorised user modifies or deletes subscriber data                                                 | COM.UserInterface I.CertificateGeneration                                    | REG01 | Integrity, Availability | AVA-2 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | Medium               | Medium               | Medium               | All UC             |
| T_REG02 | Network attacker modifies or deletes subscriber data                                                        | COM.Public or COM.Adjacent or COM.Local I.CertificateGeneration              | REG01 | Integrity, Availability | AVA-2 INT-1 | AVA-1 INT-1 | NA          | NA          | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | NA                   | NA                   | High                 | UC1, UC2, UC5      |
| T_REG03 | Local unauthorised user discloses subscriber data                                                           | COM.UserInterface I.CertificateGeneration                                    | REG01 | Confidentiality         | CON-1       | CON-1       | CON-1       | CON-1       | CON-1       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | Medium               | Medium               | Medium               | All UC             |
| T_REG04 | Network attacker discloses subscriber data                                                                  | COM.Public or COM.Adjacent or COM.Local I.CertificateGeneration              | REG01 | Confidentiality         | CON-1       | CON-1       | CON-1       | NA          | CON-1       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | High                 | NA                   | High                 | UC1, UC2, UC3, UC5 |
| T_REG05 | Local unauthorised user modifies or deletes certificate request data                                        | COM.UserInterface I.CertificateGeneration                                    | REG02 | Integrity, Availability | AVA-2 INT-1 | AVA-1 INT-1 | NA          | NA          | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | NA                   | NA                   | Medium               | UC1, UC2, UC5      |
| T_REG06 | Network attacker modifies or deletes certificate request data                                               | COM.Public or COM.Adjacent or COM.Local I.CertificateGeneration              | REG02 | Integrity, Availability | AVA-2 INT-1 | AVA-1 INT-1 | NA          | NA          | AVA-1 INT-1 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | NA                   | NA                   | High                 | UC1, UC2, UC5      |
| T_REG07 | Local unauthorised user discloses certificate requests                                                      | COM.UserInterface I.CertificateGeneration                                    | REG02 | Confidentiality         | CON-1       | CON-1       | NA          | NA          | CON-0       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | NA                   | NA                   | Medium               | UC1, UC2, UC5      |
| T_REG08 | Network attacker discloses certificate requests                                                             | COM.Public or COM.Adjacent or COM.Local I.CertificateGeneration              | REG02 | Confidentiality         | CON-1       | CON-1       | NA          | NA          | CON-0       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | NA                   | NA                   | High                 | UC1, UC2, UC5      |
| T_GEN01 | Local unauthorised user modifies or deletes public keys                                                     | COM.UserInterface I.CertificateGeneration Or I.ExternalCryptographic Service | KEY01 | Integrity, Availability | AVA-1 INT-1 | AVA-1 INT-0 | AVA-1 INT-0 | AVA-1 INT-0 | AVA-1 INT-0 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | High                 | High                 | High                 | All UC             |
| T_GEN02 | Network attacker modifies or deletes public keys                                                            | COM.Public or COM.Adjacent or COM.Local I.CertificateGeneration              | KEY01 | Integrity, Availability | AVA-1 INT-1 | NA          | NA          | NA          | NA          | DEP-2 NET-1 USR-1 COM-1 | NA                      | NA                      | NA                      | NA                      | Medium               | NA                   | NA                   | NA                   | NA                   | UC1                |
| T_GEN03 | Network attacker modifies or deletes public keys requests exchanged with the external cryptographic system. | COM.Local I.ExternalCryptographic Service                                    | KEY01 | Integrity, Availability | NA          | AVA-1 INT-0 | AVA-1 INT-0 | AVA-1 INT-0 | AVA-1 INT-0 | NA                      | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                   | High                 | High                 | High                 | High                 | UC2, UC3, UC4, UC5 |

| Threat  |                                                                                                              |                                                                                                       |       | Impact risk factors     |              |              |             |             |              | Likelihood risk factors |                         |                         |                         |                         | Risk Evaluation      |                      |                      |                      |                      | UC / App.          |
|---------|--------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|-------|-------------------------|--------------|--------------|-------------|-------------|--------------|-------------------------|-------------------------|-------------------------|-------------------------|-------------------------|----------------------|----------------------|----------------------|----------------------|----------------------|--------------------|
| ID      | Description                                                                                                  | Attack vector                                                                                         | Asset | Impact Type             | Value UC1    | Value UC2    | Value UC3   | Value UC4   | Value UC5    | Value UC1               | Value UC2               | Value UC3               | Value UC4               | Value UC5               | Risk Value UC1 (SP1) | Risk Value UC2 (SP2) | Risk Value UC3 (SP3) | Risk Value UC4 (SP4) | Risk Value UC5 (SP5) |                    |
| T_GEN04 | Local unauthorised user modifies or deletes private keys                                                     | COM.UserInterface<br>I.CertificateGeneration                                                          | KEY02 | Integrity, Availability | AVA-1 INT-0  | AVA-0 INT-0  | AVA-0 INT-0 | AVA-0 INT-0 | AVA-0 INT-0  | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | High                 | NA                   | NA                   | NA                   | NA                   | UC1                |
| T_GEN05 | Network attacker modifies or deletes private keys requests exchanged with the external cryptographic system. | COM.UserInterface<br>I.CertificateGeneration<br>I.ExternalCryptographic Service                       | KEY02 | Integrity, Availability | NA           | AVA-0 INT-0  | AVA-0 INT-0 | AVA-0 INT-0 | AVA-0 INT-0  | NA                      | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                   | High                 | High                 | High                 | High                 | UC2, UC3, UC4, UC5 |
| T_GEN06 | Network attacker modifies or deletes private keys                                                            | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateGeneration                                    | KEY02 | Integrity, Availability | AVA-1 INT-0  | AVA-0 INT-0  | AVA-0 INT-0 | NA          | AVA-0 INT-0  | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | High                 | High                 | High                 | NA                   | High                 | UC1, UC2, UC3, UC5 |
| T_GEN07 | Local unauthorised user discloses private keys                                                               | COM.UserInterface<br>I.CertificateGeneration                                                          | KEY02 | Confidentiality         | CON-0        | NA           | NA          | NA          | NA           | DEP-2 NET-1 USR-1 COM-2 | NA                      | NA                      | NA                      | NA                      | High                 | NA                   | NA                   | NA                   | NA                   | UC1                |
| T_GEN08 | Network attacker discloses private keys generated or stored by external cryptographic system.                | COM.UserInterface or COM.Local<br>I.ExternalCryptographic Service                                     | KEY02 | Confidentiality         | NA           | CON-0        | CON-0       | CON-0       | CON-0        | NA                      | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                   | High                 | High                 | High                 | High                 | UC2, UC3, UC4, UC5 |
| T_GEN09 | Network attacker discloses private keys                                                                      | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateGeneration Or I.ExternalCryptographic Service | KEY02 | Confidentiality         | CON-0        | CON-0        | CON-0       | NA          | CON-0        | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | High                 | High                 | High                 | NA                   | High                 | UC1, UC2, UC3, UC5 |
| T_DIS01 | Local unauthorised user modifies or deletes certificates in certificate store data                           | COM.UserInterface<br>I.CertificateGeneration                                                          | DIS01 | Integrity, Availability | AVA-2, INT-1 | AVA-1, INT-1 | AVA-1 INT-0 | AVA-1 INT-0 | AVA-1, INT-1 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | Medium               | High                 | High                 | Medium               | All UC             |
| T_DIS02 | Network attacker modifies or deletes certificates in certificate store data                                  | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateGeneration                                    | DIS01 | Integrity, Availability | AVA-2, INT-1 | AVA-1, INT-1 | AVA-1 INT-0 | NA          | AVA-1, INT-1 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | Medium               | High                 | NA                   | High                 | UC1, UC2, UC3, UC5 |
| T_DIS03 | Local unauthorised user discloses certificates in certificate store data                                     | COM.UserInterface<br>I.CertificateGeneration                                                          | DIS01 | Confidentiality         | CON-2        | CON-2        | CON-2       | CON-2       | CON-2        | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Low                  | Low                  | Low                  | Low                  | Low                  | None               |
| T_DIS04 | Network attacker discloses certificates in certificate store data                                            | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateGeneration                                    | DIS01 | Confidentiality         | CON-2        | CON-2        | CON-2       | NA          | CON-2        | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | DEP-1 NET-1 USR-1 COM-0 | DEP-1 NET-1 USR-1 COM-0 | Low                  | Low                  | Medium               | NA                   | Medium               | UC3, UC5           |
| T_REV01 | Local unauthorised user modifies or delete revocation request                                                | COM.UserInterface<br>I.CertificateStatus                                                              | STA01 | Integrity, Availability | AVA-2, INT-1 | NA           | NA          | NA          | NA           | DEP-2 NET-1 USR-1 COM-2 | NA                      | NA                      | NA                      | NA                      | High                 | NA                   | NA                   | NA                   | NA                   | UC1                |

| Threat  |                                                                                                                      |                                                                                                      |       | Impact risk factors     |              |             |             |             |             | Likelihood risk factors |                         |                         |                         |                         | Risk Evaluation      |                      |                      |                      |                      | UC / App.          |
|---------|----------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|-------|-------------------------|--------------|-------------|-------------|-------------|-------------|-------------------------|-------------------------|-------------------------|-------------------------|-------------------------|----------------------|----------------------|----------------------|----------------------|----------------------|--------------------|
| ID      | Description                                                                                                          | Attack vector                                                                                        | Asset | Impact Type             | Value UC1    | Value UC2   | Value UC3   | Value UC4   | Value UC5   | Value UC1               | Value UC2               | Value UC3               | Value UC4               | Value UC5               | Risk Value UC1 (SP1) | Risk Value UC2 (SP2) | Risk Value UC3 (SP3) | Risk Value UC4 (SP4) | Risk Value UC5 (SP5) |                    |
| T_REV02 | Network attacker modifies or delete revocation status protection request forwarded to external cryptographic system. | COM.UserInterface<br>I.ExternalCryptographic Service                                                 | STA01 | Integrity, Availability | NA           | AVA-0 INT-0 | NA          | NA          | AVA-0 INT-0 | NA                      | DEP-1 NET-1 USR-1 COM-2 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-2 | NA                   | High                 | NA                   | NA                   | High                 | UC2,UC5            |
| T_REV03 | Network attacker modifies or delete revocation request                                                               | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateStatus Or<br>I.ExternalCryptographic Service | STA01 | Integrity, Availability | AVA-2, INT-1 | AVA-0 INT-0 | NA          | NA          | AVA-0 INT-0 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | NA                      | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | High                 | NA                   | NA                   | High                 | UC1, UC2, UC 5     |
| T_REV04 | Local unauthorised user discloses revocation request                                                                 | COM.UserInterface<br>I.CertificateStatus                                                             | STA01 | Confidentiality         | CON-2        | CON-2       | CON-2       | CON-2       | CON-2       | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Low                  | Low                  | Low                  | Low                  | Low                  | None               |
| T_REV05 | Network attacker discloses revocation request                                                                        | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateStatus Or<br>I.ExternalCryptographic Service | STA01 | Confidentiality         | CON-2        | CON-2       | CON-2       | NA          | CON-2       | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Low                  | Low                  | Medium               | NA                   | Medium               | UC3, UC5           |
| T_REV06 | Local unauthorised user modifies certificate revocation statuses                                                     | COM.UserInterface<br>I.CertificateStatus Or<br>I.ExternalCryptographic Service                       | STA01 | Integrity, Availability | AVA-2, INT-1 | AVA-0 INT-0 | AVA-0 INT-0 | AVA-0 INT-0 | AVA-0 INT-0 | DEP-2 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | DEP-1 NET-1 USR-1 COM-2 | Medium               | High                 | High                 | High                 | High                 | All UC             |
| T_REV07 | Network attacker modifies certificate revocation statuses                                                            | COM.Public or COM.Adjacent or COM.Local<br>I.CertificateStatus Or<br>I.ExternalCryptographic Service | STA01 | Integrity, Availability | AVA-2, INT-1 | AVA-0 INT-0 | AVA-0 INT-0 | NA          | AVA-0 INT-0 | DEP-2 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-1 | DEP-1 NET-1 USR-1 COM-0 | NA                      | DEP-1 NET-1 USR-1 COM-0 | Medium               | High                 | High                 | NA                   | High                 | UC1, UC2, UC3, UC5 |

Figure B.3-5: Risk evaluation

## B.4 Requirements applicability - threats mapping rational

Table B.4-1: Threat mapping rational

| Threat  |                                            |                   |       | Requirements coverage                                                                                                                                                                                                                                                                         |                                                                                                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|---------|--------------------------------------------|-------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| ID      | Description                                | Attack vector     | Asset | Requirements                                                                                                                                                                                                                                                                                  | Associated assessment                                                                                           | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | UC / App. |
| T_ALL   | All threats applicable to the product      | All               | All   | REQ-PKI-KEV-01<br>5.4 Secure updates<br>REQ-PKI-SU-01<br>REQ-PKI-SU-02<br>REQ-PKI-SU-03<br>5.8.1 DM – General<br>REQ-PKI-DM-01<br>REQ-PKI-DM-02<br>REQ-PKI-DM-03<br>5.11 Minimisation of attack surfaces<br>REQ-PKI-MAS-01<br>5.13 Logging and monitoring<br>REQ-PKI-MON-01<br>REQ-PKI-MON-02 | All security requirements REQ-PKI-XXX-YY are covered by their respective assessment requirement ACC-PKI-XXX-YY. | Threats applicable to all product assets are mitigated through a set of approaches required by the CRA combining vulnerability management, secure software updates, attack surface minimisation, data minimisation, and comprehensive logging. The product is required to be free of known exploitable vulnerabilities, supports authenticated software updates, limits the data and interfaces exposed to only those necessary for its intended functions, and records security-relevant events to enable monitoring and detection of malicious activities. Together, these measures reduce the overall attack surface, limit opportunities for exploitation, and support the timely detection and response to security incidents. | All UC    |
| T_LOCAL | All threats related to unauthorised users. | COM.UserInterface | All   | 5.3.1 SDBC- Access control<br>- REQ-PKI-SBDC-01<br>Clause 5.5<br>- REQ-PKI-AAC-01<br>- REQ-PKI-AAC-02 or<br>- REQ-PKI-AAC-03                                                                                                                                                                  |                                                                                                                 | The threat of a local unauthorised user disclosing or modifying the product assets is mitigated by default through access control mechanisms based on the principles of authentication, authorisation, and least privilege. All assets are protected by a default-deny access policy, ensuring that modification rights are granted only to authorised users. Identification and authentication mechanisms verify user identities using state of the art cryptography, while RBAC restricts configuration management functions to users assigned the appropriate roles and privileges. Consequently, unauthorised local users are prevented from modifying product assets stored and managed locally.                               |           |

| Threat  |                                                                                                 |                                                                           |       | Requirements coverage                                                                                                                                                                                                                                                                                        |                       |                                                                                                                                                                                                                                                                                                                                                                                        |                    |
|---------|-------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|-------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| ID      | Description                                                                                     | Attack vector                                                             | Asset | Requirements                                                                                                                                                                                                                                                                                                 | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                               | UC / App.          |
| T_NET   | All threats related to network attacker.                                                        | COM.Public or<br>COM.Adjacent or<br>COM.Local                             | All   | Clause 5.3.1 SDBC- Access control<br>- REQ-PKI-SBDC-01,<br>Clause 5.5 Authentication and access control<br>- REQ-PKI-AAC-01<br>- REQ-PKI-AAC-02<br>- REQ-PKI-AAC-03<br>Clause 5.6.1 CON - General<br>- REQ-PKI-CON-04<br>- REQ-PKI-CON-06<br>5.6.2 CON - Secure storage and communications<br>REQ-PKI-CON-08 |                       | The threat of network attacker of disclosing or modifying system configuration data is mitigated as for local unauthorised user through access control.<br>Furthermore, all sensitive data including user and administrative data can only be transmitted over the network while being protected in confidentiality, preventing remote session hijacking or sensitive data disclosure. |                    |
| T_SYS01 | Local unauthorised user modifies system configuration data.                                     | COM.UserInterface<br>I.AuditAndAdministration                             | SYS01 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                        |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                  | All UC             |
| T_SYS02 | Network attacker modifies system configuration data.                                            | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS01 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                          |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                    | UC1, UC2, UC3, UC5 |
| T_SYS03 | Local unauthorised user discloses sensitive parameters in system configuration data.            | COM.UserInterface<br>I.AuditAndAdministration                             | SYS01 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                        |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                  | All UC             |
| T_SYS04 | Network attacker discloses sensitive parameters in system configuration data.                   | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS01 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                          |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                    | UC1, UC2, UC3, UC5 |
| T_SYS05 | Local unauthorised user modifies access rights in user account data.                            | COM.UserInterface<br>I.AuditAndAdministration                             | SYS02 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                        |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                  | All UC             |
| T_SYS06 | Network attacker modifies user authentication credentials or access rights in user account data | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS02 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                          |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                    | UC1, UC2, UC3, UC5 |
| T_SYS07 | Local unauthorised user discloses user authentication credentials in user account data          | COM.UserInterface<br>I.AuditAndAdministration                             | SYS02 | Cf. T_LOCAL and T_ALL and                                                                                                                                                                                                                                                                                    |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                  | All UC             |
| T_SYS08 | Network attacker user discloses user authentication credentials in user account data            | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS02 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                          |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                    | UC1, UC2, UC3, UC5 |

| Threat  |                                                                       |                                                                           |       | Requirements coverage                                                                                                                                                                                                                                                                                                                             |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                    |
|---------|-----------------------------------------------------------------------|---------------------------------------------------------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| ID      | Description                                                           | Attack vector                                                             | Asset | Requirements                                                                                                                                                                                                                                                                                                                                      | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | UC / App.          |
| T_SYS09 | Local unauthorised user modifies or deletes events in event log data. | COM.UserInterface<br>I.AuditAndAdministration                             | SYS03 | Cf. T_LOCAL and T_ALL and Clause 6.7.1 INT – Monitoring<br>REQ-PKI-INT-01<br>REQ-PKI-INT-02<br>REQ-PKI-INT-03<br>REQ-PKI-INT-04<br>REQ-PKI-INT-05<br>5.13 Logging and monitoring<br>REQ-PKI-MON-03<br>REQ-PKI-MON-04<br>REQ-PKI-MON-05                                                                                                            |                       | Cf. T_LOCAL and T_ALL<br>Cryptographic integrity protection mechanisms, including periodic audit log signing and integrity verification, enable the detection of unauthorised modifications or deletions of system configuration data. The inclusion of timestamps within the integrity-protected data further prevents tampering with the timing information associated with logged events.                                                                                                                                                                                                                                                                                                                                                                                | UC2, UC3, UC4, UC5 |
| T_SYS10 | Network attacker user modifies or deletes events in event log data.   | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS03 | Cf. T_NET and T_ALL<br>Clause 6.7.1 INT – Monitoring<br>REQ-PKI-INT-01<br>REQ-PKI-INT-02<br>REQ-PKI-INT-03<br>REQ-PKI-INT-04<br>REQ-PKI-INT-05<br>5.13 Logging and monitoring<br>REQ-PKI-MON-03<br>REQ-PKI-MON-04<br>REQ-PKI-MON-05                                                                                                               |                       | Cf. T_NET and T_ALL<br>Cryptographic integrity protection mechanisms, including periodic audit log signing and integrity verification, enable the detection of unauthorised modifications or deletions of system configuration data. The inclusion of timestamps within the integrity-protected data further prevents tampering with the timing information associated with logged events.                                                                                                                                                                                                                                                                                                                                                                                  | UC2, UC3, UC5      |
| T_SYS11 | Local unauthorised users discloses events in event log data.          | COM.UserInterface<br>I.AuditAndAdministration                             | SYS03 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                             |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | UC2, UC3, UC4, UC5 |
| T_SYS12 | Network attacker discloses events in event log data.                  | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.AuditAndAdministration | SYS03 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                               |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | UC2, UC3, UC5      |
| T_REG01 | Local unauthorised user modifies or deletes subscriber data           | COM.UserInterface<br>I.CertificateGeneration                              | REG01 | Cf. T_LOCAL and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-05<br>5.12.1 EMM - Certificate issuance<br>REQ-PKI-EMM-01<br>REQ-PKI-EMM-02<br>REQ-PKI-EMM-03<br>REQ-PKI-EMM-04<br>REQ-PKI-EMM-05<br>REQ-PKI-EMM-06<br>REQ-PKI-EMM-07<br>5.12.3 EMM - Certificate re-key<br>REQ-PKI-EMM-14<br>5.12.4 EMM - Certificate modification<br>REQ-PKI-EMM-15 |                       | Cf. T_LOCAL and T_ALL<br>The threat of a local unauthorised user modifying or deleting subscriber data is further mitigated by integrity protection and certificate management controls. Certificate requests containing personal data are cryptographically protected to preserve their integrity and confidentiality. In addition, certificate issuance, re-key, and modification processes require validation of subscriber information, enforce compliance with defined certificate profiles, and record updated registration information whenever subscriber attributes are modified. These measures help ensure that subscriber data remains accurate, consistent, and protected against unauthorised modification or deletion over the whole certificate life-cycle. | All UC             |

| Threat  |                                                                      |                                                                          |       | Requirements coverage                                                                                                                                                                                                                                                                                                                                             |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |                    |
|---------|----------------------------------------------------------------------|--------------------------------------------------------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| ID      | Description                                                          | Attack vector                                                            | Asset | Requirements                                                                                                                                                                                                                                                                                                                                                      | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | UC / App.          |
| T_REG02 | Network attacker modifies or deletes subscriber data                 | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration | REG01 | Cf. T_NET and T_ALL<br>5.6.1 CON - General<br>REQ-PKI-CON-05<br>REQ-PKI-CON-07<br>5.12.1 EMM - Certificate issuance<br>REQ-PKI-EMM-01<br>REQ-PKI-EMM-02<br>REQ-PKI-EMM-03<br>REQ-PKI-EMM-04<br>REQ-PKI-EMM-05<br>REQ-PKI-EMM-06<br>REQ-PKI-EMM-07<br>5.12.3 EMM - Certificate re-key<br>REQ-PKI-EMM-14<br>5.12.4 EMM - Certificate modification<br>REQ-PKI-EMM-15 |                       | Cf. T_NET and T_ALL<br>The threat of a network attacker modifying or deleting subscriber data is further mitigated by integrity protection and certificate management controls. Certificate requests containing personal data are cryptographically protected to preserve their integrity and confidentiality. In addition, certificate issuance, re-key, and modification processes require validation of subscriber information, enforce compliance with defined certificate profiles, and record updated registration information whenever subscriber attributes are modified. These measures help ensure that subscriber data remains accurate, consistent, and protected against unauthorised modification or deletion over the whole certificate life-cycle. | UC1, UC3, UC5      |
| T_REG03 | Local unauthorised user discloses subscriber data                    | COM.UserInterface<br>I.CertificateGeneration                             | REG01 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                             |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | All UC             |
| T_REG04 | Network attacker discloses subscriber data                           | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration | REG01 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                               |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | UC1, UC2, UC3, UC5 |
| T_REG05 | Local unauthorised user modifies or deletes certificate request data | COM.UserInterface<br>I.CertificateGeneration                             | REG02 | Cf. T_REG01                                                                                                                                                                                                                                                                                                                                                       |                       | Cf. T_REG01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | UC1, UC2, UC5      |
| T_REG06 | Network attacker modifies or deletes certificate request data        | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration | REG02 | Cf. T_REG02                                                                                                                                                                                                                                                                                                                                                       |                       | Cf. T_REG02                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | UC1, UC2, UC5      |
| T_REG07 | Local unauthorised user discloses certificate requests               | COM.UserInterface<br>I.CertificateGeneration                             | REG02 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                             |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              | UC1, UC2, UC5      |
| T_REG08 | Network attacker discloses certificate requests                      | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration | REG02 | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                               |                       | Cf. T_NET and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | UC1, UC2, UC5      |

| Threat  |                                                                                                             |                                                                                      |       | Requirements coverage                                                                                                                                                                               |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |                    |
|---------|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| ID      | Description                                                                                                 | Attack vector                                                                        | Asset | Requirements                                                                                                                                                                                        | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | UC / App.          |
| T_GEN01 | Local unauthorised user modifies or deletes public keys                                                     | COM.UserInterface<br>I.CertificateGeneration<br>Or<br>I.ExternalCryptographicService | KEY01 | Cf. T_LOCAL and T_ALL<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04<br>5.14.1 DRT - Secret management<br>REQ-PKI-DRT-01                                                                          |                       | Cf. T_LOCAL and T_ALL<br>Also, the identified threat is mitigated by ensuring that public keys are generated only through trusted Secure Cryptographic Devices (SCDs) or secure remote Key Management Systems, preventing unauthorised key creation or replacement (REQ-PKI-DM-04). In addition, all public keys stored outside an SCD are integrity-protected and verified before use, ensuring that any unauthorised modification or deletion is detected and that compromised keys are neither released nor used by the product (REQ-PKI-DRT-01).                                                    | All UC             |
| T_GEN02 | Network attacker modifies or deletes public keys                                                            | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration             | KEY01 | Cf. T_NET and T_ALL<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04<br>5.14.1 DRT - Secret management<br>REQ-PKI-DRT-01                                                                            |                       | Cf. T_NET and T_ALL<br>Also, the identified threat is mitigated by ensuring that public keys are generated only through trusted Secure Cryptographic Devices (SCDs) or secure remote Key Management Systems, preventing unauthorised key creation or replacement (REQ-PKI-DM-04). In addition, all public keys stored outside an SCD are integrity-protected and verified before use, ensuring that any unauthorised modification or deletion is detected and that compromised keys are neither released nor used by the product (REQ-PKI-DRT-01).                                                      | UC1                |
| T_GEN03 | Network attacker modifies or deletes public keys requests exchanged with the external cryptographic system. | COM.Local<br>I.ExternalCryptographicService                                          | KEY01 | Cf. T_NET and T_ALL<br>5.6.2 CON - Secure storage and communications<br>REQ-PKI-CON-09                                                                                                              |                       | Cf. T_NET and T_ALL<br>Communication with the SCD or external KMS are ensured to be protected and attacker cannot intercept or modify those.                                                                                                                                                                                                                                                                                                                                                                                                                                                            | UC2, UC3, UC4, UC5 |
| T_GEN04 | Local unauthorised user modifies or deletes private keys                                                    | COM.UserInterface<br>I.CertificateGeneration                                         | KEY02 | Cf. T_LOCAL and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-01<br>REQ-PKI-CON-02<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04 |                       | Cf. T_LOCAL and T_ALL<br>Also, the identified threat is mitigated by ensuring that private keys are generated only by trusted Secure Cryptographic Devices (SCDs) or secure remote Key Management Systems (REQ-PKI-DM-04). Private keys are protected against unauthorised extraction, copying, and disclosure through access controls, cryptographic protection, and secure storage mechanisms (REQ-PKI-CON-01, REQ-PKI-CON-02, REQ-PKI-CON-10, REQ-PKI-CON-11), thereby preventing unauthorised users from modifying, deleting, or replacing private keys without compromising the protected storage. | UC1                |



| Threat  |                                                                                                              |                                                                                             |       | Requirements coverage                                                                                                                                                                                                                                                |                       |                                                                                                                                                                                             |                    |
|---------|--------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|-------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| ID      | Description                                                                                                  | Attack vector                                                                               | Asset | Requirements                                                                                                                                                                                                                                                         | Associated assessment | Rational                                                                                                                                                                                    | UC / App.          |
| T_GEN05 | Network attacker modifies or deletes private keys requests exchanged with the external cryptographic system. | COM.Local<br>COM.UserInterface<br>I.CertificateGeneration<br>I.ExternalCryptographicService | KEY02 | Cf. T_NET and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-01<br>REQ-PKI-CON-2<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04                                                                     |                       | Cf. T_NET, T_ALL and T_GEN04                                                                                                                                                                | UC2, UC3, UC4, UC5 |
| T_GEN06 | Network attacker modifies or deletes private keys                                                            | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration                    | KEY02 | Cf. T_NET and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-01<br>REQ-PKI-CON-2<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04                                                                     |                       | Cf. T_LOCAL, T_ALL and T_GEN04                                                                                                                                                              | UC1, UC2, UC3, UC5 |
| T_GEN07 | Local unauthorised user discloses private keys                                                               | COM.UserInterface<br>I.CertificateGeneration                                                | KEY02 | Cf. T_LOCAL and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-01<br>REQ-PKI-CON-02<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04                                                                  |                       | Cf. T_NET, T_ALL and T_GEN04                                                                                                                                                                | UC1                |
| T_GEN08 | Network attacker discloses private keys generated or stored by external cryptographic system.                | COM.UserInterface<br>I.ExternalCryptographicService                                         | KEY02 | Cf. T_NET and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-01<br>REQ-PKI-CON-02<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret management<br>REQ-PKI-DM-04<br>5.6.2 CON - Secure storage and communications<br>REQ-PKI-CON-09 |                       | Cf. T_NET and T_ALL<br>Also, communications with the SCD or external KMS are protected, preventing an attacker from intercepting or modifying them, provided they are correctly configured. | UC2, UC3, UC4, UC5 |

| Threat  |                                                                                    |                                                                                                                  |       | Requirements coverage                                                                                                                                                             |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |                       |
|---------|------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|
| ID      | Description                                                                        | Attack vector                                                                                                    | Asset | Requirements                                                                                                                                                                      | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | UC / App.             |
| T_GEN09 | Network attacker discloses private keys                                            | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration<br>Or<br>I.ExternalCryptographicService | KEY02 | Cf. T_NET and T_ALL<br>5.6.1 CON – General<br>REQ-PKI-CON-2<br>5.6.3 CON - Key management<br>REQ-PKI-CON-10<br>REQ-PKI-CON-11<br>5.8.2 DM - Secret<br>management<br>REQ-PKI-DM-04 |                       | Cf. T_NET, T_ALL and T_GEN04                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | UC1, UC2,<br>UC3, UC5 |
| T_DIS01 | Local unauthorised user modifies or deletes certificates in certificate store data | COM.UserInterface<br>I.CertificateGeneration                                                                     | DIS01 | Cf. T_LOCAL and T_ALL<br>5.7.2 INT - Certificate signing<br>REQ-PKI-INT-06<br>REQ-PKI-INT-07                                                                                      |                       | Cf. T_LOCAL and T_ALL<br>Alos, the threat is mitigated by ensuring that certificates are signed exclusively using a Secure Cryptographic Device (SCD) and state-of-the-art cryptographic mechanisms (REQ-PKI-INT-06, REQ-PKI-INT-07). These requirements ensure that any modified or forged certificate cannot be presented as a valid product-generated certificate, although they do not explicitly prevent or detect unauthorised deletion or modification of certificates stored in the certificate store. | All UC                |
| T_DIS02 | Network attacker modifies or deletes certificates in certificate store data        | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration                                         | DIS01 | Cf. T_NET and T_ALL<br>5.7.2 INT - Certificate signing<br>REQ-PKI-INT-06<br>REQ-PKI-INT-07                                                                                        |                       | Cf. T_NET, T_ALL and T_DIS01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | UC1, UC2,<br>UC3, UC5 |
| T_DIS03 | Local unauthorised user discloses certificates in certificate store data.          | COM.UserInterface<br>I.CertificateGeneration                                                                     | DIS01 | NA                                                                                                                                                                                |                       | Cf. T_LOCAL, T_ALL and T_DIS01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | None                  |
| T_DIS04 | Network attacker discloses certificates in certificate store data                  | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateGeneration                                         | DIS01 | Cf. T_NET and T_ALL<br>5.7.2 INT - Certificate signing<br>REQ-PKI-INT-06<br>REQ-PKI-INT-07                                                                                        |                       | Cf. T_NET, T_ALL and T_DIS01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | UC3, UC5              |
| T_REV01 | Local unauthorised user modifies or delete revocation request                      | COM.UserInterface<br>I.CertificateStatus                                                                         | STA01 | Cf. T_LOCAL and T_ALL                                                                                                                                                             |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | UC1,                  |

| Threat  |                                                                                                                      |                                                                                                              |       | Requirements coverage                                                                                                                                                                                                                                                                                                                                                                                                                                   |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                   |
|---------|----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|
| ID      | Description                                                                                                          | Attack vector                                                                                                | Asset | Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                            | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | UC / App.         |
| T_REV02 | Network attacker modifies or delete revocation status protection request forwarded to external cryptographic system. | COM.UserInterface<br>I.ExternalCryptographicService                                                          | STA01 | Cf. T_NET and T_ALL<br>REQ-PKI-CON-09<br>5.7.3 INT- CRL signing<br>REQ-PKI-INT-08                                                                                                                                                                                                                                                                                                                                                                       |                       | Cf. T_NET and T_ALL<br>Also, the threat is mitigated by requiring the product to establish and maintain a secure communication link with the Secure Cryptographic Device (SCD) or Key Management System (KMS), protecting revocation status requests against unauthorised modification or deletion in transit (REQ-PKI-CON-09). In addition, CRLs are generated and signed only by the SCD (REQ-PKI-INT-08), ensuring the authenticity and integrity of the resulting revocation information.                                                                                                                                                                                                                                                                                                                                                                                                                                                                | UC2,UC5           |
| T_REV03 | Network attacker modifies or delete revocation request                                                               | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateStatus<br>Or<br>I.ExternalCryptographicService | STA01 | Cf. T_NET and T_ALL<br>REQ-PKI-CON-09<br>5.7.3 INT- CRL signing<br>REQ-PKI-INT-08                                                                                                                                                                                                                                                                                                                                                                       |                       | Cf. T_REV02                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | UC1, UC2,<br>UC 5 |
| T_REV04 | Local unauthorised user discloses revocation request                                                                 | COM.UserInterface<br>I.CertificateStatus                                                                     | STA01 | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                   |                       | Cf. T_LOCAL and T_ALL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | None              |
| T_REV05 | Network attacker discloses revocation request                                                                        | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateStatus<br>Or<br>I.ExternalCryptographicService | STA01 | Cf. T_NET and T_ALL<br>5.6.2 CON - Secure storage and communications<br>REQ-PKI-CON-09                                                                                                                                                                                                                                                                                                                                                                  |                       | Cf. T_NET and T_ALL<br>Also, communications with the SCD or external KMS are protected, preventing an attacker from intercepting or modifying them, provided they are correctly configured.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | UC3, UC5          |
| T_REV06 | Local unauthorised user modifies certificate revocation statuses                                                     | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateStatus<br>Or<br>I.ExternalCryptographicService | STA01 | Cf. T_LOCAL and T_ALL<br>5.7.3 INT- CRL signing<br>REQ-PKI-INT-08<br>REQ-PKI-INT-09<br>REQ-PKI-INT-10<br>5.9.1 AP - Certificate suspension and revocation<br>REQ-PKI-AP-01<br>REQ-PKI-AP-02<br>REQ-PKI-AP-03<br>REQ-PKI-AP-04<br>5.9.2 AP - Certificate status services<br>REQ-PKI-AP-05<br>REQ-PKI-AP-06<br>REQ-PKI-AP-07<br>5.12.2 EMM - Certificate status<br>REQ-PKI-EMM-08<br>REQ-PKI-EMM-09<br>REQ-PKI-EMM-10<br>REQ-PKI-EMM-11<br>REQ-PKI-EMM-12 |                       | Cf. T_LOCAL and T_ALL<br>The threat is mitigated by enforcing that all Certificate Revocation Lists (CRLs) are generated and signed exclusively using a Secure Cryptographic Device (SCD), combined with state-of-the-art cryptographic mechanisms (REQ-PKI-INT-08, REQ-PKI-INT-09). This ensures that any modification of CRL content by a local unauthorised user would result in signature verification failure, thereby preserving the integrity and authenticity of certificate revocation status information. Furthermore, CRLs should be signed using a valid certificate (REQ-PKI-INT-10), ensuring that only trusted and authorised entities within the PKI infrastructure can issue or update revocation information, reducing the risk of unauthorised manipulation. In addition, certificate lifecycle and status service requirements ensure the correct and controlled propagation of revocation information over time. Certificates cannot be | All UC            |

| Threat  |                                                          |                                                                                                              |       | Requirements coverage                                                                                                                                                                                                                                                                                                                                                                           |                       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |           |
|---------|----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------|-------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| ID      | Description                                              | Attack vector                                                                                                | Asset | Requirements                                                                                                                                                                                                                                                                                                                                                                                    | Associated assessment | Rational                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | UC / App. |
|         |                                                          |                                                                                                              |       | REQ-PKI-EMM-13                                                                                                                                                                                                                                                                                                                                                                                  |                       | reinstated once revoked (REQ-PKI-AP-01), preventing rollback or unauthorised recovery of revoked status. CRL validity and update constraints (REQ-PKI-AP-02 to REQ-PKI-AP-04) ensure that revocation information remains current and consistently maintained, while supporting predictable update cycles. Revocation status services (REQ-PKI-AP-05 to REQ-PKI-AP-07) further ensure that certificate status is consistently provided across mechanisms such as CRLs and OCSP, with controlled synchronisation and consistency rules that reduce the risk of conflicting or manipulated status data. Finally, profile and policy enforcement requirements for CRLs and OCSP responses (REQ-PKI-EMM-08 to REQ-PKI-EMM-13) ensure strict adherence to defined formats, field constraints, and authorised configuration of critical parameters such as issuer identity, responder identity, and update timing. These controls limit the ability of a local unauthorised user to introduce malformed, inconsistent, or unauthorised revocation status data. Overall, the combination of cryptographic protection, strict lifecycle management, and enforced service consistency ensures that any attempt to modify certificate revocation status information is either prevented or reliably detected. |           |
| T_REV07 | Network attacker modifies certificate revocation statues | COM.Public or<br>COM.Adjacent or<br>COM.Local<br>I.CertificateStatus<br>Or<br>I.ExternalCryptographicService | STA01 | Cf. T_NET and T_ALL<br>5.7.3 INT- CRL signing<br>REQ-PKI-INT-08<br>REQ-PKI-INT-09<br>REQ-PKI-INT-10<br>5.9.1 AP - Certificate suspension and revocation<br>REQ-PKI-AP-01<br>REQ-PKI-AP-02<br>REQ-PKI-AP-03<br>REQ-PKI-AP-04<br>5.9.2 AP - Certificate status services<br>REQ-PKI-AP-05<br>REQ-PKI-AP-06<br>REQ-PKI-AP-07<br>5.12.2 EMM - Certificate status<br>REQ-PKI-EMM-08<br>REQ-PKI-EMM-09 |                       | Cf. T_NET, T_ALL and T_REV06                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | All UC    |

| Threat |             |               |       | Requirements coverage                                                |                       |          |           |
|--------|-------------|---------------|-------|----------------------------------------------------------------------|-----------------------|----------|-----------|
| ID     | Description | Attack vector | Asset | Requirements                                                         | Associated assessment | Rational | UC / App. |
|        |             |               |       | REQ-PKI-EMM-10<br>REQ-PKI-EMM-11<br>REQ-PKI-EMM-12<br>REQ-PKI-EMM-13 |                       |          |           |

---

Annexes C to J:  
Void

---

## Annex K (normative): Generic cryptographic requirements and assessment

### K.1 Cryptography

#### K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

- 1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
- 2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1] and meets at least one of the following conditions:
  - a) the cryptographic mechanism is listed in clause K.3.2 as an ACM-extended cryptographic mechanism for the specific product function(s);
  - b) where the cryptographic mechanism is not listed in clause K.3.2, the cryptographic mechanism meets all the following criteria:
  - c) the cryptographic mechanism, or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
    - i) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognised European, international or sector-specific standards development organisation, or by an industry specification organisation accountable for the relevant specification, or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognised national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process;
    - ii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;
    - iii) the cryptographic properties of the cryptographic mechanism are known;
    - iv) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;
    - v) the cryptographic mechanism is required for a specific set of product functions;
- 3) Interoperability-based: the cryptographic mechanism is listed in clause K.4.2 as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

NOTE 1: The reference to the product's default configuration is intended to define a clear and assessable baseline, corresponding to the configuration in which the product is placed on the market. The product can provide several configurations that fulfil the requirement.

NOTE 2: For products supplied as hardware platforms or components to be configured by an integrator, references in this annex to the product's default configuration refer to the configuration specified for the intended operational use of the product after integration, including the relevant integration assumptions and configuration constraints.

NOTE 3: The applicable ACM catalogue version is identified in the normative references of the present document. The lifecycle treatment of mechanisms affected by ACM deprecation dates, expiry dates, migration conditions or usage limitations is addressed in clause K.2.

NOTE 4: In this clause, an external specification or external requirement means a specification or requirement that is imposed on the product, and which requires the use of a specific cryptographic mechanism for the product to interoperate with an identified system, platform or operational context. An external requirement can be a regulatory requirement, operational constraint, technical interoperability constraint, or platform compatibility requirement.

NOTE 5: Inclusion of a cryptographic mechanism under the interoperability-based criterion does not classify that mechanism as state-of-the-art cryptography.

EXAMPLE: Examples of product functions include secure communication based on TLS 1.3; authenticated encryption of communicated data based on AES-GCM; storage confidentiality based on AES-XTS; firmware signature verification based on Ed25519; and key derivation based on HKDF.

## K.1.2 Assessment of product cryptographic configuration

### K.1.2.0 General

The assessment in clause K.1.2 verifies the cryptographic mechanisms used in the product's default configuration against clause K.1.1.

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause K.3.2 or fulfils the criteria specified in clause K.1.1 item 2.b. For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause K.4.2. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

### K.1.2.1 Assessment of ACM-listed cryptographic mechanisms

#### K.1.2.1.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

#### K.1.2.1.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

#### K.1.2.1.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 1) is identified by reference to a relevant ACM entry;
- b) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;
- c) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

#### K.1.2.1.4 Assessment evidence

The assessment evidence shall include, as applicable:



- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 1);
- c) references to the relevant ACM entries;
- d) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;
- e) relevant lifecycle information from the ACM catalogue, where applicable.

#### K.1.2.1.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 1).
- The verdict FAIL shall be assigned otherwise.

### K.1.2.2 Assessment of ACM-extended cryptographic mechanisms

#### K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause K.3.2 or fulfil the criteria specified in clause K.1.1 item 2.b, and are used for the claimed product function(s).

#### K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:
  - a) the relevant entry in clause K.3.2; or
  - b) evidence that the cryptographic mechanism fulfils all applicable criteria in clause K.1.1 item 2.b.

#### K.1.2.2.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 2) is either listed in clause K.3.2 as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause K.1.1 item 2.b;
- b) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause K.3.2 or described in the evidence provided under clause K.1.1 item 2.b;
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2 or justified under clause K.1.1 item 2.b;
- d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2 or justified under clause K.1.1 item 2.b, where applicable;
- e) where clause K.3.2 or the justification under clause K.1.1 item 2.b defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;
- f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

#### K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 2);
- c) reference to the relevant entry in clause K.3.2, where the mechanism is listed in clause K.3.2;
- d) evidence that the cryptographic mechanism fulfils the criteria in clause K.1.1 item 2.b, where compliance with clause K.1.1 item 2 is claimed on the basis of those criteria;
- e) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2 or in the justification under clause K.1.1 item 2.b, where applicable.

#### K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 2).
- The verdict FAIL shall be assigned otherwise.

### K.1.2.3 Assessment of interoperability-based cryptographic mechanisms

#### K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause K.4.2 and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause K.4.2.

#### K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause K.4.2.

#### K.1.2.3.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 3) is listed in clause K.4.2 as an interoperability-based cryptographic mechanism;
- b) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause K.4.2;
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.4.2;
- d) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause K.4.2;

- e) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.4.2, where applicable;
- f) the conditions or limitations specified in clause K.4.2 for the use of the cryptographic mechanism are reflected in the product's default configuration;
- g) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

#### K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 3);
- c) reference to the relevant entry in clause K.4.2;
- d) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- e) identification of the external specification or external requirement requiring use of the cryptographic mechanism;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.4.2.

#### K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 3).
- The verdict FAIL shall be assigned otherwise.

NOTE 1: The assessment of the external specification or external requirement itself is outside the scope of this assessment case. The assessment verifies that the external specification or external requirement is identified in clause K.4.2 and that the cryptographic mechanism is used by the product for the related product function.

NOTE 2: Documentation review is a minimum assessment activity under the present annex. Functional and/or resistance testing activities can be added by vertical standards where relevant for the product category, product function or cryptographic mechanism.

---

## K.2 Crypto agility

### K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

- a) updating the cryptographic mechanism;
- b) using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;
- c) disabling the use of the affected cryptographic mechanism; or

- d) limiting the use of the affected product functions accordingly.

**EXAMPLE:** Where a security mechanism uses a hybrid cryptographic construction, for example a hybrid key-encapsulation mechanism combining a classical and a post-quantum primitive, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridisation can be used as part of a planned migration strategy where permitted by the ACM catalogue or by the present document. However, hybridisation does not, by itself, extend the recommended usage lifetime of a constituent primitive that has been deprecated.

**NOTE 1:** Where a hybrid cryptographic construction includes multiple cryptographic primitives, the lifecycle status of each constituent primitive is relevant to the lifecycle status of the construction. Hybridisation is not assumed to mitigate the deprecation of a constituent primitive unless the ACM catalogue or the present document classifies the hybrid construction as suitable for the corresponding product function.

**NOTE 2:** Crypto agility supports maintaining appropriate cryptographic protection within the intended lifetime of the product, in addition to the capability of updating cryptographic mechanisms on the product in accordance with secure update and secure communication mechanisms.

**NOTE 3:** Deprecation information from sources other than the ACM catalogue or the present document can be considered as input to vulnerability management or security risk assessment but does not by itself trigger the requirement in clause K.2.1.

**NOTE 4:** Where the product provides cryptographic capabilities for use by other products, components or layers, the mechanism required by clause K.2.1 can consist of update, configuration, disabling, deprecation or limitation capabilities usable by the integrating product, system operator or user, where applicable.

**NOTE 5:** The applicability condition of this requirement can express exceptions based on product characteristics, e.g. cryptographic implementation based on immutable hardware co-processor(s) or hardware-based root of trust, or long-lived silicon used in a long-lived non-updateable environment.

## K.2.2 Assessment of crypto-agility

### K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue, or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause K.2.1.

### K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:
  - a) the intended lifetime of the product;
  - b) the cryptographic mechanisms used in the product's default configuration;
  - c) the related product function(s) for each cryptographic mechanism;
  - d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

### K.2.2.3 Assessment activities

The assessment shall include verification that:

- a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;
- b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;
- c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism, or limiting the use of the affected product functions accordingly;
- d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

### K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) documentation of the intended lifetime of the product;
- b) list of cryptographic mechanisms used in the product's default configuration;
- c) identification of the related product function(s) for each cryptographic mechanism;
- d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;
- e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;
- f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism, or limitation of the use of the affected product functions.

### K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.2.1.
- The verdict FAIL shall be assigned otherwise.

---

## K.3 ACM-extended cryptographic mechanisms

### K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause K.1.1 item 2.

## K.3.2 List of ACM-extended cryptographic mechanisms

No ACM-extended cryptographic mechanisms are specified.

## K.3.3 Assessment

Compliance with the ACM-extended criterion in clause K.1.1 item 2 is assessed in clause K.1.2.2.

---

# K.4 Interoperability-based cryptographic mechanisms

## K.4.1 Requirement

Where the product's default configuration uses interoperability-based cryptographic mechanisms, these mechanisms shall be selected from the interoperability-based cryptographic mechanisms listed in clause K.4.2 for the specified product functions and external specifications or external requirements and shall be used in accordance with the conditions or limitations specified in clause K.4.2.

## K.4.2 List of interoperability-based cryptographic mechanisms

No interoperability-based cryptographic mechanisms are specified.

## K.4.3 Assessment

Compliance with the requirement in clause K.4.1 is assessed in clause K.1.2.3.

NOTE: The assessment of the external specifications or external requirements themselves is outside the scope of this assessment. Their relevance is deemed confirmed by their inclusion in the present document.

---

Annexes I to T:  
Void

---

## Annex U (informative): Use case description

### U.1 UC1 - Product for use in Private PKI for non critical sectors

#### U.1.1 UC1 - General description

A private enterprise using public-key cryptography that manages a PKI internally to the enterprise. The enterprise therefore manages the policy framework, the generation of key pairs, the certification of key pairs and the purposes of keys. In such organisations the PKI may be organised on department centric hierarchies, or on location centric hierarchies, or on organisation role hierarchies or some combination of these. Whilst the set of services to be enabled by the PKI in this use case are large they may include VPN access and management, timestamp services, disk or message encryption, email, and document access and distribution and so on. The deployment of such a private Public Key Infrastructure (PKI) is not driven by regulatory or standardised requirements but rather by the need to align with the entity's internal policies and security practices. Additionally, users of these PKI solutions often prioritise flexibility and ease of use over highly secure but restrictive technologies. For instance, they will not rely on Secure Cryptographic Devices (SCD) but rather have private keys stored using operating system or platform key management facilities that provide protection against unauthorised access at rest. The manufacturer should document the protection mechanisms relied upon and their limitations. Where the platform facility supports hardware-backed protection (e.g. TPM), this should be the preferred configuration.

EXAMPLE 1: Products deployed to support software maintenance.

EXAMPLE 2: Products deployed to support internal IT service for network security deployments (e.g. VPN, ssh, TLS servers).

EXAMPLE 3: User management (identification and authentication) for services like User & Device Authentication, Single Sign-On (SSO).



## UC1 - Private PKI for non critical entities

Product functionalities

PKI Service

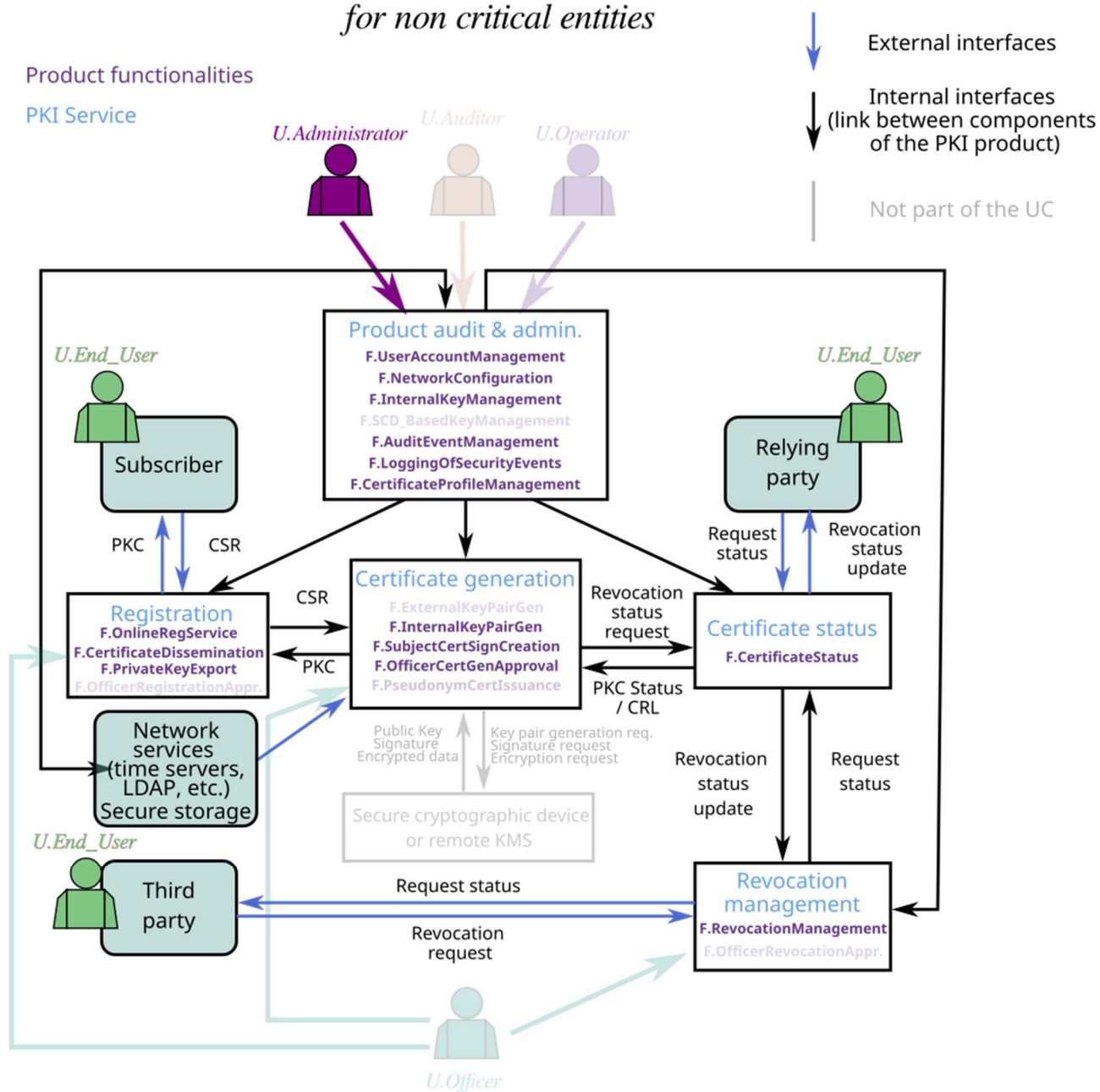


Figure U.1.1-1: UC1 functional architecture

## U.1.2 UC1 - Product Functions and assets

### U.1.2.1 UC1 - List of functions

#### Product audit & administration

F.UserAccountManagement: creation, modification, rights attributions and modification of the different user accounts. F.NetworkConfiguration: set up of network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.). F.Non\_SCD\_BasedKeyManagement: software keys suppression, export, renewal. F.OfficerRegistrationApproval: request to the SCD for keys suppression, export, renewal. F.AuditEventManager: configuration of audit events to be stored and their associated format. Search or erasure capabilities associated to stored audit events. F.LoggingOfSecurityEvents: for example, account access attempts, product configuration changes, and system warnings or errors. F.CertificateProfileManagement: administration functions to define format and default values of certificates to be signed.

#### Registration

F.OnlineRegService: a remote certificate enrolment interface (or Certificate Request Service) that enables users to submit certificate signing requests (CSRs) or certificate creation requests from any network-connected device. F.CertificateDissemination: distributes signed certificates to subscribers; and, if applicable, stores and makes them available to relying parties. F.PrivateKeyExport: private key, secret key or critical data can be encrypted and then exported in the form of an encrypted file.

#### Certificate generation

F.Non\_SCD\_BasedKeyPairGen: generates the public-private key pair. F.SubjectCertSignCreation: creates and signs subject certificates based on the identity and other attributes verified by the registration service. F.OfficerCertGenApproval: privileged users to approve and execute this issuance, when certificates are issued.

#### Certificate status

F.CertificateStatus: maintains certificate status information (e.g. active, expired, revoked).

#### Revocation management

F.RevocationManagement: processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service.

### U.1.2.2 UC1 - Assets

**Table U.1.2.2-1: Mapping between Functions and Assets for UC1**

| Functions                      | Assets                                                                                                |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
| F.UserAccountManagement        | SYS02.User account data                                                                               |
| F.NetworkConfiguration         | SYS01.System configuration data                                                                       |
| F.Non_SCDBasedKeyManagement    | KEY01.Keys                                                                                            |
| F.OfficerRegistrationApproval  | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.AuditEventManagement         | SYS01.System configuration data                                                                       |
| F.LoggingOfSecurityEvents      | SYS03: Event log data                                                                                 |
| F.CertificateProfileManagement | SYS01.System configuration data                                                                       |
| F.OnlineRegService             | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.CertificateDissemination     | DIS01.Certificate store data<br>SYS01.System configuration data                                       |
| F.PrivateKeyExport             | KEY02.Secret Keys                                                                                     |
| F.ExternalKeyPairGen           | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.SubjectCertSignCreation      | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.OfficerCertGenApproval       | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.CertificateStatus            | STA01.Certificate status data                                                                         |
| F.RevocationManagement         | STA01.Certificate status data                                                                         |

## U.1.3 UC1 - Operational Environment

### Physical/Hardware

POE.PartiallyControlled: partially controlled physical operational environment, none product users can access the product's hardware it is installed on.

### Logical Software

SOE.PartiallyControlled: partially controlled software operational environment product users can access the product's interfaces and network data in transit. EC.Audit records secure storage: external hardware and software use to store audit data. EC.Timesource: a network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes.

## U.1.4 UC1 - Distribution of Security Functions

### Connectivity

COM.Local: Local communication

### Distribution

ARC.Monolithic: all components are integrated and run on a single machine or platform.; or ARC.Distributed: functions are split across multiple machines or services, often communicating over a network; or ARC.PrivateCloud: product is deployed on a private cloud where HW infrastructure as well as orchestrator layer are in control of the organisation managing the PKI); or ARC.PublicCloud: product is deployed on a public cloud where HW and orchestrator layer are managed by the cloud company.

## Interfaces

I.AuditAndAdministration: interface for remote access to for product for administration and audit purposes.

I.Registration: online registration interface receiving remote Certificates Signing Requests from subscribers.

I.ExternalKMS: interface with external components providing cryptographic services such as signature or key

management. I.CertificateStatus: online certificate status requests and dissemination. I.RevocationManagement: online

access to revocation management services (certificate revocation requests). I.NetworkServices: Interface to local

network services (secure storage, timesources, user directory)

## U.1.5 UC1 - Users

In this UC the product should be able to defined user profile restriction on function associated to the following role:

- U.Administrator: install, configure, and maintain the product, ensuring its proper operation and security.

---

## U.2 UC2 - Product for use in Private PKI for critical entities

### U.2.1 UC2 - General description

Critical entities often need to produce their own certificates to manage sensitive IT and network services. These services include VPNs, remote SSH connections, timestamp services, disk or message encryption, and PDF signatures. The deployment of such a private Public Key Infrastructure (PKI) is governed by regulatory or standardised requirements, which impose strict constraints, such as:

- Network and physical security,
- Encryption and access control of digital data,
- Incident reporting obligations,
- Compliance with secure operational practices.

As a result, users of these PKI solutions do not have the same deployment flexibility as in less regulated use cases (e.g. UC1). However, they are still permitted to use products that offer diverse functionalities.

**EXAMPLE 1:** Products deployed by telecommunications service providers used to manage proofs of identity, authorisation, and encryption to enable secure access to internal services and customer-facing networks, including e.g. 5G core and edge systems, as standardised in ETSI TS 133 501 [i.9] and ETSI GS NFV 003 [i.6]. The product is responsible for the issuance, revocation, and overall management of certificates and certificate status information (e.g. via CRLs or OCSP).

## UC2 - Private PKI for critical entities

Product functionalities  
PKI Service

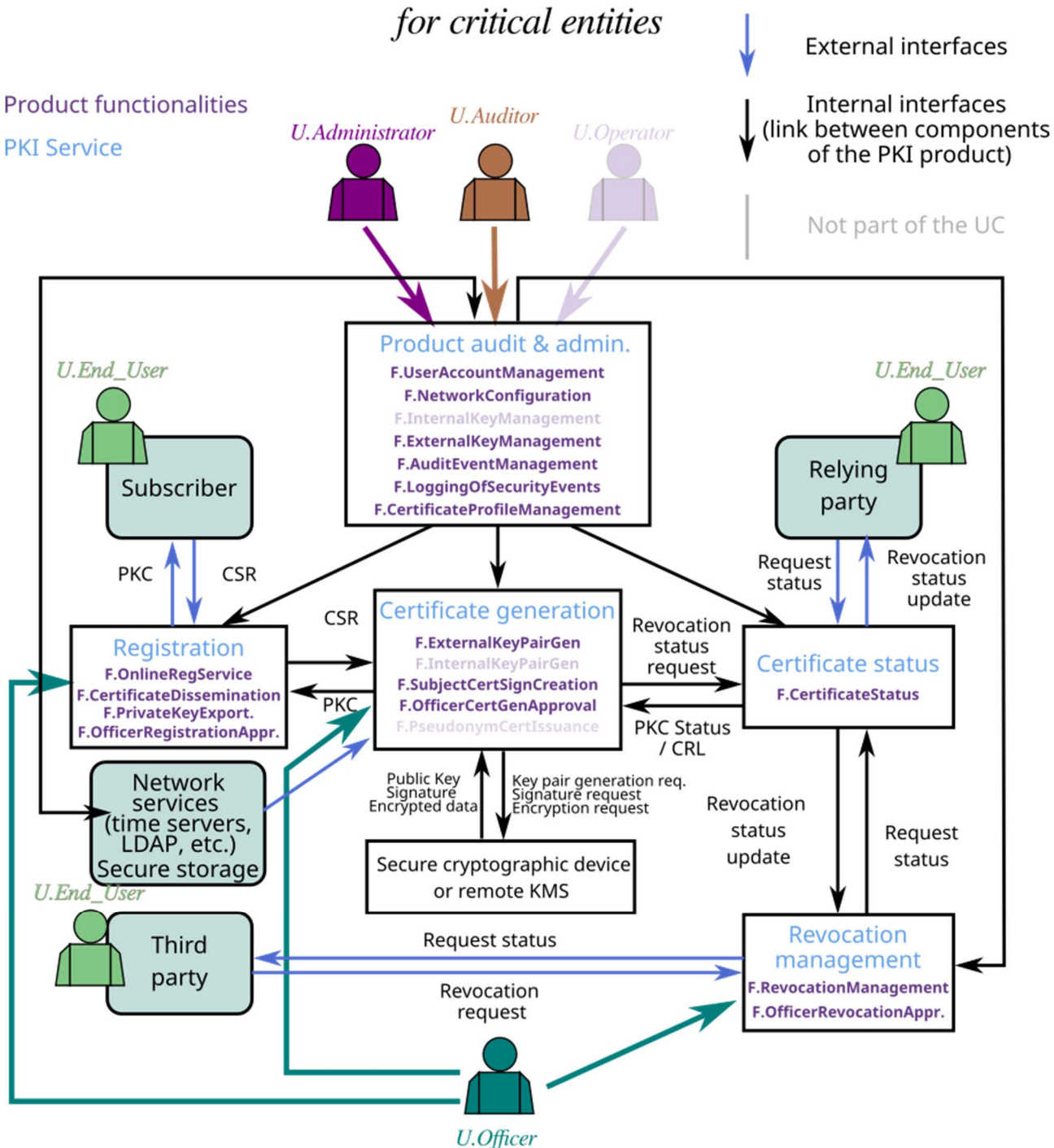


Figure U.2.1-1: UC2 functional architecture

## U.2.2 UC2 - List of functions

### Product audit & administration

F.UserAccountManagement: Creation, modification, rights attributions and modification of the different user accounts. F.Network\_Configuration: Set up of network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.). F.AuditEventManager: Configuration of audit events to be stored and their associated format. Search or erasure capabilities associated to stored audit events. F.LoggingOfSecurityEvents: For example, account access attempts, product configuration changes, and system warnings or errors. F.CertificateProfileManagement: Administration functions to define format and default values of certificates to be signed. Registration

F.OnlineRegService: A remote certificate enrolment interface (or Certificate Request Service) that enables users to submit Certificate Signing Requests (CSRs) or certificate creation requests from any network-connected device. F.CertificateDissemination: Distributes signed certificates to subscribers; and, if applicable, stores and makes them available to relying parties. F.PrivateKeyExport: Private key, secret key or critical data can be encrypted and then exported in the form of an encrypted file. F.OfficerRegistrationApproval: Explicit user (Officer) approval of registration requests.

### Certificate generation

F.SCD\_BasedKeyPairGen: Request the generation of the public-private key pair to an external SCD. F.Non\_SCD\_BasedKeyPairGen: Generates the public-private key pair. F.SubjectCertSignCreation: Creates and signs subject certificates based on the identity and other attributes verified by the registration service. F.OfficerCertGenApproval: Privileged users to approve and execute this issuance, when certificates are issued.

### Certificate status

F.CertificateStatus: Maintains certificate status information (e.g. active, expired, revoked).

### Revocation management

F.RevocationManagement: Processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service. F.OfficerRevocationApproval: Explicit user (Officer) approval of certificate revocation requests.

### U.2.2.1 UC2 - Assets

**Table U.2.2.1-1: Mapping between Functions and Assets for UC2**

| Functions                      | Assets                                                                                                |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
| F.UserAccountManagement        | SYS02.User account data                                                                               |
| F.NetworkConfiguration         | SYS01.System configuration data                                                                       |
| F.Non_SCDBasedKeyManagement    | KEY01.Keys                                                                                            |
| F.AuditEventManager            | SYS01.System configuration data                                                                       |
| F.LoggingOfSecurityEvents      | SYS03: Event log data                                                                                 |
| F.CertificateProfileManagement | SYS01.System configuration data                                                                       |
| F.OnlineRegService             | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.CertificateDissemination     | DIS01.Certificate store data<br>SYS01.System configuration data                                       |
| F.PrivateKeyExport             | KEY02.Secret Keys                                                                                     |
| F.OfficerRegistrationApproval  | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.InternalKeyManagement        | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.ExternalKeyPairGen           | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.SubjectCertSignCreation      | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.OfficerCertGenApproval       | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.CertificateStatus            | STA01.Certificate status data                                                                         |
| F.RevocationManagement         | STA01.Certificate status data                                                                         |
| F.OfficerRevocationApproval    | STA01.Certificate status data<br>SYS03.Authorised user data                                           |

## U.2.3 UC2 - Operational Environment

### Physical/Hardware

POE.FullyControlled: Fully controlled physical operational environment, where only authorised users have access to the product interfaces.

### Logical Software

SOE.FullyControlled: Fully controlled logical operational environment (segregation, least privileged, network protection e.g. firewalls/IDS/IPS/etc.). Only authorised users can access the product interfaces and network data.

### Required external components

EC.Audit records secure storage: External hardware and software use to store audit data. EC.Timesource: A network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes.

### Connectivity

COM.Local: Local communication

## U.2.4 UC2 - Distribution of Security Functions

### Distribution

- ARC.Monolithic: all components are integrated and run on a single machine or platform. or
- ARC.Distributed: functions are split across multiple machines or services, often communicating over a network. or
- ARC.PrivateCloud: product is deployed on a private cloud where HW infrastructure as well as orchestrator layer are in control of the organisation managing the PKI). or
- ARC.PublicCloud: product is deployed on a public cloud where HW and orchestrator layer are managed by the cloud company.

### Interfaces

I.AuditAndAdministration: interface for remote access to for product for administration and audit purposes.

I.Registration: online registration interface receiving remote Certificates Signing Requests from subscribers.

I.CertificateGeneration: Interface with external components providing cryptographic services such as signature or key management. I.ExternalKMS: interface with external components providing cryptographic services such as signature or key management. I.CertificateStatus: online certificate status requests and dissemination. I.RevocationManagement: online access to revocation management services (certificate revocation requests). I.NetworkServices: Interface to local network services (secure storage, timesources, user directory)

## U.2.5 UC2 - Users

In this UC the product should be able to defined user profile restriction on function associated to the following role:

- U.Administrator: Install, configure, and maintain the product, ensuring its proper operation and security.  
U.Officer (or Registration Authority Officer) Manage certificate life-cycle operations, including approvals and revocations e.g. Configure profiles, policies, and security parameters, review and approve or reject certificate requests based on policy compliance, initiate and manage certificate revocation (e.g. due to compromise, expiration, or policy violations), verify the identity and authenticity of certificate applicants, ensure that certificate issuance and revocation processes align with organisational policies. U.Auditor Authorised to monitor and review product operations logs to ensure compliance and security.

---

## U.3 UC3 - Public PKI for critical entities

### U.3.1 General description

Product used to support certification management services (registration, certificate generation, revocation and status management) provided within very large multi-site company or provided by a CA to the public, and where a compromise carries a significant risk of impact to the security of remote or unknown users, other products, networks or services, or to the health, security or safety of the public.

Such PKIs are deployed in highly controlled environments, including robust physical and logical security measures, along with strict policies and processes.



## UC3 - Public PKI for critical entities.

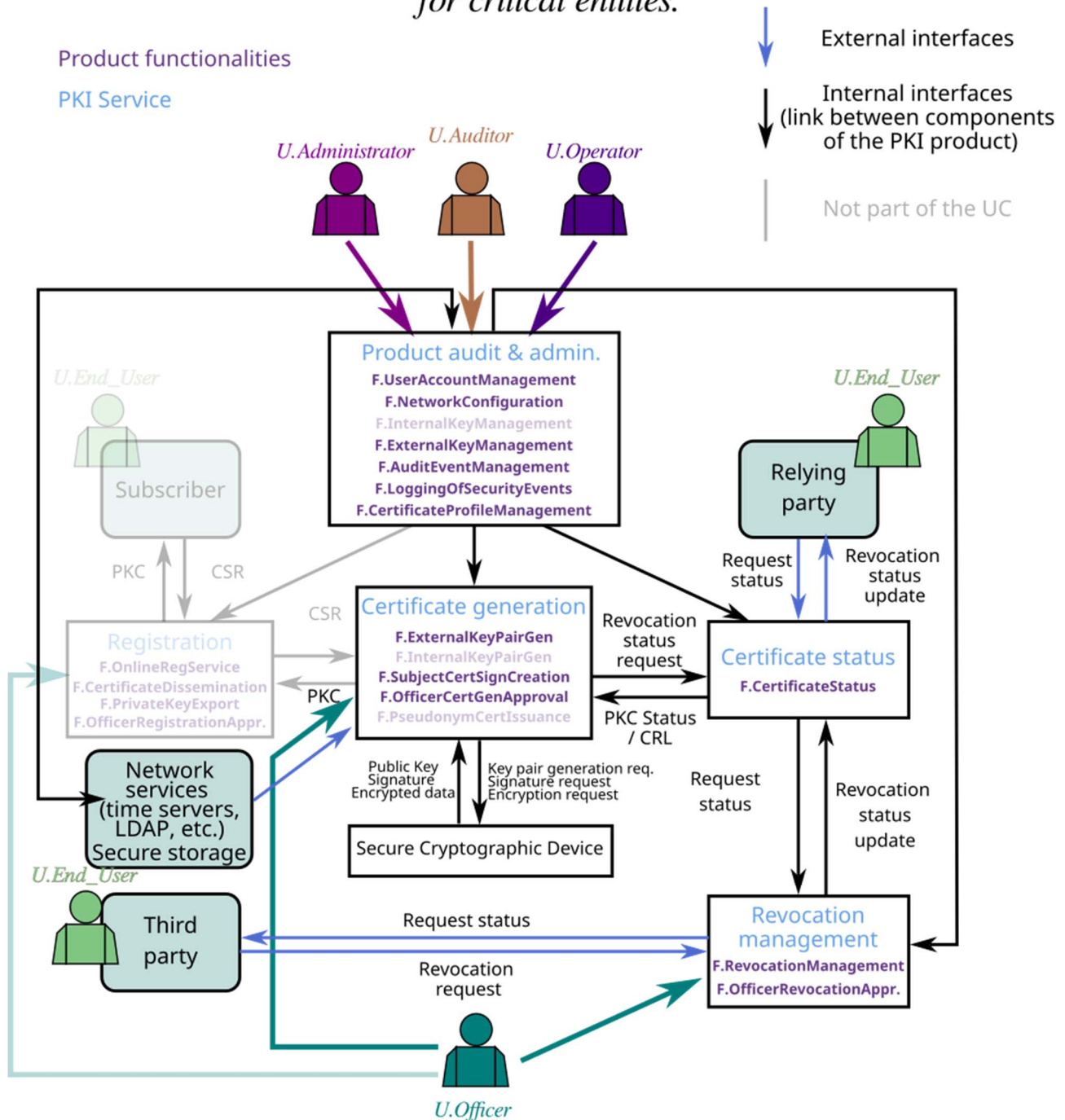


Figure U.3.1-1: UC3 functional architecture

## U.3.2 UC3 - List of functions

### Product audit & administration

F.UserAccountManagement: Creation, modification, rights attributions and modification of the different user accounts.  
 F.NetworkConfiguration: Set up of network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.).  
 F.SCD\_BasedKeyManagement: Request to the SCD for keys suppression, export, renewal.  
 F.AuditEventManager: Configuration of audit events to be stored and their associated format. Search or erasure capabilities associated to stored audit events.  
 F.LoggingOfSecurityEvents: For example, account access attempts, product configuration changes, and system warnings or errors.

F.CertificateProfileManagement: Administration functions to define format and default values of certificates to be signed.

#### Certificate generation

F.SCD\_BasedKeyPairGen: Request the generation of the public-private key pair to an external SCD.

F.SubjectCertSignCreation: Creates and signs subject certificates based on the identity and other attributes verified by the registration service F.OfficerCertGenApproval: Privileged users to approve and execute this issuance, when certificates are issued.

#### Certificate status

F.CertificateStatus: Maintains certificate status information (e.g. active, expired, revoked).

#### Revocation management

F.RevocationManagement: Processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service. F.OfficerRevocationApproval: Explicit user (Officer) approval of certificate revocation requests.

### U.3.2.1 UC3 - Assets

**Table U.3.2.1-1: Mapping between Functions and Assets for UC3**

| Functions                      | Assets                                                                                                |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
| F.UserAccountManagement        | SYS02.User account data                                                                               |
| F.NetworkConfiguration         | SYS01.System configuration data                                                                       |
| F.ExternalKeyManagement        | KEY01.Keys                                                                                            |
| F.AuditEventManager            | SYS01.System configuration data                                                                       |
| F.LoggingOfSecurityEvents      | SYS03: Event log data                                                                                 |
| F.CertificateProfileManagement | SYS01.System configuration data                                                                       |
| F.InternalKeyManagement        | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.SubjectCertSignCreation      | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.OfficerCertGenApproval       | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.CertificateStatus            | STA01.Certificate status data                                                                         |
| F.RevocationManagement         | STA01.Certificate status data                                                                         |
| F.OfficerRevocationApproval    | STA01.Certificate status data<br>SYS03.Authorised user data                                           |

### U.3.3 UC3 - Operational Environment

#### Physical/Hardware

POE.FullyControlled: Fully controlled physical operational environment, where only authorised users have access to the product interfaces. POE.SCD: The environment provides a Secure Cryptographic Device (often taking the form of an Hardware Security Module) to generate keys and provide signature support.

#### Logical Software

SOE.FullyControlled: Fully controlled logical operational environment (segregation, least privileged, network protection e.g. firewalls/IDS/IPS/etc.). Only authorised users can access the product interfaces and network data.

## Required external components

EC.Timesource: A network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes. EC.UserDirectory: A directory server that centrally stores, organises, and provides access to user, group, and resource information (e.g. authentication credentials, contact details) for networked systems and applications.

## Connectivity

COM.Public: Public communication COM.Local: Local communication.

## U.3.4 UC3 - Distribution of Security Functions

### Distribution

ARC.Monolithic: All components are integrated and run on a single machine or platform. ARC.Distributed: Functions are split across multiple machines or services, often communicating over a network. ARC.PrivateCloud: Product is deployed on a private cloud where HW infrastructure as well as orchestrator layer are in control of the organisation managing the PKI)

### Interfaces

I.LocalInterface: Local interface used by the different privileged users to access the product functionalities and data. I.AuditAndAdministration: Interface for remote access to for product for administration and audit purposes. I.CertificateGeneration: Interface with external components providing cryptographic services such as signature or key management. I.CertificateStatus: Online certificate status requests and dissemination. I.RevocationManagement: Online access to revocation management services (certificate revocation requests). I.NetworkServices: Interface to local network services (secure storage, timesources, user directory)

## U.3.5 UC3 - Users

In this UC the product should be able to defined user profile restriction on function associated to the following role:

- U.Administrator: Install, configure, and maintain the product, ensuring its proper operation and security.
- U.Operator: Performs operational tasks to ensure the availability and integrity of the product and data, e.g. execute system backups and recovery procedures to prevent data loss, monitor product health and performance, manage routine operational tasks, such as certificate issuance workflows.
- U.Officer: (or Registration Authority Officer) Manage certificate life-cycle operations, including approvals and revocations e.g. Configure profiles, policies, and security parameters, review and approve or reject certificate requests based on policy compliance, initiate and manage certificate revocation (e.g. due to compromise, expiration, or policy violations), verify the identity and authenticity of certificate applicants, ensure that certificate issuance and revocation processes align with organisational policies.
- U.Auditor: Authorised to monitor and review product operations logs to ensure compliance and security.

---

## U.4 UC4 - Product for use in Critical Public basic PKI

### U.4.1 UC4 - General description

Product used to support certification services (certificate generation, revocation and status management) provided within very large multi-site company or provided by a CA to the public, and where a compromise carries a significant risk of impact to the security of remote or unknown users, other products, networks or services, or to the health, security or safety of the public.

Such PKIs are deployed in highly controlled environments, including robust physical and logical security measures, along with strict policies and processes.

EXAMPLE: Products deployed for Trust services. Software used to issue certificates for trust services including those used in electronic attribute attestation.

### UC4 - Public Basic PKI for critical entities

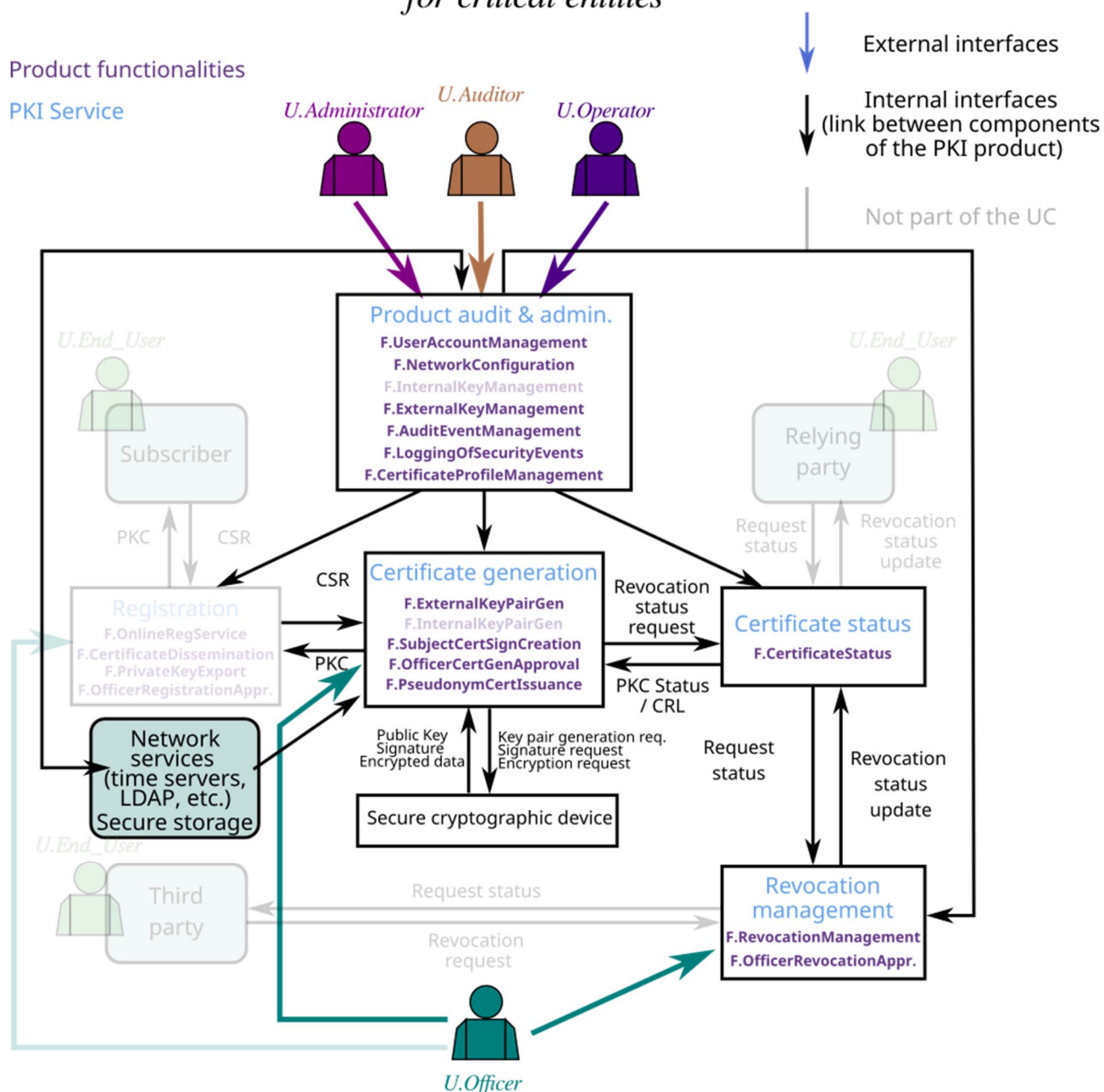


Figure U.4.1-1: UC4 functional architecture

## U.4.2 UC4 - List of functions

### Product audit & administration

F.UserAccountManagement: Creation, modification, rights attributions and modification of the different user accounts. F.NetworkConfiguration: Set up of network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.). F.NoneSCD\_BasedKeyManagement: Software keys suppression, export, renewal. F.SCD\_BasedKeyManagement: Request to the SCD for keys suppression, export, renewal. F.AuditEventManager: Configuration of audit events to be stored and their associated format. Search or erasure capabilities associated to stored audit events. F.LoggingOfSecurityEvents: For example, account access attempts, product configuration changes, and system warnings or errors. F.CertificateProfileManagement: Administration functions to define format and default values of certificates to be signed.

### Certificate generation

F.SCD\_BasedKeyPairGen: Request the generation of the public-private key pair to an external SCD. F.SubjectCertSignCreation: Creates and signs subject certificates based on the identity and other attributes verified by the registration service F.OfficerCertGenApproval: Privileged users to approve and execute this issuance, when certificates are issued.

### Certificate status

F.CertificateStatus: Maintains certificate status information (e.g. active, expired, revoked).

### Revocation management

F.RevocationManagement: Processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service. F.OfficerRevocationApproval: Explicit user (Officer) approval of certificate revocation requests.

## U.4.2.1 UC4 - Assets

**Table U.4.2.1-1: Mapping between Functions and Assets for UC4**

| Functions                      | Assets                                                                                                |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
| F.UserAccountManagement        | SYS02.User account data                                                                               |
| F.NetworkConfiguration         | SYS01.System configuration data                                                                       |
| F.ExternalKeyManagement        | KEY01.Keys                                                                                            |
| F.AuditEventManager            | SYS01.System configuration data                                                                       |
| F.LoggingOfSecurityEvents      | SYS03: Event log data                                                                                 |
| F.CertificateProfileManagement | SYS01.System configuration data                                                                       |
| F.InternalKeyManagement        | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.SubjectCertSignCreation      | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.OfficerCertGenApproval       | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.CertificateStatus            | STA01.Certificate status data                                                                         |
| F.RevocationManagement         | STA01.Certificate status data                                                                         |
| F.OfficerRevocationApproval    | STA01.Certificate status data<br>SYS03.Authorised user data                                           |

## U.4.3 UC4 - Operational Environment

### Physical/Hardware

POE.PartiallyControlled: Partially controlled physical operational environment, none product users can access the product's hardware it is installed on. POE.SCD: The environment provides a Secure Cryptographic Device (often taking the form of a Hardware Security Module) to generate keys and provide signature support. Logical Software.

SOE.PartiallyControlled Partially controlled software operational environment product users can access the product's interfaces and network data in transit. EC.Audit records secure storage: External hardware and software use to store audit data. EC.Timesource: A network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes. EC.UserDirectory: A directory server that centrally stores, organises, and provides access to user, group, and resource information (e.g. authentication credentials, contact details) for networked systems and applications. Connectivity.

COM.Public: Public communication COM.Local: Local communication.

## U.4.4 UC4 - Distribution of Security Functions

### Distribution

ARC.Monolithic: All components are integrated and run on a single machine or platform.

### Interfaces

I.LocalInterface: Local interface used by the different privileged users to access the product functionalities and data.

## U.4.5 UC4 - Users

In this UC the product should be able to defined user profile restriction on function associated to the following roles:

- U.Administrator Install, configure, and maintain the product, ensuring its proper operation and security. U.Operator Performs operational tasks to ensure the availability and integrity of the product and data, e.g. execute system backups and recovery procedures to prevent data loss, monitor product health and performance, manage routine operational tasks, such as certificate issuance workflows. U.Officer (or Registration Authority Officer) Manage certificate life-cycle operations, including approvals and revocations e.g. Configure profiles, policies, and security parameters, review and approve or reject certificate requests based on policy compliance, initiate and manage certificate revocation (e.g. due to compromise, expiration, or policy violations), verify the identity and authenticity of certificate applicants, ensure that certificate issuance and revocation processes align with organisational policies. U.Auditor Authorised to monitor and review product operations logs to ensure compliance and security.

---

## U.5 UC5 - Product for use in Critical Multi-Authority PKI

### U.5.1 General description

In general terms the multi-authority model separates the entity responsible for authentication from the entity responsible for authorisation of specific services, in like manner to the model of Kerberos [i.5] but applied to a public key system.

The multi-authority PKI is intended to combine multiple authorities in a single (extended) domain, sharing resources, and enforcing minimisation of identifying data. In like manner to Kerberos the certificate model in multi-authority PKI enables anonymous or pseudonymous proof of authority. The product in multi-authority PKIs is expected to be able to generate and distribute signed attestations of authority, to verify any received attestation of authority, and to maintain the status of stored public keys.

**EXAMPLE 1:** The PKI dedicated to Co-operative Intelligent Transport Systems (C-ITS) is used to manage proofs of authorisation and identity to enable access to services on different components of ITS systems standardised in ETSI TS 102 940 [i.16] and ETSI TS 102 941 [i.7]. The product is responsible for the issuance, revocation, and overall management of certificates and certificate status information. The PKI service architecture and its functionalities considered here are the one. The C-ITS PKI standards provide the basis for the European C-ITS trust model [i.10].

**NOTE 1:** For the C-ITS example within this use case the product requirements for the ITS-Station acting as a signature creation and verification element the European C-ITS trust model specifies that the ITS-S conforms to a specific protection profile.

**NOTE 2:** In the C-ITS model the product uses pseudonymous key pairs and cycles them rapidly and the product may need to have multiple key pairs maintained at any one time, this may place constraints on the number of private keys that have to be maintained in the product.

**EXAMPLE 2:** In a smart contract environment, such as that outlined in ETSI TR 119 540 [i.15], the chain of trust requires that a device operates within multiple trust domains across and evidenced in the use of a distributed ledger wherein some entries may be signed as proof of an attribute attestation (e.g. a contractual state transition), or signed as proof of an identity attestation (e.g. identifying the legal entity that is a smart contract stakeholder).

## UC5 - Multi-authority PKI for critical entities

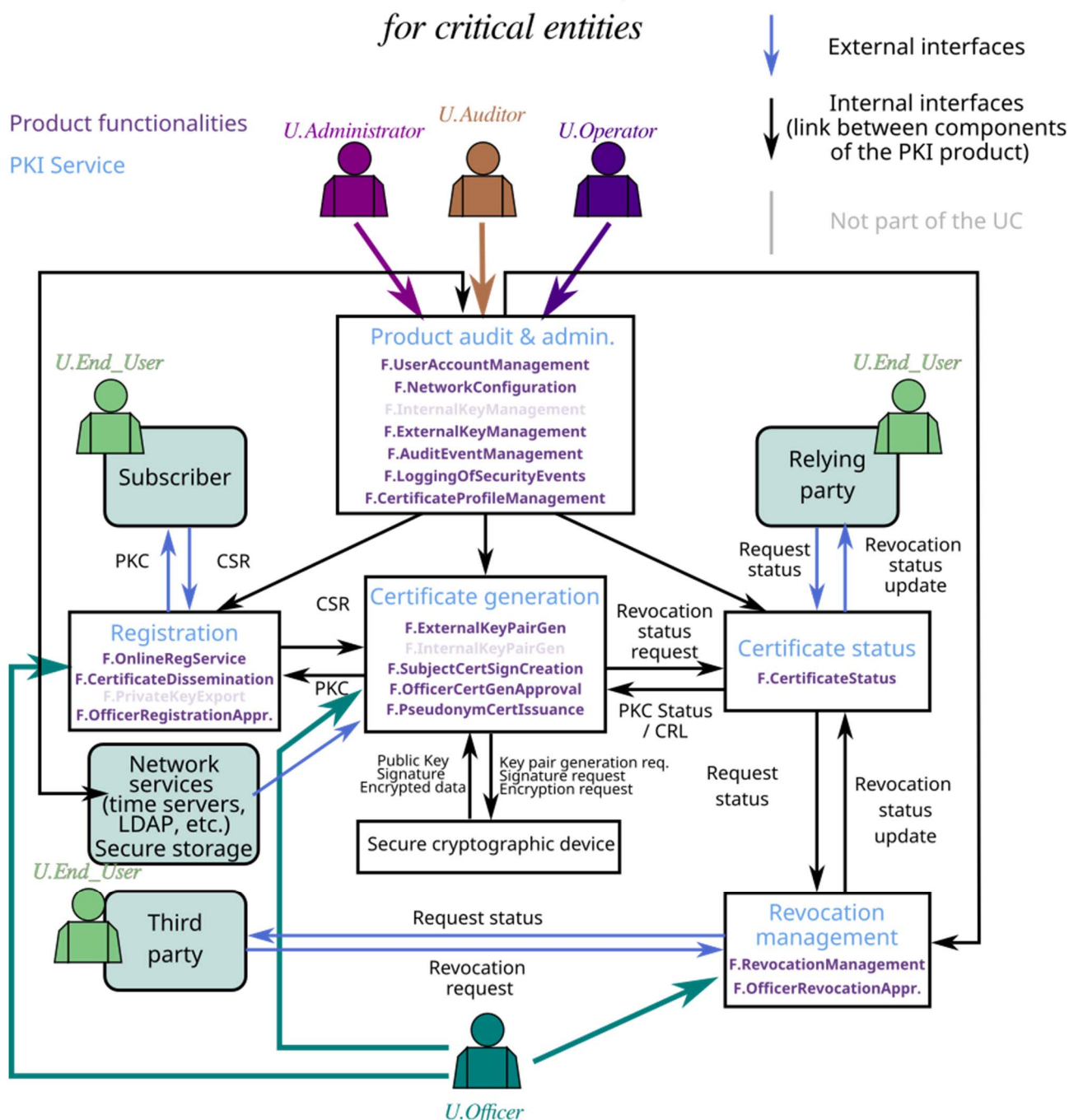


Figure U.5.1-1: UC5 functional architecture

## U.5.2 UC5 - List of functions

### Product audit & administration

F.UserAccountManagement: Creation, modification, rights attributions and modification of the different user accounts. F.NetworkConfiguration: Set up of network addresses and protocols for the different product network interfaces (management, certificate generation/revocation/status requests, etc.). F.NoneSCD\_BasedKeyManagement: Software keys suppression, export, renewal. F.SCD\_BasedKeyManagement: Request to the SCD for keys suppression, export, renewal. F.AuditEventManager: Configuration of audit events to be stored and their associated format. Search or erasure capabilities associated to stored audit events. F.LoggingOfSecurityEvents: For example, account access attempts, product configuration changes, and system warnings or errors. F.CertificateProfileManagement: Administration functions to define format and default values of certificates to be signed.



## Registration

F.OnlineRegService: A remote certificate enrolment interface (or Certificate Request Service) that enables users to submit Certificate Signing Requests (CSRs) or certificate creation requests from any network-connected device.

F.CertificateDissemination: Distributes signed certificates to subscribers; and, if applicable, stores and makes them available to relying parties. F.OfficerRegistrationApproval: Explicit user (Officer) approval of registration requests.

## Certificate generation

F.SCD\_BasedKeyPairGen: Request the generation of the public-private key pair to an external SCD.

F.SubjectCertSignCreation: Creates and signs subject certificates based on the identity and other attributes verified by the registration service F.OfficerCertGenApproval: Privileged users to approve and execute this issuance, when certificates are issued. F.PseudonymCertIssuance: Issuance of pseudonym certificates derived from long-term certificates Those certificates shall not include user identification data.

## Revocation management

F.RevocationManagement: Processes revocation requests and reports to determine the necessary action to be taken; and provides updates to the certificate status service. F.OfficerRevocationApproval: Explicit user (Officer) approval of certificate revocation requests.

## U.5.2.1 UC5 - Assets

**Table U.5.2.1-1: Mapping between Functions and Assets for UC5**

| Functions                      | Assets                                                                                                |
|--------------------------------|-------------------------------------------------------------------------------------------------------|
| F.UserAccountManagement        | SYS02.User account data                                                                               |
| F.NetworkConfiguration         | SYS01.System configuration data                                                                       |
| F.ExternalKeyManagement        | KEY01.Keys                                                                                            |
| F.AuditEventManager            | SYS01.System configuration data                                                                       |
| F.LoggingOfSecurityEvents      | SYS03: Event log data                                                                                 |
| F.CertificateProfileManagement | SYS01.System configuration data                                                                       |
| F.OnlineRegService             | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.CertificateDissemination     | DIS01.Certificate store data<br>SYS01.System configuration data                                       |
| F.OfficerRegistrationApproval  | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.InternalKeyManagement        | KEY01.Public Keys<br>KEY02.Secret Keys                                                                |
| F.SubjectCertSignCreation      | REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys                               |
| F.OfficerCertGenApproval       | SYS03.Authorised user data<br>REG02.Certificate request<br>REG01.Subscriber data<br>KEY01.Public Keys |
| F.PseudonymCertIssuance        | REG02.Certificate request<br>KEY01.Public Keys                                                        |
| F.RevocationManagement         | STA01.Certificate status data                                                                         |
| F.OfficerRevocationApproval    | STA01.Certificate status data<br>SYS03.Authorised user data                                           |

## U.5.3 UC5 - Operational Environment

### Physical/Hardware

POE.FullyControlled: Fully controlled physical operational environment, where only authorised users have access to the product interfaces. POE.SCD: The environment provides a Secure Cryptographic Device (often taking the form of an Hardware Security Module) to generate keys and provide signature support.

### Logical Software

SOE.FullyControlled: Fully controlled logical operational environment (segregation, least privileged, network protection e.g. firewalls/IDS/IPS/etc.). Only authorised users can access the product interfaces and network data.

### External component

EC.Timesource: A network server that synchronises the clocks of devices within an IT infrastructure to ensure consistent and accurate timekeeping for security, logging, and operational purposes. EC.UserDirectory: A directory server that centrally stores, organises, and provides access to user, group, and resource information (e.g. authentication credentials, contact details) for networked systems and applications.

### Connectivity

COM.Public: Public communication COM.Local: Local communication.

## U.5.4 UC5 - Distribution of Security Functions

### Distribution

ARC.Distributed: Functions are split across multiple machines or services, often communicating over a network.

### Interfaces

I.LocalInterface: Local interface used by the different privileged users to access the product functionalities and data. I.AuditAndAdministration: Interface for remote access to for product for administration and audit purposes. I.Registration: Online registration interface receiving remote Certificates Signing Requests from subscribers. I.CertificateGeneration: Interface with external components providing cryptographic services such as signature or key management. I.CertificateStatus: Online certificate status requests and dissemination. I.RevocationManagement: Online access to revocation management services (certificate revocation requests). I.NetworkServices: Interface to local network services (secure storage, timesources, user directory).

## U.5.5 UC5 - Users

In this UC the product should be able to defined user profile restriction on function associated to the following role:

- U.Administrator: Install, configure, and maintain the product, ensuring its proper operation and security. U.Operator: Performs operational tasks to ensure the availability and integrity of the product and data, e.g. execute system backups and recovery procedures to prevent data loss, monitor product health and performance, manage routine operational tasks, such as certificate issuance workflows. U.Officer: (or Registration Authority Officer) Manage certificate life-cycle operations, including approvals and revocations e.g. Configure profiles, policies, and security parameters, review and approve or reject certificate requests based on policy compliance, initiate and manage certificate revocation (e.g. due to compromise, expiration, or policy violations), verify the identity and authenticity of certificate applicants, ensure that certificate issuance and revocation processes align with organisational policies. U.Auditor: Authorised to monitor and review product operations logs to ensure compliance and security. U.End\_User: Individuals or systems that request certificates or check certificate status for authentication, encryption, or digital signing purposes.

## Annex V (informative): Change history

| Version   | Information about changes                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V 0.0.7   | editHelp provision                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| V 0.0.7.1 | Update of agreed changes regarding resolution of comments in TF CR #06                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| V 0.0.7.2 | Update of changes regarding <b>proposal</b> of solution of comments in TFCR #07 and editorial changes                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| V 0.0.8.3 | (BSI): Updates following the meeting #8<br>(IOTR): Editorial improvements clarifications to Annex K, including refinement of assessment wording, clarification of evidence expectations for PASS/FAIL verdicts, and minor corrections to crypto-agility assessment criteria, without changing the agreed structure or technical intent of the annex.<br>(Qualcomm): contribution addressing some limitations of the current version of Annex K                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| V 0.0.8.4 | Targeted consistency updates to align K.1.2 with the three CRY-SOTA routes defined in K.1.1; clarification of assessment objectives, preparation, activities, evidence and PASS/FAIL verdicts; refinement of stability, vulnerability and crypto-agility wording; integration of relevant generic assessment improvements identified from a vertical Annex K customisation; removal of actor-specific assessment wording; harmonisation of assessment structure across K.1.2.1, K.1.2.2 and K.2.2; review of EC and Google comments and integration of corresponding resolutions where agreed, including clarification that documentation review is a minimum assessment activity, refinement of the stability-period criterion, and clarification of publicly available specifications and catalogues; and editorial consistency improvements while preserving the agreed Annex K structure.                                                                                             |
| V 0.0.8.5 | Restructuring of Annex K to distinguish ACM-listed, ACM-extended and interoperability-based cryptographic mechanisms; replacement of "cryptographic algorithm" by "cryptographic mechanism" where needed; clarification of terms and definitions, including cryptographic mechanism, cryptographic property and interoperability; refinement of Application Guidance for vertical standards and rapporteurs; separation between rapporteur selection criteria in K.1.1 and product assessment in K.1.2; update of K.1.2 assessment cases to focus on the product's default cryptographic configuration; update of K.2 crypto-agility requirement and assessment; introduction of K.3 and K.4 clauses for ACM-extended and interoperability-based cryptographic mechanisms, including template tables and guidance for cases where no items are specified; and editorial clean-up to remove obsolete state-of-the-art route terminology and align references across K.1, K.2, K.3 and K.4. |
| V 0.0.8.6 | Integration of comments received on v0.0.8.5, including terminology alignment with the ACM by replacing "cryptographic item" with "cryptographic mechanism"; replacement of "product mechanism" with "product function"; clarification of the scope of Note 4 regarding cryptographic protocols versus primitives, modes of operation, constructions, parameter sets and cipher suites; restructuring of K.1.1 into a simplified product-facing requirement; transfer of ACM-extended and interoperability-based selection criteria to K.3.1 and K.4.1; clarification of the use of national cryptographic catalogues and introduction of a placeholder for the list of recognised organisations pending validation; and corresponding updates to K.1.2, K.2, K.3 and K.4 assessment and guidance text.                                                                                                                                                                                   |

| Version   | Information about changes                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V 0.0.8.7 | <p>Version prepared for EUSR endorsement.</p> <p>Integration of European Commission comments on v0.0.8.6, including clarification in the application guidance that applicable vertical standards may define additional or more specific requirements, assessment activities, assessment evidence or assessment criteria where needed for the relevant product category, product function, use case or risk profile; addition of use-case references where relevant, including in the guidance for completing clauses K.3.1 and K.4.1 and in the K.3.1/K.4.1 table structures; clarification that ACM-extended cryptographic mechanisms may include sector-specific cryptographic mechanisms not explicitly listed in the ACM catalogue, including sector-specific profiles, restrictions or configurations of ACM-listed mechanisms; clarification that K.3.1 provides a complementary route to the ACM and that listing an organisation in the selection criteria does not by itself make a mechanism ACM-extended; update of recognised organisation examples to include sector-specific standards development organisations and industry specification organisations such as 3GPP and O-RAN Alliance; clarification of the term "external requirement" for interoperability-based cryptographic mechanisms, including regulatory, procurement, customer, deployment, technical interoperability and platform compatibility requirements; addition of a note explaining that conditions or limitations are necessary for the secure and constrained use of interoperability-based cryptographic mechanisms; definition of "migration condition"; update of the crypto-agility requirement and assessment to refer to deprecation dates, expiry dates, migration conditions and usage limitations specified by the ACM catalogue or the applicable vertical standard; replacement of "supported use" by wording based on limiting the use of affected product functions; and corresponding consistency updates across K.1.1, K.1.2, K.2, K.3 and K.4.</p> |
| V1.0r1    | <p>Version prepared for endorsement following resolution of all comments received on Annex K v0.0.8.7. The update integrates agreed comment resolutions and consistency improvements across the whole annex, including clarification of the treatment of cryptographic protocols and their underlying primitives, modes of operation, constructions, parameter sets and cipher suites; refinement of the K.1.1 product-facing requirement; addition of the corresponding assessment case in K.1.2 for protocols not explicitly listed; restructuring of K.3 and K.4 to separate rapporteur guidance, requirements, lists and assessment references; clarification that ACM-extended and interoperability-based mechanisms are selected through the vertical-standard tables and not through manufacturer self-classification; alignment of terminology with the ECCG ACM; removal or replacement of ambiguous "may" and "should" wording where needed; clarification of default configuration, lifecycle and crypto-agility treatment; and editorial consistency updates to notes, editor's notes, table references and cross-references.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| V1.1      | <p>Version prepared for endorsement following resolution of the comments received on Annex K V1.0 r1 during the EUSR #35 joint ETSI / CEN-CENELEC meeting. The update introduces a controlled criteria-based ACM-extended route for cryptographic mechanisms not explicitly listed in the ACM catalogue and not listed in clause K.3.2; aligns the corresponding assessment case in K.1.2.2; restructures K.3 and K.4 to distinguish rapporteur guidance, requirements, lists and assessment references; and includes editorial consistency updates to notes, editor's notes, table references and cross-references.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| V1.2      | <p>The update clarifies the ACM-extended route in clause K.1.1 item 2 by removing the reference to the criteria in item 2.b from item 2.a, confirming that mechanisms listed in clause K.3.2 are accepted through the K.3.2 route, while the criteria in item 2.b apply where the mechanism is not listed in clause K.3.2. The corresponding rapporteur guidance remains in clause K.3.0.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

---

# History

| Version | Date        | Status                                              |
|---------|-------------|-----------------------------------------------------|
| V1.0.0  | August 2026 | SRdAP process EV 20261029: 2026-08-06 to 2026-10-29 |
|         |             |                                                     |
|         |             |                                                     |
|         |             |                                                     |
|         |             |                                                     |